

1. Introduzione

Concetti di sicurezza

Computer security: la protezione offerta a un sistema informativo automatizzato al fine di preservare l'**integrità**, la **disponibilità** e la **riservatezza** delle sue risorse (hardware, software, firmware, informazioni/dati).

La definizione introduce i 3 obiettivi principali della materia:

- **Riservatezza** (Confidentiality): articolata in
 - **Riservatezza dei dati:** assicura che le informazioni private o confidenziali non siano rese disponibili o divulgate a individui non autorizzati.
 - **Privacy:** assicura che gli individui controllino quali loro informazioni possono essere raccolte e archiviate, da chi e a chi esse possano essere divulgate.

Perdita di riservatezza → divulgazione non autorizzata di informazioni.

- **Integrità:** articolata in
 - **Integrità dei dati:** assicura che i dati (sia archiviati che trasmessi) e i programmi siano modificati solo in modo specificato e autorizzato.
 - **Integrità del sistema:** assicura che il sistema svolga la sua funzione in maniera inalterata, libero da una sua manipolazione deliberata o involontaria.

Perdita di integrità → modifica o distruzione non autorizzata di informazioni.

- **Disponibilità** (Availability): assicura che i sistemi lavorino velocemente e che il servizio non sia negato a utenti autorizzati.

Perdita di disponibilità → interruzione dell'accesso o dell'uso di un sistema informativo.

Ci si riferisce a questi tre concetti come **triade CIA**.

Architettura di sicurezza OSI (X.800)

Per stimare le necessità di sicurezza di un'organizzazione c'è bisogno di un modo sistematico per definire i requisiti di sicurezza e gli approcci per soddisfarli. L'architettura di sicurezza OSI è stata sviluppata a questo scopo come standard internazionale; essa si concentra su:

- **Attacchi alla sicurezza:** ogni azione che compromette la sicurezza delle informazioni possedute da un'organizzazione;
- **Meccanismi di sicurezza:** i processi (o i dispositivi che incorporano tali processi) progettati per rilevare, prevenire o recuperare da un attacco;

- **Servizi di sicurezza:** un servizio di elaborazione o comunicazione che migliora la sicurezza di un sistema di elaborazione dati e del trasferimento di informazioni di un'organizzazione.

Attacchi

Possono essere classificati in passivi e attivi.

Attacchi passivi

Hanno lo scopo di ottenere informazioni da un sistema senza influenzarne le risorse. Possono essere intercettazioni o monitoraggi di trasmissioni.

Due tipi di attacchi passivi sono:

- **Intercettazione dei messaggi**
- **Analisi del traffico:** supponiamo di avere un modo per mascherare il contenuto dei messaggi, chi attacca può determinare gli indirizzi degli host che comunicano e ricavare un pattern della conversazione.

Gli attacchi passivi sono difficili da individuare in quanto le comunicazioni si svolgono normalmente.

Attacchi attivi

Hanno lo scopo di modificare il flusso dati o di creare falsi flussi; possono essere suddivisi in 4 categorie:

- **Mascheramento:** si verifica quando un'entità (della comunicazione o del servizio) si autentica come un'altra; spesso questo attacco ne include anche altri attivi.
- **Ripetizione:** consiste nell'acquisizione passiva di dati e la loro ritrasmissione per causare effetti dannosi
- **Modifica dei messaggi:** consiste nella modifica, nel ritardo o nel riordinamento dei messaggi in modo da causare effetti dannosi.
- **Denial-of-service:** previene o inibisce il normale uso dei sistemi di comunicazione. Questo attacco potrebbe essere indirizzato verso un preciso target o verso un'intera rete.

2. CRITTOGRAFIA - cifratura simmetrica e confidenzialità dei messaggi

📋 Obiettivi

- panoramica dei concetti principali della crittografia simmetrica
- differenza tra crittoanalisi e attacchi brute-force
- funzionalità DES
- panoramica di AES
- concetti di randomicità e imprevedibilità dei numeri randomici
- panoramica dei cifrari a flusso e di RC4
- comparazione di ECB, CBC, CFB

Disciplina che si occupa dei metodi per rendere un messaggio non comprensibile a persone non autorizzate a leggerlo.

Cifratura simmetrica

Metodo per cifrare un testo dove la chiave di crittazione è anche quella di decrittazione. Uno schema di cifratura simmetrica è costituito da 5 parti:

- **Testo:** messaggio originali o dati forniti in input all'algoritmo
- **Algoritmo di cifratura:** effettua varie sostituzioni e trasformazioni del testo
- **Chiave segreta:** input dell'algoritmo, da essa dipendono le sostituzioni effettuate
- **Testo cifrato:** testo prodotto come output
- **Algoritmo di decrittazione:** lo stesso algoritmo di cifratura che prende in input il testo cifrato e la chiave e produce il testo originario.

I requisiti per usare un algoritmo di cifratura simmetrica in modo sicuro sono:

1. Abbiamo bisogno di un algoritmo forte: l'opponente non deve essere in grado di decifrare il testo cifrato o scoprire la chiave essendo in possesso di un certo numero di testi cifrati e dei testi che li hanno prodotti. (Ho molte coppie testo di input, testo di output e voglio scoprire la chiave)
2. Le parti principali devono aver ottenuto la chiave in modo sicuro.

La sicurezza di questo metodo dipende dalla segretezza della chiave, non da quella dell'algoritmo.

Crittografia

I sistemi di crittografia sono classificati considerando:

- **Il tipo di operazioni utilizzate per trasformare il testo:** tutti gli algoritmi di cifratura sono basati su due principi: **sostituzione**, ogni elemento del testo originario viene mappato in un altro; e **trasposizione**, gli elementi del testo sono riarrangiati. Il requisito fondamentale è che nessuna informazione venga persa.
- **Il numero di chiavi usate:** se entrambe le parti usano la stessa chiave il sistema viene chiamato simmetrico, a chiave singola, a chiave segreta o convenzionale; se usano chiavi diverse il sistema viene detto asimmetrico, a chiave doppia, o a chiave pubblica.
- **Il modo in cui il testo viene processato:** un algoritmo di cifratura **a blocchi** suddivide il testo in sezioni e produce tanti blocchi in output, un algoritmo di cifratura **a flusso** processa l'input in maniera continua producendo un elemento dell'output alla volta.

Crittoanalisi

Processo tramite cui si cerca di scoprire il testo originale o la chiave. Le tattiche di crittoanalisi dipendono dalle informazioni disponibili, nel caso peggiore si ha a disposizione solo il testo cifrato. Nel caso in cui si conosca l'algoritmo di cifratura è possibile tentare un attacco brute-force, provando tutte le chiavi.

Type of Attack	Known to Cryptanalyst
Ciphertext only	■ Encryption algorithm ■ Ciphertext to be decoded
Known plaintext	■ Encryption algorithm ■ Ciphertext to be decoded ■ One or more plaintext–ciphertext pairs formed with the secret key
Chosen plaintext	■ Encryption algorithm ■ Ciphertext to be decoded ■ Plaintext message chosen by cryptanalyst, together with its corresponding ciphertext generated with the secret key
Chosen ciphertext	■ Encryption algorithm ■ Ciphertext to be decoded ■ Purported ciphertext chosen by cryptanalyst, together with its corresponding decrypted plaintext generated with the secret key
Chosen text	■ Encryption algorithm ■ Ciphertext to be decoded ■ Plaintext message chosen by cryptanalyst, together with its corresponding ciphertext generated with the secret key ■ Purported ciphertext chosen by cryptanalyst, together with its corresponding decrypted plaintext generated with the secret key

Un schema di cifratura viene detto computazionalmente sicuro se soddisfa almeno uno dei seguenti criteri:

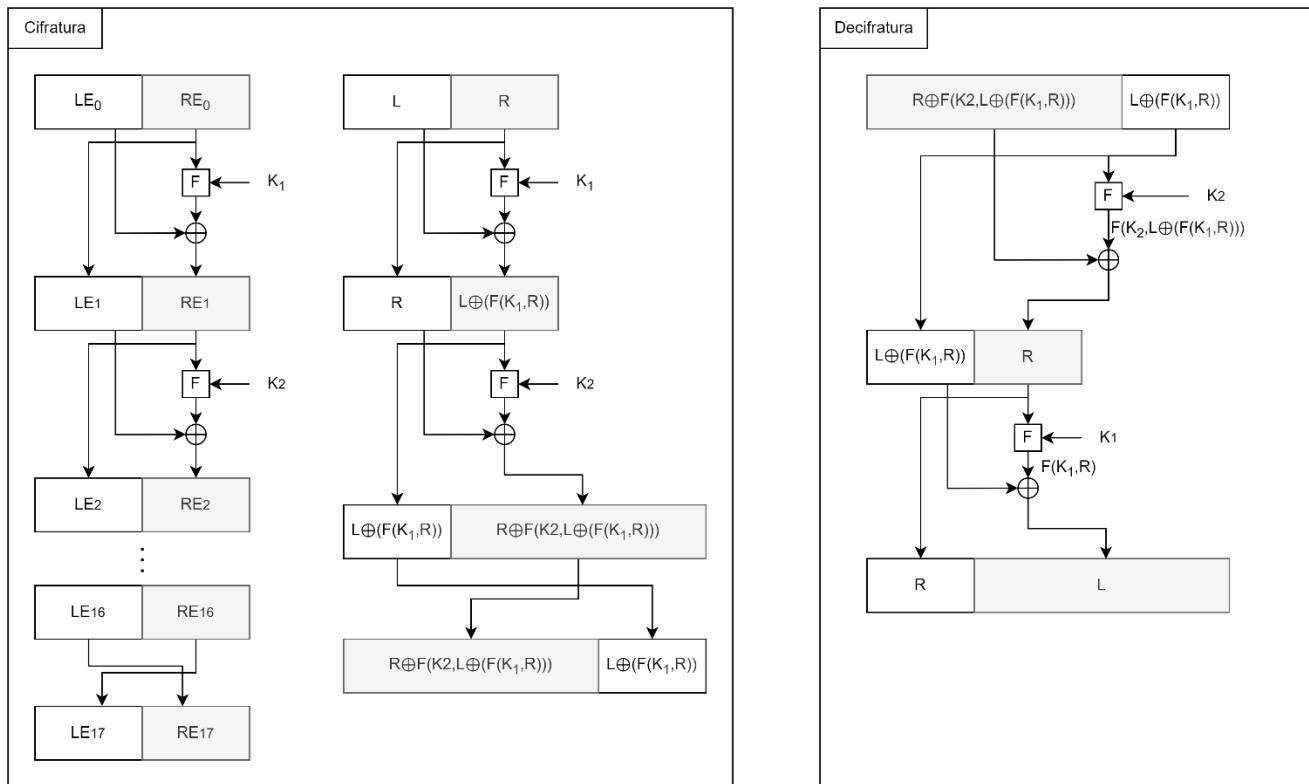
- Il costo per la violazione è maggiore del valore dell'informazione cifrata
- Il tempo richiesto per la violazione eccede il tempo di vita utile dell'informazione

Per stimare il costo della violazione è possibile testare lo schema con un attacco brute-force.

Cifrario di Fiestel

Struttura per realizzare un algoritmo di cifratura a blocchi.

L'input dell'algoritmo è costituito da un blocco del testo di lunghezza $2w$ e dalla chiave K . Il blocco viene diviso in due metà, LE_0 e RE_0 ; queste due parti passano attraverso n step di cifratura e sono poi combinate per produrre il blocco in output.



Ogni round i ha come input LE_{i-1} e RE_{i-1} prodotti dal round precedente e la sottochiave K_i . Le sottochiavi sono diverse da K e tra loro e sono generate da un algoritmo.

Tutti i round hanno la stessa struttura: viene applicata la *funzione del round* F alla parte destra e si mette il risultato in XOR con la parte sinistra. F ha la stessa struttura per ogni round ma viene parametrizzata da K_i . Dopo questa sostituzione viene effettuata una permutazione che consiste nello scambio di posizione delle due parti del blocco.

La struttura di Fiestel è un caso particolare di una struttura generale che viene usata in tutti gli algoritmi simmetrici a blocchi. In generale si hanno n round, ognuno dei quali effettua sostituzioni e

permutazioni condizionate dalla chiave. Le particolari realizzazioni dipendono dalla lunghezza dei blocchi, la lunghezza della chiave (comune 128 bit), numero di round (da 10 a 16), algoritmo di generazione delle sottochiavi, funzione di round, facilità di analisi.

La struttura permette di decifrare il messaggio semplicemente rimettendolo in input.

Algoritmi di cifratura simmetrica a blocchi

I più importanti sono: il Data Encryption Standard (DES), il triple DES (3DES), l'Advanced Encryption Standard (AES).

Data Encryption Standard

Principale algoritmo fino all'introduzione del AES (2001).

Descrizione dell'algoritmo: i blocchi sono da 64 bit e la chiave da 56; è una variazione della struttura di Fiestel, ci sono 16 round.

È stato dimostrato insicuro nel 1998.

Triple DES

usa tre chiavi e 3 esecuzioni di DES; segue lo schema cifratura-decifratura-cifratura

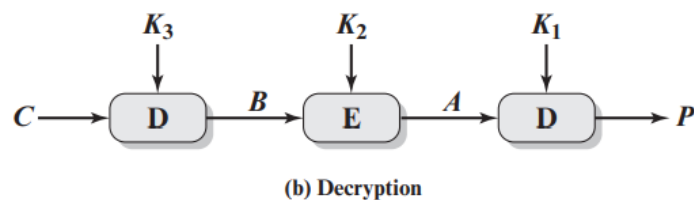
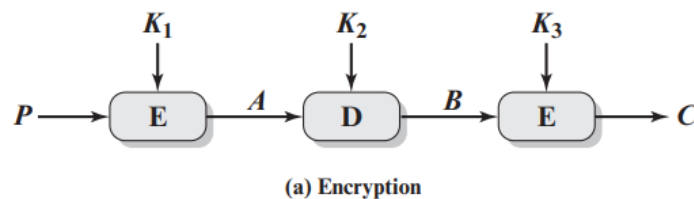
$$C = E(K_3, D(K_2, E(K_1, P)))$$

C = ciphertext

P = plaintext

$E[K, X]$ = encryption of X using key K

$D[K, Y]$ = decryption of Y using key K

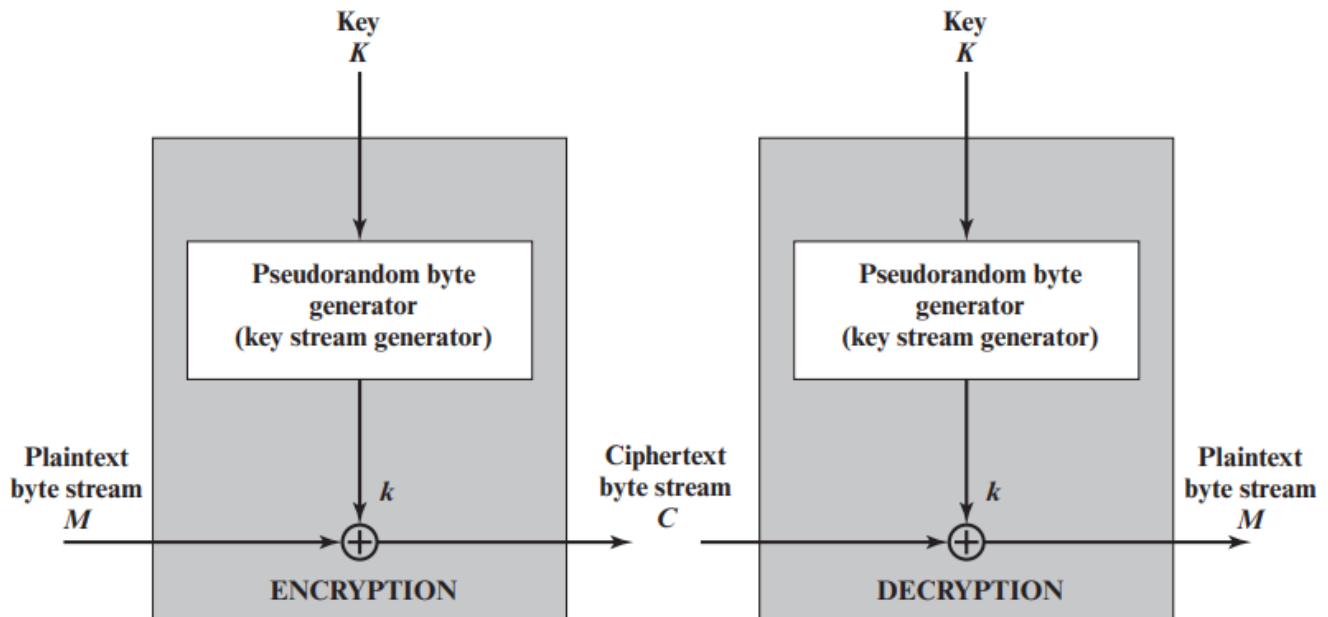


La lunghezza effettiva della chiave è 168 bit. Attualmente approvato ma è stato soppiantato da AES, molto più efficiente.

Advanced Encryption Standard

Blocchi lunghi 128bit, supporta chiavi di 128, 192 e 256 bit.

Cifrari a flusso



Solitamente lavorano con input di un byte, ma possono lavorare anche con input di un bit.

Una chiave K viene messa in input a un generatore pseudorandomico di byte, il suo output viene detto **keystream** e viene combinato un byte alla volta con il testo utilizzando l'operazione XOR

Modalità di funzionamento dei cifrari a blocchi

Per applicare la cifratura a blocchi a una varietà di applicazioni sono state definite diverse modalità di funzionamento che dovrebbero coprire tutti i possibili casi d'uso.

Electronic codebook ECB

Il testo viene processato b bit alla volta e cifrato utilizzando la stessa chiave. Due blocchi che contengono lo stesso testo producono lo stesso output visto che vengono cifrati utilizzando la stessa chiave. Critico nel caso in cui il plaintext contenga delle regolarità.

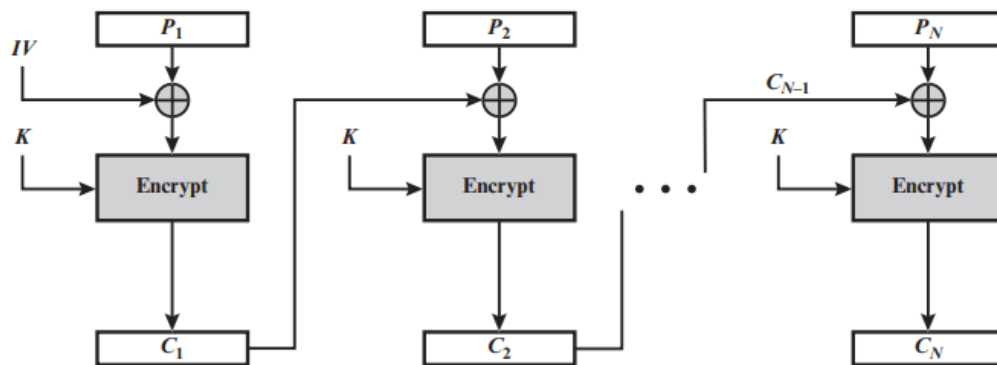
Cipher block chaining CBC

L'input dell'algoritmo è lo XOR del blocco del plaintext corrente e dell'output del blocco precedente. Viene usata la stessa chiave per ogni blocco.

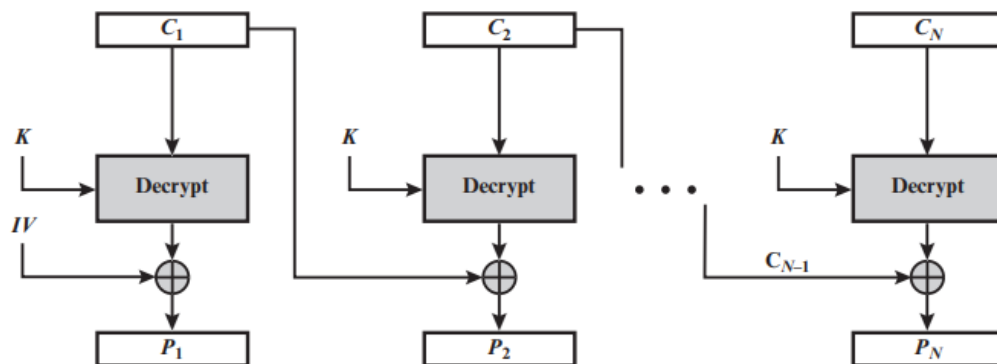
IV = vettore di inizializzazione

La cifratura di un blocco dipende da quella del blocco precedente → no parallelizzazione

Vulnerabilità: se un attaccante modifica un blocco, esso e tutti i blocchi successivi non verranno decifrati correttamente dal destinatario.



(a) Encryption



(b) Decryption

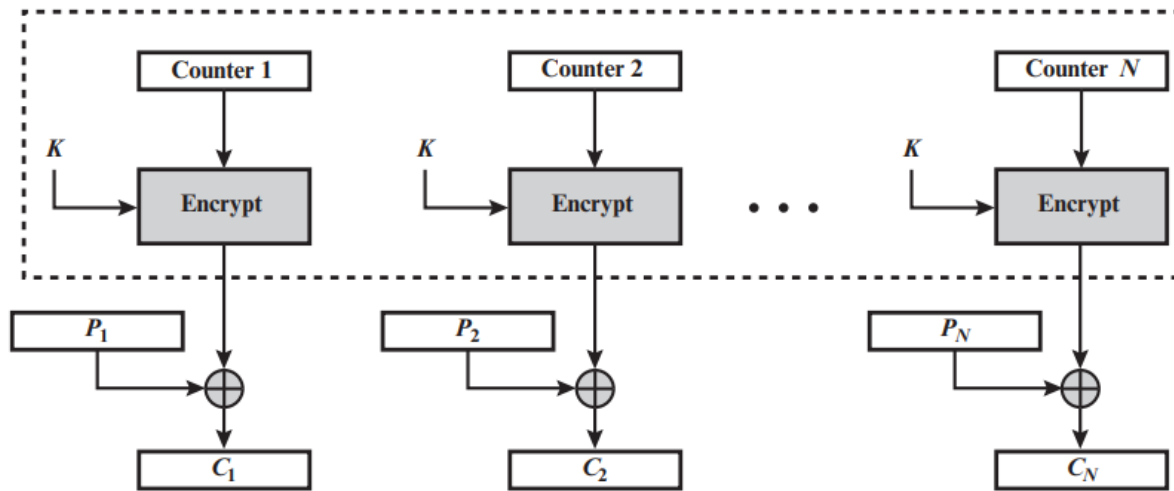
Counter CTR

Viene utilizzato un counter di dimensione uguale a quella del blocco, esso viene incrementato di uno ad ogni blocco processato.

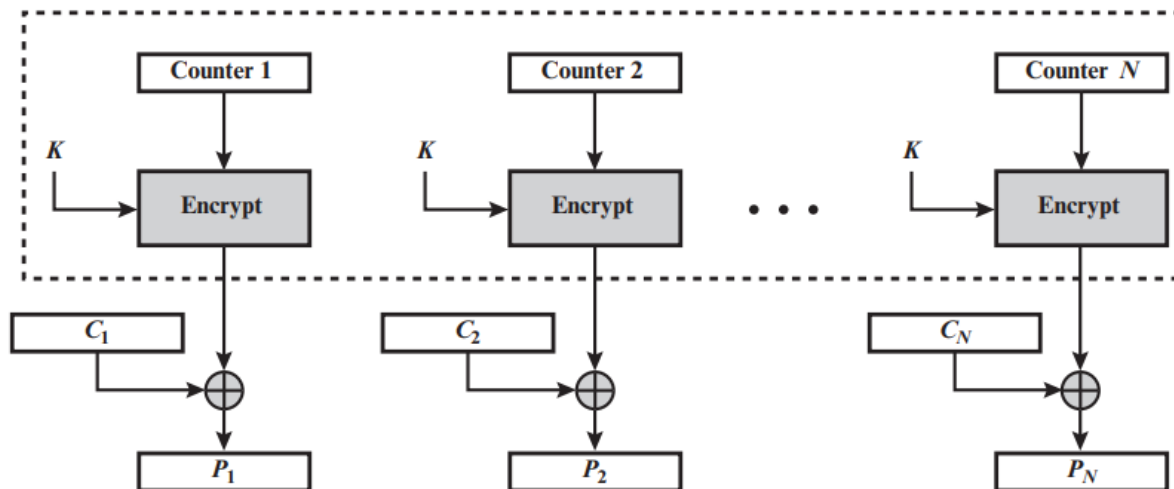
Il counter viene cifrato con la chiave, la stessa per tutti i blocchi e il risultato viene messo in XOR con il blocco.

Il counter deve essere utilizzato solo una volta.

Blocchi con lo stesso contenuto producono output diversi, approccio parallelizzabile, le cifratura dei blocchi è indipendente.



(a) Encryption



(b) Decryption

Visto che il counter è pubblico la segretezza del metodo è assicurata dalla chiave (simmetrica che deve essere condivisa in maniera sicura tra gli interlocutori).

03 CRITTOGRAFIA - crittografia a chiave pubblica e autenticazione dei messaggi



Obiettivi

- saper definire il termine **codice di autenticazione dei messaggi**
- elencare e spiegare i requisiti di un codice di autenticazione dei messaggi
- spiegare perché la funzione di hash usata per i codici di aut. dei mess. deve essere protetta
- capire le differenze tra resistenza alla preimmagine, resistenza alla seconda preimmagine e resistenza alla collisione
- capire il funzionamento di SHA-512
- panoramica di HMAC
- panoramica dei principi base dei sistemi crittografici a chiave pubblica
- spiegare i due usi dei sistemi crittografici a chiave pubblica
- panoramica dell'algoritmo RSA
- definire lo scambio di chiavi Diffie-Hellman
- comprendere l'attacco man-in-the-middle

Approcci

La crittografia protegge contro gli attacchi passivi (intercettazioni). La protezione contro gli attacchi attivi (falsificazione di dati e transazioni) è conosciuta come autenticazione dei messaggi.

Un messaggio, un file, un documento o un'altra collezione di dati viene detta autentica quando è il suo contenuto non è stato alterato e proviene dalla sorgente dichiarata. L'autenticazione dei messaggi è una procedura che permette alle parti in comunicazione di verificare l'autenticità del messaggio ricevuto.

Autenticazione tramite cifratura convenzionale

L'autenticazione tramite cifratura simmetrica consiste nella cifratura da parte del mittente del messaggio tramite una chiave condivisa con il destinatario; solo il destinatario dovrebbe essere in grado di decifrare correttamente il messaggio.

Questa modalità espone al rischio di riordinamento dei blocchi da parte di un terzo, nel caso in cui i blocchi fossero riordinati il destinatario li decifrerebbe comunque con successo.

Se il messaggio contiene un codice di error-detection e un numero di sequenza, il destinatario è sicuro che non ci sono state alterazioni e che la sequenza è arrivata in ordine.

Se il messaggio include anche un timestamp, il destinatario è sicuro che il messaggio non sia stato ritardato.

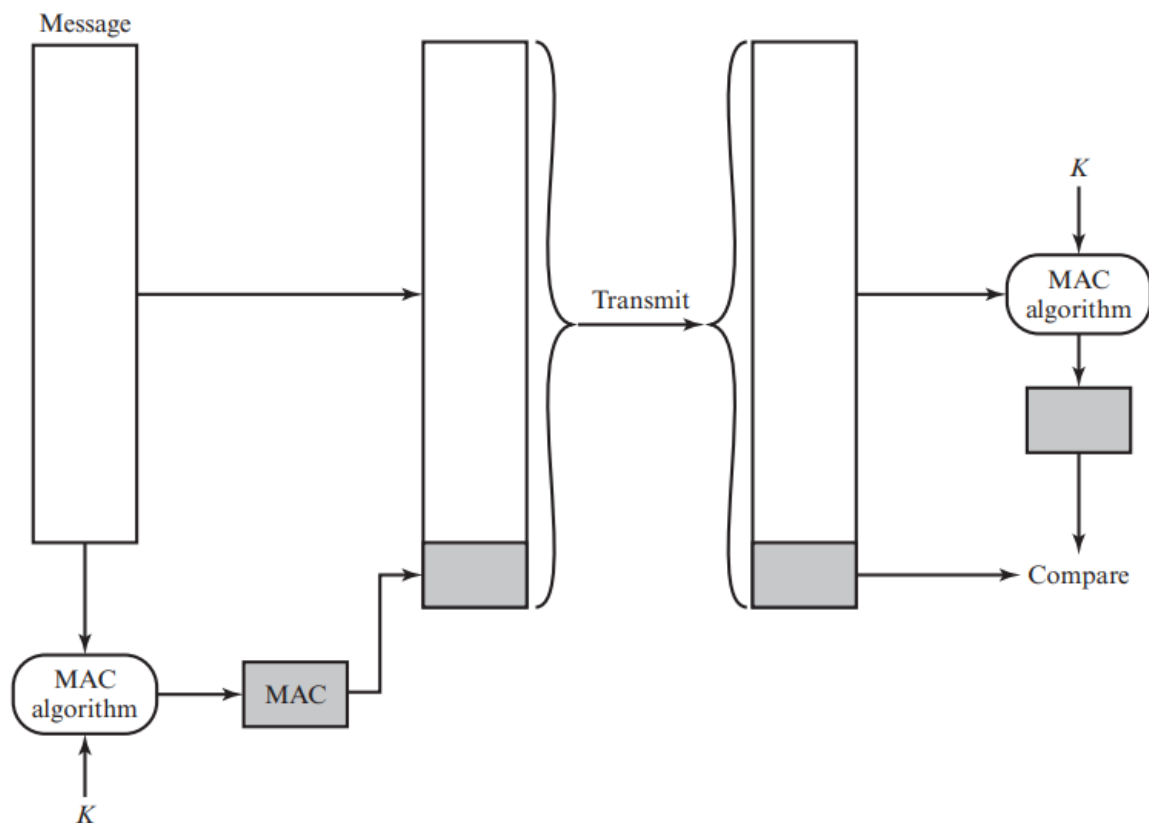
Autenticazione senza cifratura dei messaggi

Tutti gli approcci esaminati in seguito non cifrano il messaggio quindi non garantiscono confidenzialità; tutti prevedono che venga generato un tag di autenticazione, appeso a ogni messaggio trasmesso.

Si può combinare autenticazione e confidenzialità in un singolo algoritmo che cifra il messaggio e genera i tag di autenticazione.

Codice di autenticazione dei messaggi:

prevede che venga usata una chiave segreta per generare un piccolo blocco di dati detto message authentication code (MAC), che viene appeso al messaggio. Assumiamo che le parti che comunicano condividano una chiave segreta K ; quando A invia un messaggio a B calcola il MAC come funzione della chiave e del messaggio stesso: $MAC = F(K, M)$. B esegue lo stesso processo e confronta il suo MAC con quello contenuto nel messaggio ricevuto.



Se un attaccante alterasse il messaggio e non il MAC, il MAC calcolato da B non coinciderebbe con quello presente nel messaggio; se solo A e B conoscono la chiave segreta, nel momento in cui i due MAC coincidono, B è sicuro che il mittente sia A; se il messaggio contiene un numero di sequenza allora B è sicuro che i messaggi non sono stati riordinati.

Diversi algoritmi possono essere usati per generare il tag di autenticazione, come ad esempio il DES, il messaggio viene cifrato tramite DES e gli ultimi 16 o 32 bit sono usati come tag.

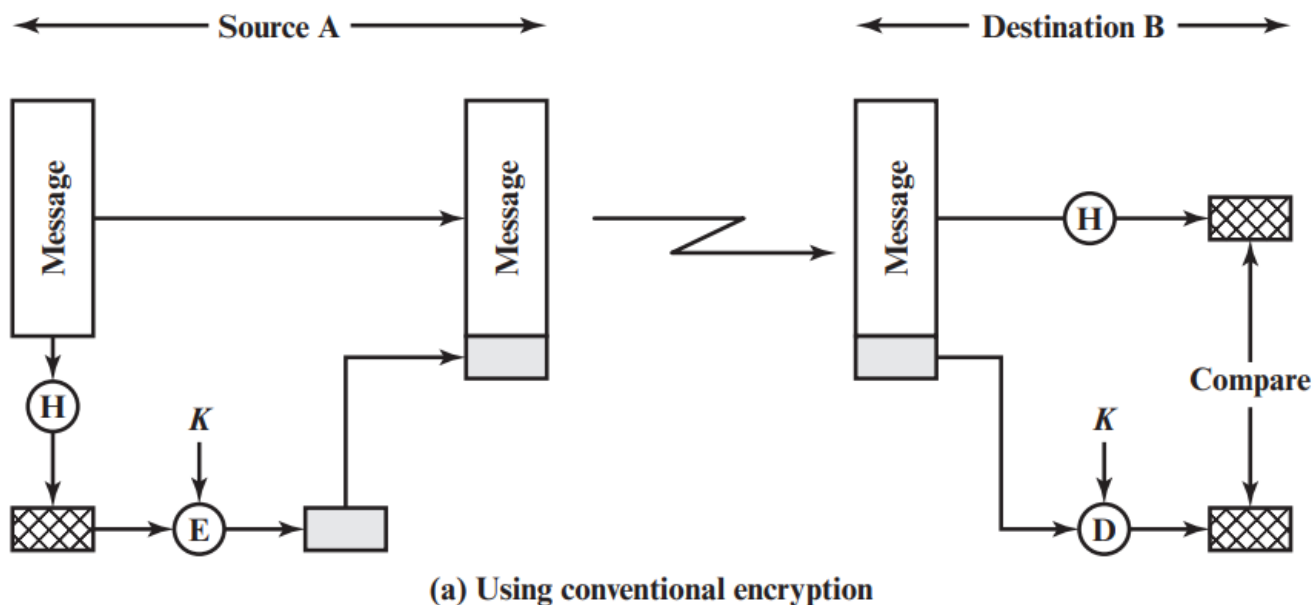
One-way hash function:

alternativa al MAC

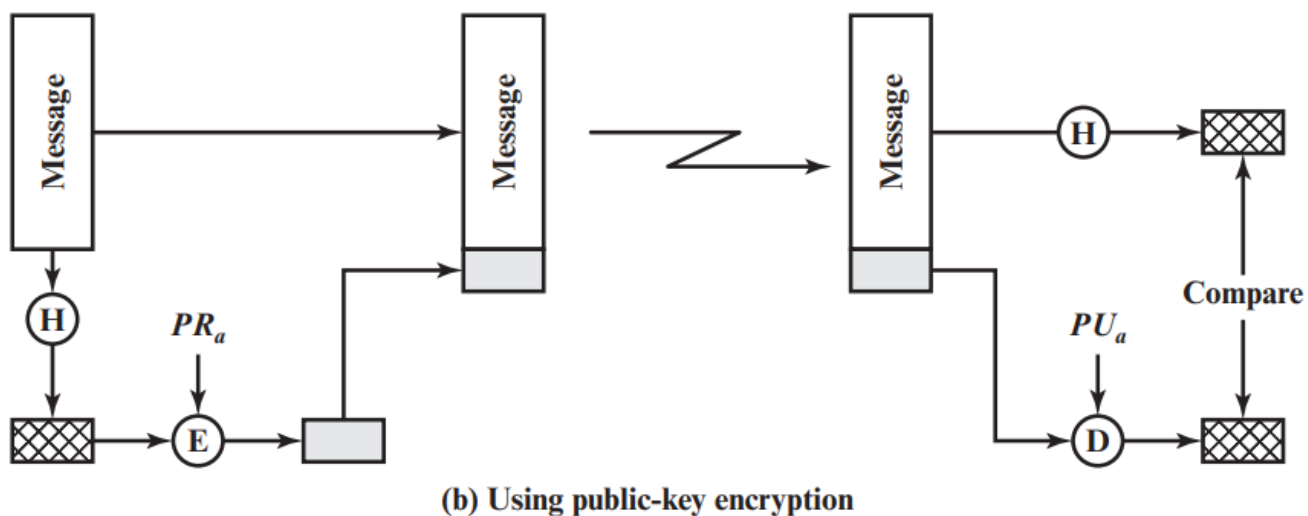
funzione che accetta in input un messaggio M di lunghezza variabile e produce un digest di lunghezza fissa $H(M)$.

A differenza del MAC, le funzioni di hash non hanno bisogno di una chiave segreta.

Il digest può essere criptato simmetricamente, se solo il mittente e il destinatario conoscono la chiave l'autenticità è assicurata.

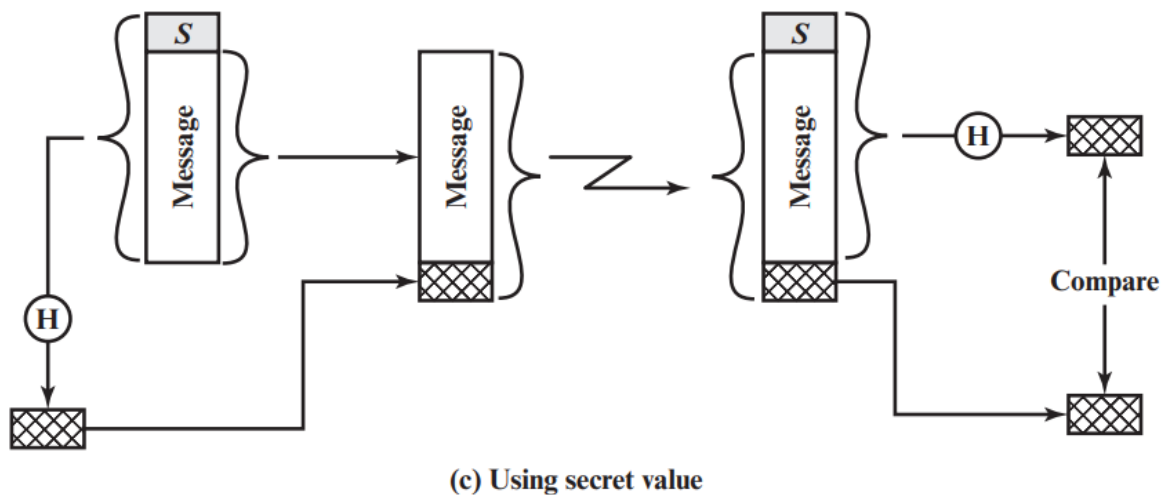


Il digest può essere cifrato utilizzando la cifratura a chiave pubblica



Questi due approcci hanno il vantaggio di non cifrare l'intero messaggio, risparmiando risorse.

Esiste anche una tecnica che non prevede cifratura:



essa prevede che A e B condividano un valore segreto. Quando A invia un messaggio calcola la funzione hash della concatenazione di S e del messaggio stesso e spedisce la concatenazione del messaggio e dell'hash a B; visto che B conosce S può ripetere la procedura e confrontarla con il digest.

Funzioni di hash sicure

Le funzioni di hash a una via, o funzioni di hash sicure, sono utilizzate sia nell'autenticazione dei messaggi che per le firme digitali.

Requisiti:

lo scopo di una funzione di hash è quello di produrre l'impronta digitale di un file, messaggio o blocco di dati. Per essere utile per l'autenticazione dei messaggi la funzione deve avere i seguenti requisiti:

- deve poter essere applicata a un blocco di ogni dimensione
- deve produrre un blocco di lunghezza fissa
- deve essere relativamente facile da implementare
- per ogni codice h deve essere computazionalmente infattibile trovare x tale che $H(x)=h$; una funzione con questa caratteristica viene detta **resistente alla preimmagine** o non invertibile. Garantisce che un attaccante non possa conoscere il messaggio a partire dal codice generato come hash.
- per ogni blocco x deve essere computazionalmente infattibile trovare $y \neq x$ con $H(y)=H(x)$; una funzione con questa proprietà viene detta **resistente alla seconda preimmagine**. Garantisce che non sia possibile trovare un messaggio alternativo con lo stesso digest, ciò previene la falsificazione del messaggio.

- deve essere computazionalmente infattibile trovare una coppia (x,y) tale che $H(x)=H(y)$. Una funzione con questa proprietà viene detta **resistente alla collisione**.

I primi tre requisiti sono fondamentali per l'applicazione della funzione di hash all'autenticazione dei messaggi.

Il quarto, resistenza alla preimmagine, è la proprietà 'one-way': è facile generare un codice per un dato messaggio ma è virtualmente impossibile generare un messaggio dato un codice.

La resistenza alla seconda preimmagine garantisce che sia impossibile trovare un messaggio alternativo con lo stesso hash del messaggio originario. Ciò previene che un attaccante possa: osservare o intercettare un messaggio più il suo hash cifrato, generare un hash non cifrato del messaggio e poi generare un messaggio alternativo con lo stesso hash.

Codici di autenticazione dei messaggi

HMAC

Approccio di combinazione del MAC e di una funzione di hash crittografica.

MAC derivato da funzioni di hash crittografiche. Obiettivi:

- utilizzare funzioni di hash già disponibili
- permettere la sostituzione della funzione di hash utilizzata
- mantenere l'efficienza della funzione di hash senza degradarne le prestazioni

I primi due obiettivi sono importanti per l'accettabilità di HMAC, esso deve trattare la funzione di hash come una scatola nera, con due benefici: un'implementazione esistente di una funzione di hash può essere usata come modulo per implementare HMAC, è possibile sostituirla facilmente.

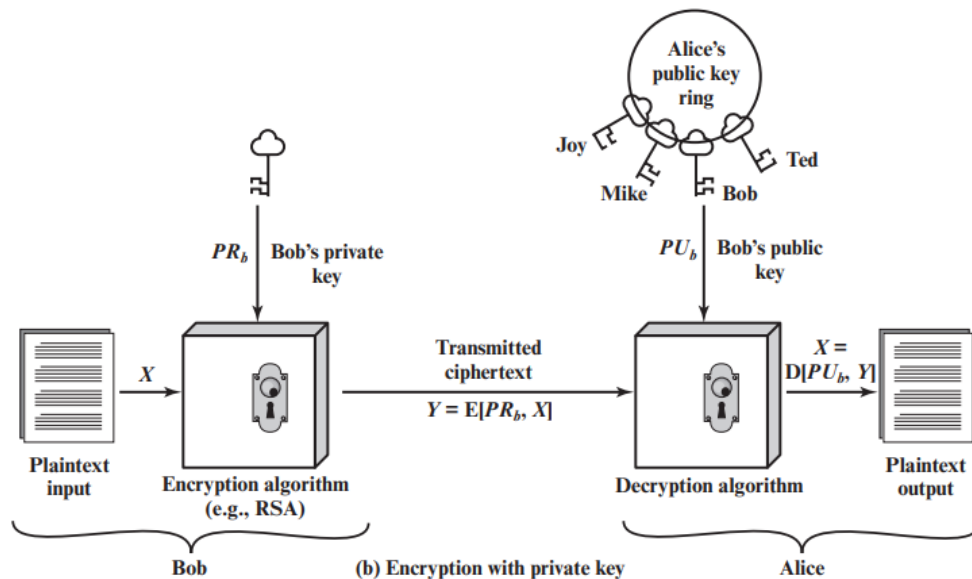
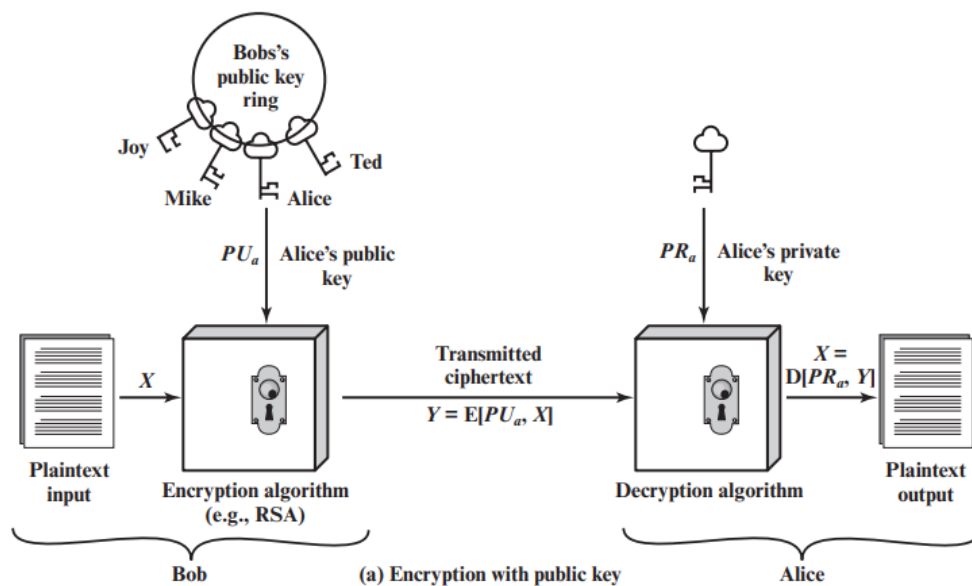
Principi di crittografia a chiave pubblica

Struttura della cifratura a chiave pubblica

Utilizza la cifratura asimmetrica (le chiavi di codifica e decodifica sono diverse).

Elementi:

- messaggio in chiaro
- algoritmo di cifratura
- chiave pubblica e privata
- testo cifrato
- algoritmo di decifrazione



Passi fondamentali:

- ogni utente ha una chiave pubblica e una chiave privata e la chiave pubblica viene inserita all'interno di un registro pubblicamente accessibile
- nel momento in cui Bob vuole inviare un messaggio ad Alice lo cifra con la chiave pubblica di Alice, quando Alice riceve il messaggio lo decifra utilizzando la sua chiave privata.

Applicazioni per i sistemi crittografici a chiave pubblica

- cifratura/decifratura: Il mittente cifra il messaggio con la chiave pubblica del destinatario
- firma digitale: Il mittente firma il messaggio con la sua chiave privata; applicando un algoritmo di cifratura a tutto il messaggio o a una sua parte
- scambio di chiavi: le due parti cooperano per scambiarsi una chiave di sessione

Algorithm	Encryption/Decryption	Digital Signature	Key Exchange
RSA	Yes	Yes	Yes
Diffie–Hellman	No	No	Yes
DSS	No	Yes	No
Elliptic curve	Yes	Yes	Yes

Requisiti per la crittografia a chiave pubblica

- deve essere computazionalmente semplice generare la coppia chiave pubblica-privata
- deve essere computazionalmente semplice per A ottenere la chiave pubblica di B; deve essere comp. semplice per B decifrare il messaggio con la sua chiave privata.
- deve essere comp. infattibile per un attaccante conoscere la chiave privata di un utente conoscendo quella pubblica
- deve essere comp. infattibile per un attaccante arrivare al messaggio conoscendo la chiave pubblica di B e il messaggio cifrato
- (opzionale) ognuna delle due chiavi nella coppia deve poter essere usata per cifrare quando l'altra è usata per decifrare

$$M = D[PU_b, E(PR_b, M)] = D[PR_b, E(PU_b, M)]$$

Algoritmi di crittografia a chiave pubblica

I principali sono RSA e Dieffie-Hellman.

RSA

Il nome è l'acronimo dei cognomi degli inventori.

L'utente genera due chiavi (una pubblica e una privata) utilizzando numeri primi molto grandi e un valore ausiliario. I numeri primi sono tenuti segreti. I messaggi vengono criptati da chiunque conosca la chiave pubblica ma possono essere decifrati solo da chi possiede la chiave privata.

È un algoritmo relativamente lento quindi non viene utilizzato per cifrare direttamente i messaggi utente; viene principalmente usato per la trasmissione delle chiavi condivise:

Immaginiamo che Bob e Alice vogliano comunicare e che siano d'accordo nell'utilizzare RSA, Bob deve conoscere la chiave pubblica di Alice e viceversa. Per permettere a Bob di comunicare, Alice trasmette la sua chiave pubblica attraverso un mezzo affidabile, ma non necessariamente sicuro.

Scambio di chiavi tramite alg. Dieffie-Hellman

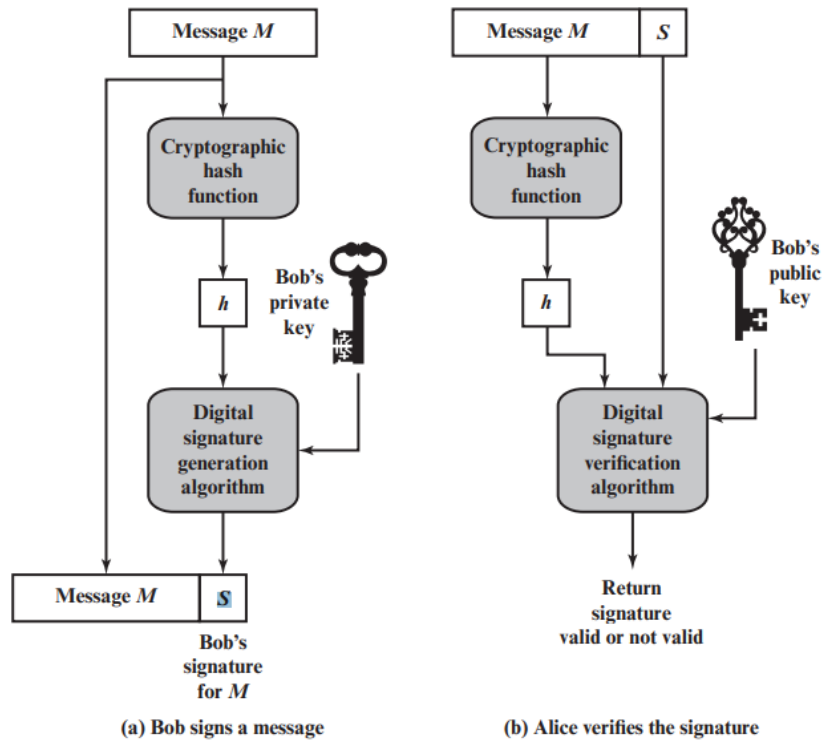
Algoritmo che permette di generare una chiave segreta tra due corrispondenti che comunicano attraverso un canale non sicuro.

Si basa sulla complessità computazionale del calcolo del logaritmo discreto (che deve essere utilizzato per ottenere la chiave segreta).

Firme digitali

 **Firma digitale:** risultato di una trasformazione crittografica dei dati che fornisce un meccanismo per verificare l'autenticazione dell'origine, l'integrità dei dati e il non-ripudio del firmatario.

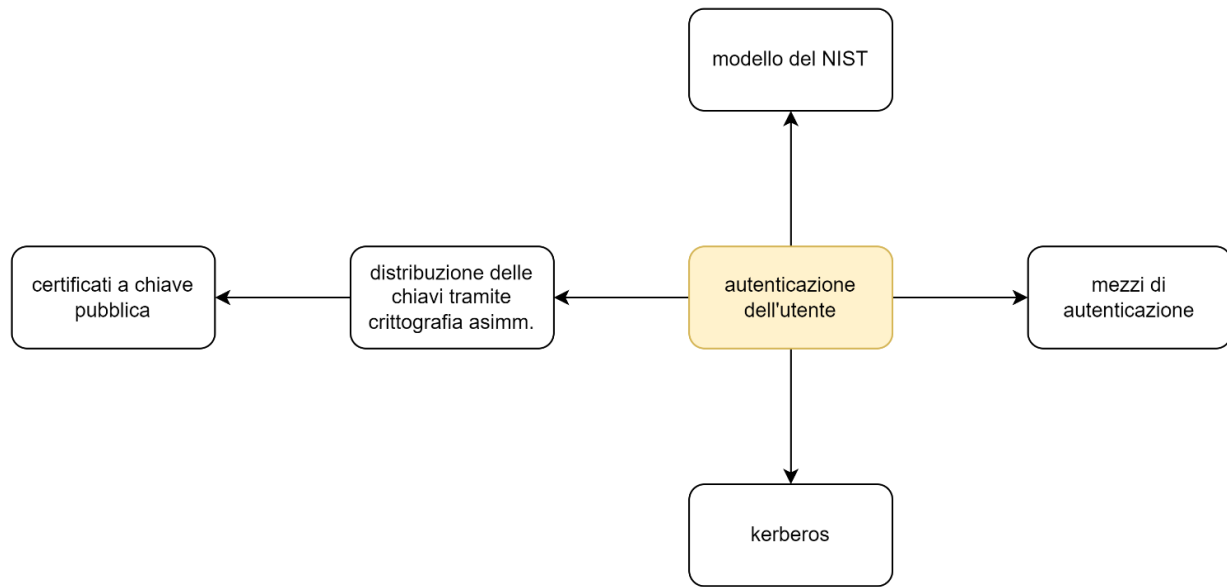
Generazione e verifica



Approccio che non fornisce confidenzialità.

Viene utilizzato in un primo momento della comunicazione, prima che i due interlocutori inizino a scambiarsi dati essi si verificano l'un l'altro (es handshake TLS).

4. Autenticazione degli utenti



Principi di autenticazione di utenti remoti

Autenticazione dell'utente: processo di verifica dell'identità reclamata da un'entità del sistema.

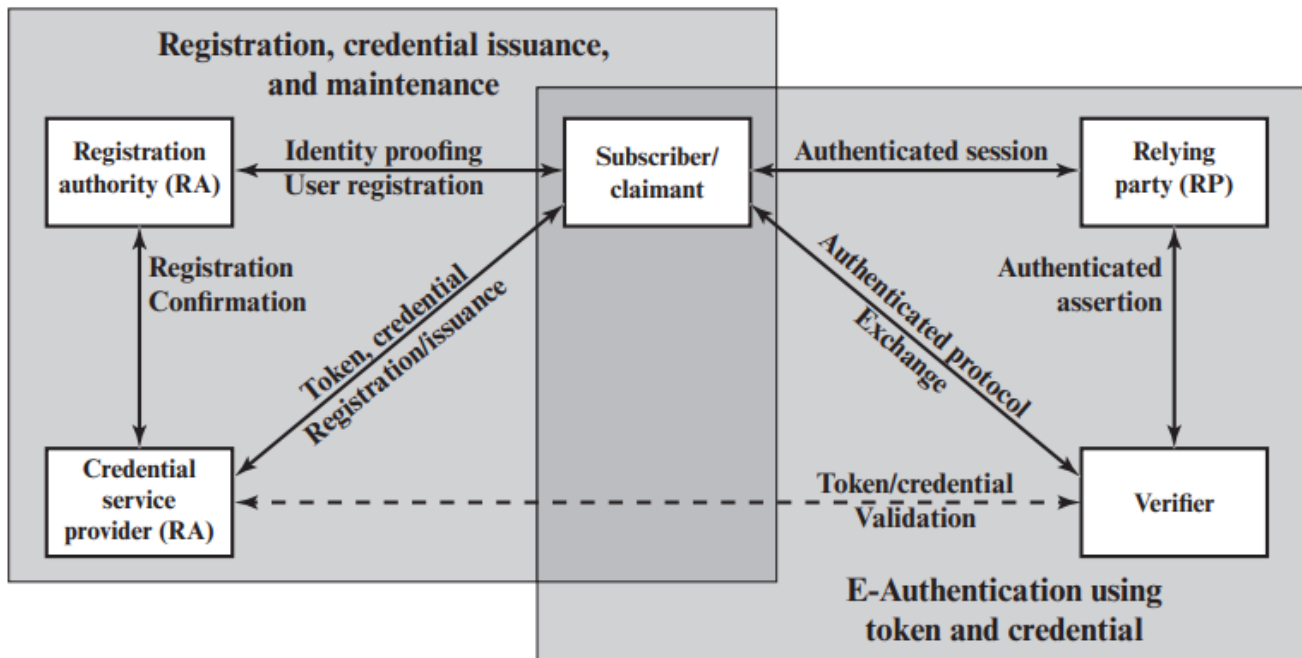
In molti contesti di cybersicurezza, l'autenticazione dell'utente è l'elemento costruttivo fondamentale e la linea di difesa primaria; è la base di molti tipi di controllo degli accessi.

Il processo di autenticazione consiste di due step:

1. **Identificazione:** viene presentato un identificativo al sistema (ID utente);
2. **Verifica:** viene presentata un'informazione di autenticazione che corrobora l'associazione tra l'entità e l'identificativo (password).

Modello per autenticazione del NIST

Il NIST (national institute of standards and technology) ha definito un modello per l'autenticazione degli utenti:



Il requisito fondamentale è che l'utente sia registrato nel sistema, per la registrazione: un applicante fa domanda a un'entità di registrazione (RA) per diventare utente di un fornitore di servizi di credenziali (CSP = credentials service provider). Il sottoscrittore riceve qualche sorta di credenziali elettroniche dal CSP (es token con psw); quindi a questo punto l'utente ha tutte le credenziali per autenticarsi.

Nel momento dell'autenticazione l'utente fornisce le sue credenziali al verificatore attraverso un protocollo di autenticazione, se il verificatore stabilisce il collegamento tra identificativo e token permette l'accesso al sistema.

L'applicante si registra presso la RA, quindi si stabilisce un rapporto di fiducia tra le due entità; la RA garantisce l'identità dell'utente presso il CSP. Il CSP fornisce le credenziali all'utente che può iniziare il processo di autenticazione.

Gli elementi fondamentali dell'architettura sono:

- la **Registration Authority**, fa in modo che l'utente sia registrato nel sistema, è un'entità fidata che garantisce l'identità dell'applicante presso il CSP;
- il **Credential Service Provider**, comunica con l'applicante e, dipendentemente dai dettagli del sistema di autenticazione, fornisce delle credenziali; la credenziale è una struttura dati che collega in maniera autoritativa un'identità e un attributo aggiuntivo a un token posseduto dall'utente.
- il **Verifier**, è l'entità che verifica, attraverso un protocollo di autenticazione, che il claimant posseda e controlli il token associato all'identificativo fornito. Dopo ciò, il verifier invia un messaggio contenente un'asserzione sull'identità dell'utente al Relying Party.
- il **Relying Party**, è l'entità finale del processo, quella che, in base alle informazioni fornite dal verifier implementa il controllo degli accessi o le decisioni relative all'autorizzazione.

Mezzi di autenticazione

4 principali mezzi che possono essere usati da soli o combinandoli:

- **Informazione conosciuta dall'utente:** es password, PIN (personal identification number)
- **Informazione posseduta dall'utente:** chiave crittografica, chiave elettronica, chiave fisica; ci si riferisce ad essa come *token*
- **Informazione che l'utente contiene:** impronta, retina ...
- **Informazione legata alle azioni dell'utente:** riconoscimento vocale, riconoscimento scrittura

Le psw rischiano: guessing, snooping (sbirciate mentre inserite), sniffing (intercettate quando trasmesse), spoofing (intercettate da terze parti che impersonano l'interfaccia di login)

Kerberos

Kerberos è un **servizio di distribuzione delle chiavi e autenticazione degli utenti** sviluppato dal MIT.

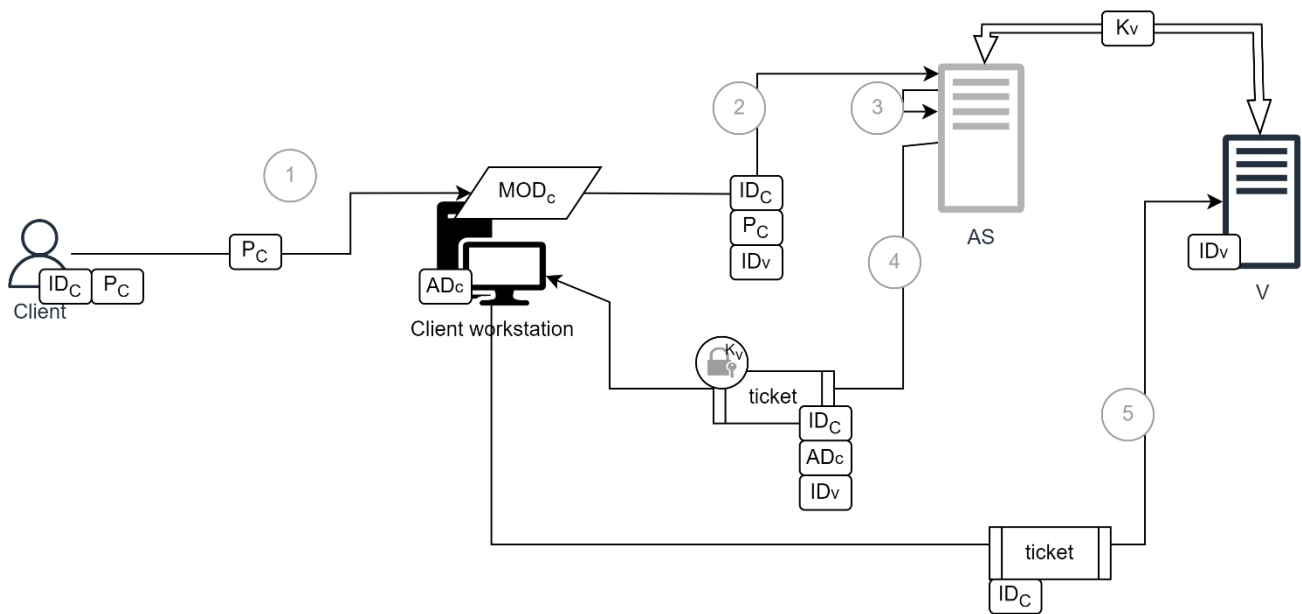
Il problema affrontato da Kerberos è: assumiamo un ambiente distribuito in cui gli utenti vogliono accedere servizi su server distribuiti nella rete. Vorremmo che i server restringessero gli accessi agli utenti autorizzati e fossero in grado di autenticare le richieste per i servizi. In questa situazione non si può utilizzare la postazione di lavoro come identificativa dell'utente visto che la postazione potrebbe essere utilizzata da utenti con permessi diversi, che un utente potrebbe alterare l'indirizzo di una postazione in modo che la richiesta da lui inviata sembri inviata da un'altra postazione o un utente potrebbe intercettare i messaggi tra una postazione e il server e utilizzare la replicazione per guadagnare l'accesso al server.

Kerberos fornisce un **server di autenticazione centralizzato** la cui funzione è quella di autenticare gli utenti ai server e viceversa. Utilizza solo la crittografia simmetrica.

Versione 4

Fa uso di DES (data encryption standard) per fornire il servizio di autenticazione.

Dialogo di autenticazione semplice



In un ambiente in rete non protetto ogni utente può fare richiesta a ogni server per un servizio, il rischio maggiore è l'impersonazione. I server devono essere in grado di confermare le identità dei clients. Si può utilizzare un **authentication server (SA)** che conosce le password di tutti gli utenti e le mantiene in un DB centralizzato e condivide con ogni utente una chiave segreta univoca.

Funzionamento del dialogo:

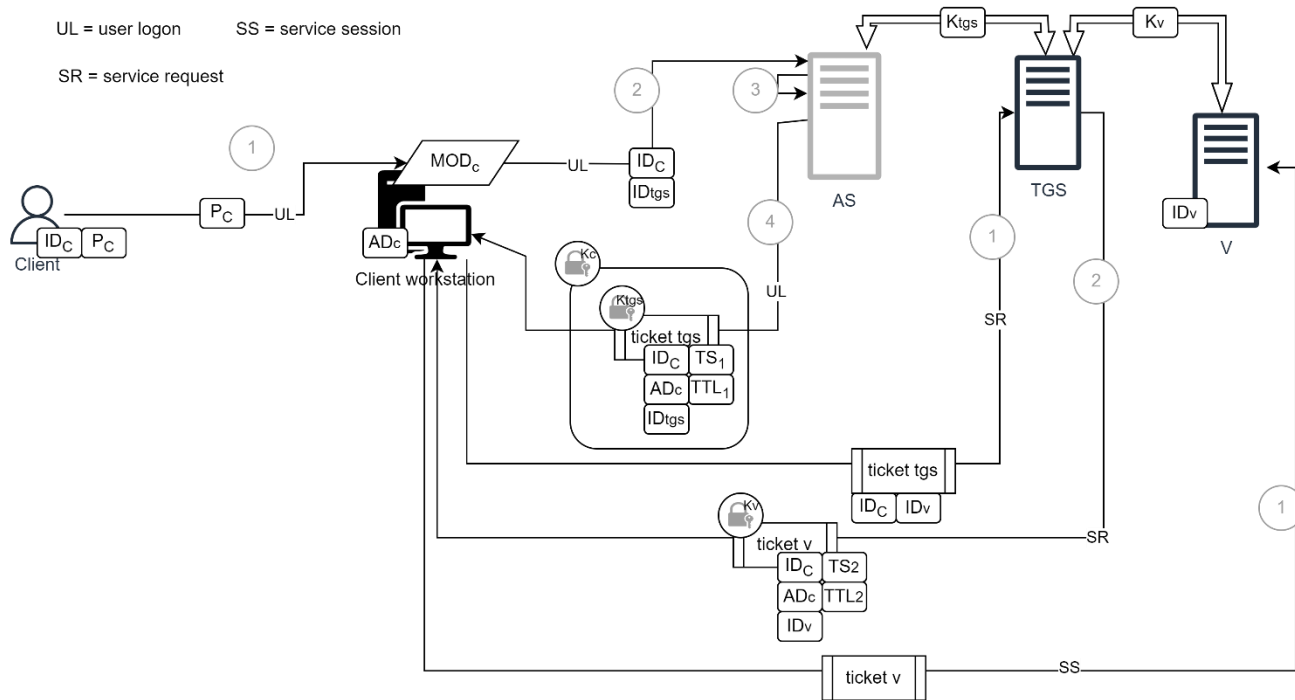
gli interlocutori sono:

- l'utente che accede al modulo C della sua postazione tramite le credenziali ID_C e P_C (password per C)
- la postazione dell'utente che ha un indirizzo di rete AD_C
- il server di autenticazione AS
- il server V a cui l'utente vuole accedere

gli step seguiti sono:

1. il modulo C richiede la password dell'utente
2. C invia una richiesta a AS contenente le credenziali dell'utente e l'id del server con cui l'utente vuole comunicare
3. AS controlla se l'utente ha fornito la giusta psw e se gli è permesso l'accesso a V
4. se tutti i test dello step 3 vengono passati, AS crea un ticket contenente l'id dell'utente, l'indirizzo di rete e l'id del server V; il ticket viene criptato con la chiave condivisa tra AS e V
5. C invia un messaggio a V contenente il ticket e l'id dell'utente; V decrypta il ticket e confronta l'id dell'utente passato in chiaro con quello contenuto nel ticket, se i due corrispondono V considera l'utente autenticato e gli garantisce i permessi

Dialogo di autenticazione più sicuro



L'approccio precedente ha due problemi: primo, vorremmo minimizzare il numero di volte in cui l'utente deve inserire la password, se i ticket durano solo il tempo di eseguire un'operazione l'utente potrebbe dover inserire la sua psw molte volte, anche se il ticket fosse di sessione l'utente avrebbe comunque bisogno di un ticket per ogni servizio; il secondo problema è che la psw dell'utente viene spedita in chiaro e potrebbe essere intercettata.

Per risolvere questi problemi viene introdotto uno schema per evitare l'invio delle password in chiaro e un nuovo server detto **ticket-granting server (TGS)**.

L'utente richiede all'AS un ticket per autenticarsi presso il TGS e lo salva; ogni volta che l'utente richiede accesso a un nuovo servizio, il client fa richiesta al TGS usando il ticket per autenticarsi. Il TGS fornisce un ticket per il particolare servizio, il client salva questo ticket e lo usa ogni volta che vuole aprire una sessione verso quel servizio.

Dettagli:

- nel momento in cui AS invia il ticket tgs lo encripta con una chiave derivata dalla psw dell'utente che esso contiene; quando il ticket arriva al client esso chiede la password all'utente, genera la chiave e prova a decifrare il ticket, se ci riesce il ticket viene salvato.
- il ticket tgs include un timestamp che indica quando è stato creato e un TTL.
- nel momento in cui un utente vuole accedere a un nuovo server esso trasmette un messaggio al TGS contenente il ticket tgs e l'ID del server

- il TGS decripta il ticket con la chiave che condivide con AS e verifica il successo della decifratura controllando la presenza del suo ID. Controlla che il TTL non sia scaduto. Controlla che l'utente abbia i permessi per accedere a V e in caso invia un ticket che permetterà l'accesso al server.
 - l'utente usa quest'ultimo ticket per ottenere l'accesso al servizio.
-

Dialogo di autenticazione di Kerberos 4

L'ultimo scenario presenta due problemi: se il TTL del ticket tgs è molto breve l'utente dovrà inserire molte volte la psw, se il TTL è molto lungo un attaccante potrebbe avere la possibilità di intercettarlo e replicarlo.

Quindi si arriva a un ulteriore requisito il TGS deve essere in grado di provare che la persona che sta utilizzando il ticket è la stessa che lo ha richiesto.

Il secondo requisito è che i server devono autenticarsi verso l'utente, potrebbe esserci una configurazione per cui le chiamate verso un server vengono dirottate verso un altro che potrebbe impadronirsi delle credenziali degli utenti.

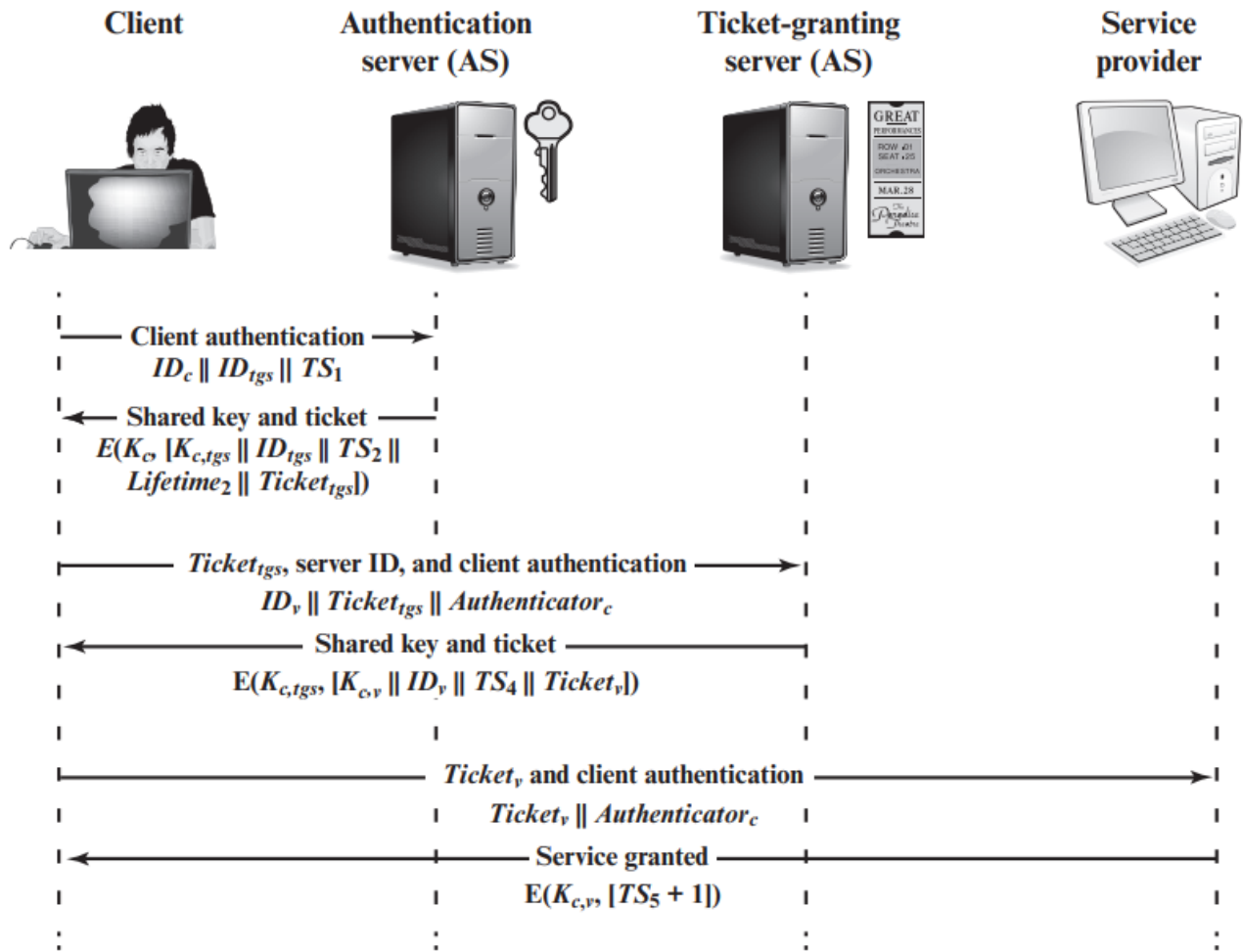
Problema 1: il TGS deve poter provare che l'utente è lo stesso che ha richiesto il ticket

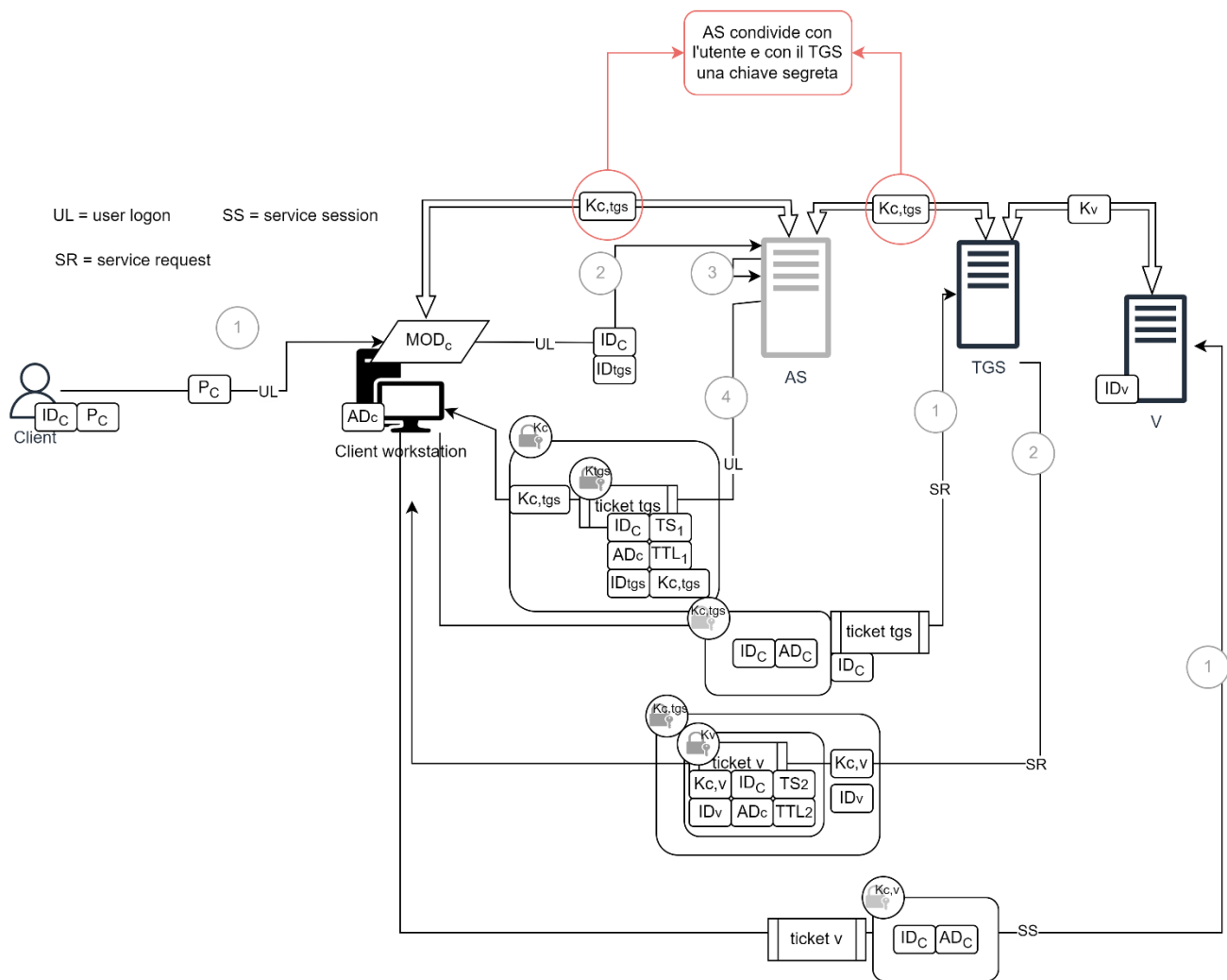
AS deve condividere un'informazione segreta con l'utente che si identifica presso il TGS mandandogli questa informazione in maniera sicura, un modo per fare ciò è utilizzare una chiave di cifratura come informazione segreta che viene chiamata **chiave di sessione in Kerberos**.

Il client invia un messaggio ad AS chiedendo l'accesso al TGS; l'AS risponde con un messaggio cifrato con la chiave KC derivata dalla psw dell'utente; il messaggio contiene anche la chiave di sessione per fare in modo che C possa comunicare con TGS, tale chiave è inclusa anche nel ticket che verrà letto dal TGS.

Il client invia un messaggio al TGS che include il ticket, l'id del servizio richiesto e un elemento di autenticazione che include ADc, IDc e un timestamp (TTL molto breve perché deve essere utilizzato solo una volta). TGS può decriptare il ticket con Ktgs (che condivide con AS), nel ticket vi è la chiave di sessione assegnata da AS a C. autenticazione, compara l'id utente e l'indirizzo contenuti nell'identificatore con quelli del ticket.

Il TGS invia un messaggio criptato con la chiave condivisa con C e include una chiave di sessione che deve essere condivisa tra C e V, l'ID di V e il timestamp del ticket.





Infrastruttura Kerberos

L'infrastruttura Kerberos consiste di un server Kerberos, un numero di client e un numero di application software.

Requisiti:

- il server Kerberos deve avere gli ID e le psw hashate di tutti gli utenti
- il server Kerberos deve condividere una chiave segreta con ogni server

Ci si riferisce a questo ambiente come **Kerberos realm**, ovvero un insieme di nodi che condividono lo stesso DB Kerberos. Il DB Kerberos deve risiedere sulla macchina principale in una stanza sicura.

Il **Kerberos principal** è il sistema o l'utente conosciuto dal sistema kerberos, identificato dal suo principal name che consiste di tre parti: service/user name, instance name, realm name.

Versione 5

Carenze ambientali di Kerberos v4:

1. **Dipendenza dal sistema di cifratura:** la v4 richiede l'utilizzo di DES; nella versione 5 i testi cifrati sono taggati con un identificativo del tipo di cifratura; le chiavi di cifratura sono taggate con la lunghezza e il tipo in modo da poter essere usate in diversi algoritmi.
2. **Dipendenza da IP:** la v4 richiede l'uso di indirizzi IP; nella v5 gli indirizzi sono taggati con il tipo e la lunghezza
3. **TTL dei ticket:** in v4 i TTL sono espressi con 8 bit in unità da 5 minuti (es: 000100 → 20 min) quindi il massimo era $(2^8 - 1) * 5 = 1275$ minuti; in v5 i ticket includono un timestamp di inizio e uno di fine.
4. **Authentication forwarding:** v4 non permette che le credenziali di un utente vengano passate da un server a un altro; il che avrebbe permesso all'utente di utilizzare indirettamente un servizio. v5 permette il forwarding

Funzionamento della v5

(1) $C \rightarrow AS$ $Options \parallel ID_c \parallel Realm_c \parallel ID_{tgs} \parallel Times \parallel Nonce_1$ (2) $AS \rightarrow C$ $Realm_c \parallel ID_C \parallel Ticket_{tgs} \parallel E(K_c, [K_{c,tgs} \parallel Times \parallel Nonce_1 \parallel Realm_{tgs} \parallel ID_{tgs}])$ $Ticket_{tgs} = E(K_{tgs}, [Flags \parallel K_{c,tgs} \parallel Realm_c \parallel ID_C \parallel AD_C \parallel Times])$
--

Nel momento in cui il client richiede il ticket tgs ad AS vengono inseriti nella richiesta dei nuovi elementi:

- **Realm** dell'utente
- **Options:** utilizzate per richiedere che certe flags vengano settate nel ticket
- **Nonce:** valore randomico che deve essere ripetuto nella risposta per verificare che non sia stata replicata

(3) $C \rightarrow TGS$ $Options \parallel ID_v \parallel Times \parallel Nonce_2 \parallel Ticket_{tgs} \parallel Authenticator_c$ (4) $TGS \rightarrow C$ $Realm_c \parallel ID_C \parallel Ticket_v \parallel E(K_{c,tgs}, [K_{c,v} \parallel Times \parallel Nonce_2 \parallel Realm_v \parallel ID_v])$ $Ticket_{tgs} = E(K_{tgs}, [Flags \parallel K_{c,tgs} \parallel Realm_c \parallel ID_C \parallel AD_C \parallel Times])$ $Ticket_v = E(K_v, [Flags \parallel K_{c,v} \parallel Realm_c \parallel ID_C \parallel AD_C \parallel Times])$ $Authenticator_c = E(K_{c,tgs}, [ID_C \parallel Realm_c \parallel TS_1])$

Lo scambio tra C e TGS ha la stessa struttura della v4 e include le opzioni richieste da C.

(5) $C \rightarrow V$ $Options \parallel Ticket_v \parallel Authenticator_c$

(6) $V \rightarrow C$ $E_{K_{c,v}}[TS_2 \parallel Subkey \parallel Seq\#]$

$Ticket_v = E(K_v, [Flags \parallel K_{c,v} \parallel Realm_c \parallel ID_C \parallel AD_C \parallel Times])$

$Authenticator_c = E(K_{c,v}, [ID_C \parallel Realm_c \parallel TS_2 \parallel Subkey \parallel Seq\#])$

Durante la comunicazione tra C e V, C può richiedere come opzione che venga effettuata l'autenticazione mutua. L'autenticatore include nuovi campi:

- sottochiave: la chiave di cifratura scelta dal client per proteggere la sessione, se è omessa viene usata la chiave $K_{c,v}$
- numero di sequenza: utilizzato dal server per i messaggi da esso inviati in modo che il client possa capire se ci sono state repliche.

Distribuzione delle chiavi tramite crittografia asimmetrica

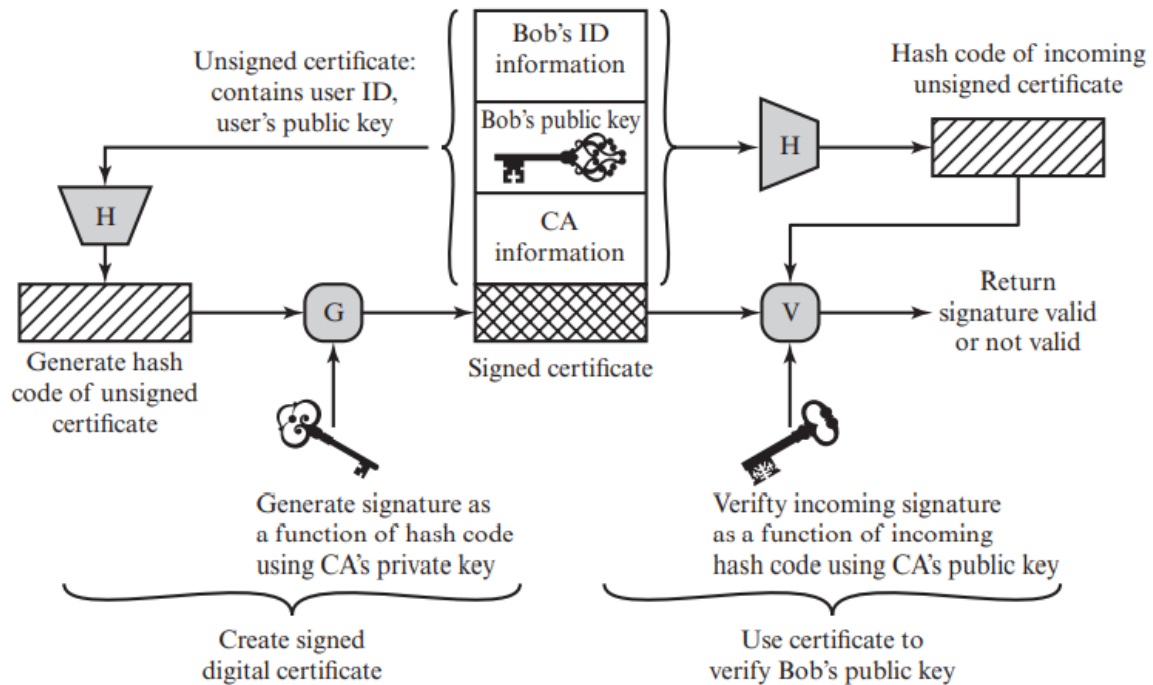
Uno dei ruoli più importanti della cifratura a chiave pubblica è la soluzione del problema della distribuzione delle chiavi. Ci sono 2 aspetti distinti dell'utilizzo della crittografia asimmetrica a questo riguardo:

- la distribuzione delle chiavi pubbliche
- l'uso della crittografia a chiave pubblica per la distribuzione delle chiavi segrete

Certificati a chiave pubblica

Le chiavi pubbliche devono essere distribuite a un insieme di utenti ma farlo attraverso una pubblicazione diretta può esporre al rischio di mascheramento, un attaccante può fingersi A e distribuire la propria chiave pubblica facendo credere che sia quella di A.

La soluzione a questo problema è il **certificato a chiave pubblica**, che consiste di una chiave pubblica e dell'ID dell'utente; il blocco viene firmato da un'entità terza fidata. La terza parte è un'**autorità di certificazione** CA fidata dalla comunità dell'utente. L'utente può presentare la sua chiave pubblica alla CA e ottenere un certificato che poi pubblica; chi ha bisogno della chiave pubblica dell'utente richiede il certificato di cui si fida in quanto contiene la firma della CA.



Lo standard per la formattazione dei certificati a chiave pubblica è X.509.

Distribuzione delle chiavi segrete

Per la cifratura convenzionale è necessario che le due parti condividano una chiave.

Se B vuole inviare una chiave simmetrica ad A può:

1. preparare il messaggio
2. cifrare il messaggio con una chiave di sessione utilizzabile una volta
3. cifrare la chiave di sessione con la chiave pubblica di A
4. allegare la chiave di sessione cifrata al messaggio e inviarlo ad A

Solo A può decifrare la chiave di sessione e quindi il messaggio. Se la chiave pubblica di A è stata recuperata da B attraverso un certificato pubblico allora B è sicuro dell'identità di A.

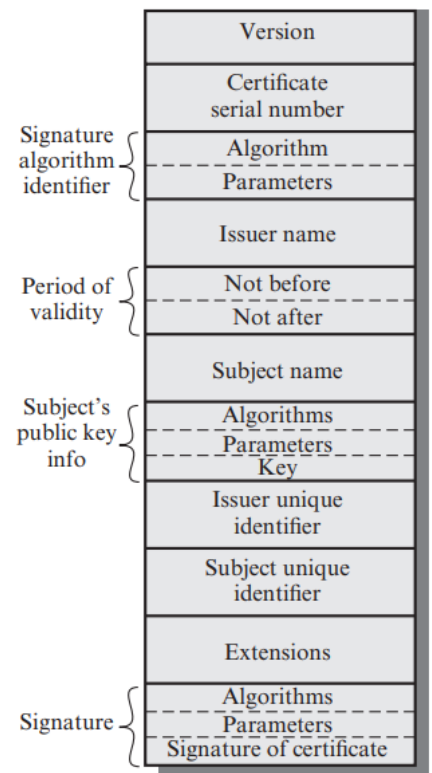
Certificati X.509

Ogni certificato contiene la chiave pubblica di un utente e è firmato con la chiave privata dell'autorità di certificazione.

Lo standard è basato sull'utilizzo della crittografia a chiave pubblica e delle firme digitali; esso non detta un particolare algoritmo per la firma né una specifica funzione di hash.

Il formato generale di un certificato che segue lo schema X.509 è il seguente

- **Versione** di X.509 utilizzata
- **Numero seriale**: un valore intero, univoco nel contesto del CA, associato al certificato
- **Id dell'algoritmo** utilizzato per firmare il certificato
- **Nome dell'emittente**: nome del CA
- **Periodo di validità**: due date, inizio e fine
- **Nome del soggetto** a cui si riferisce il certificato
- **Informazioni della chiave pubblica del soggetto**: contiene la chiave, l'identificativo dell'algoritmo e i parametri
- **Id della CA**: nel caso in cui il nome sia stato utilizzato per diverse entità
- **Id univoco del soggetto**: nel caso in cui il nome sia stato usato per diverse entità
- **Firma**: comprende la firma digitale applicata a tutti gli altri componenti del certificato



Ottenimento del certificato utente

I certificati generati dalle autorità di certificazione possono essere verificati da tutti gli utenti che possiedono la chiave pubblica della CA e nessuno al di fuori della CA stessa li può modificare senza che la modifica sia evidente.

Visto che i certificati non possono essere falsificati essi possono essere mantenuti in una directory non protetta.

Visto che le CA sono molte e è preferibile che ognuna serva un numero ristretto di utenti si può creare una "catena di fiducia" che permette ad un utente A di ottenere in modo sicuro la chiave di B da una CA X1 non fidata, basta che il certificato di X1 sia firmato da X2, ovvero una CA di cui A si fida.

Revoca dei certificati

Ogni certificato include un periodo di validità; solitamente viene creato un nuovo certificato prima che il precedente scada. Ci sono occasioni in cui è necessario revocare il certificato prima della scadenza:

- la chiave privata dell'utente è compromessa
- l'utente non è più certificato dalla CA
- il certificato è compromesso

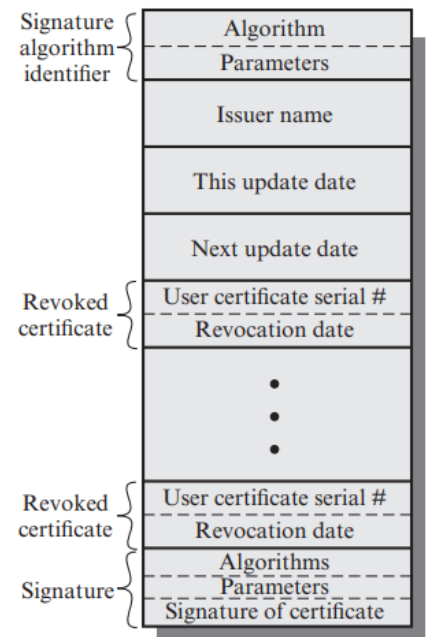
Ogni CA deve mantenere una lista dei certificati revocati prima della scadenza.

Ogni CRL (certificate revocation list) contiene:

la data di creazione della lista,
una entry per ogni certificato revocato

Ogni entry relativa a un certificato revocato contiene:

numero seriale del certificato (univoco nel contesto della CA),
la data di revoca



(b) Certificate revocation list

Infrastruttura a chiave pubblica (PKI)



Infrastruttura a chiave pubblica: l'insieme di hw, sw, persone, policies e procedure necessarie per creare, gestire, mantenere, distribuire e revocare i certificati digitali basati sulla crittografia asimmetrica.

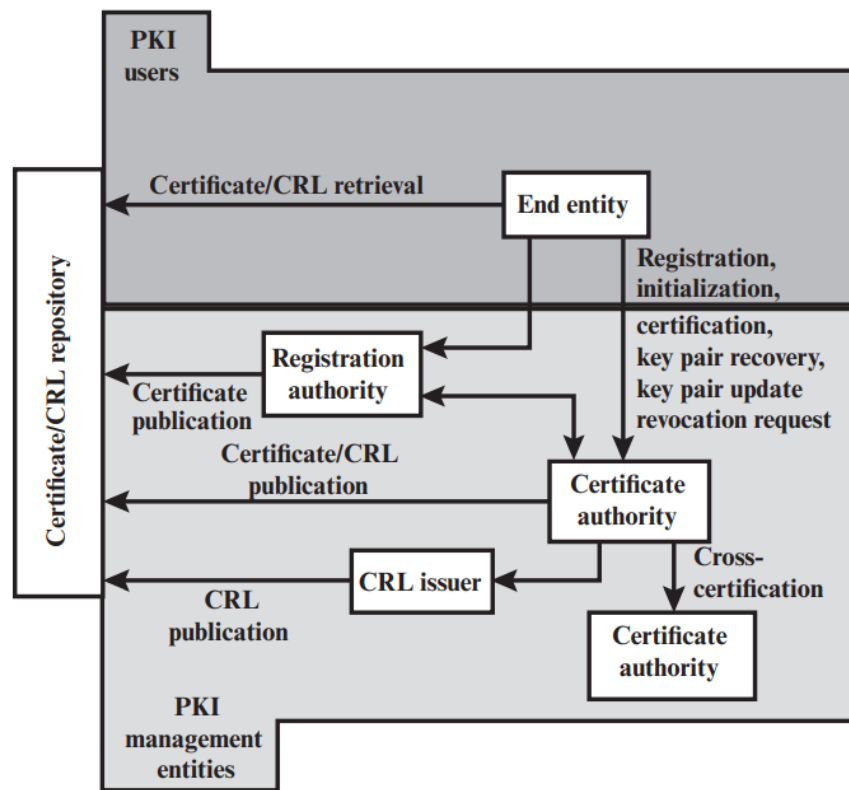
Il principale motivo per sviluppare una PKI è quello di avere un'acquisizione delle chiavi pubbliche sicura, conveniente e efficiente.

PKIX = modello basato su X.509 per sviluppare un'architettura basata sui certificati in Internet.

Gli elementi principali del modello sono:

- **Entità finale:** termine generico per indicare gli utenti finali, i dispositivi o ogni altra entità che consuma e/o supporta i servizi relativi alla PKI
- **Autorità di certificazione (CA)**
- **Autorità di registrazione (RA):** componente opzionale che può assumere delle funzioni amministrative dal CA
- **Emittente CRL (certificates revocation lists):** componente opzionale che può essere delegato dal CA di pubblicare le CRL
- **Repository:** termine generico utilizzato per denotare qualsiasi metodo di mantenimento dei certificati e delle CRL in modo che essi possano essere acceduti dalle entità finali.

Funzionalità



Il PKIX definisce alcune funzionalità che devono essere garantite dall'infrastruttura:

- **Registrazione:** processo attraverso il quale un'entità si fa conoscere per la prima volta da una CA (direttamente o tramite una RA), prima che la CA possa emettere il certificato dell'entità. Dopo la registrazione vengono rilasciate una o più chiavi segrete condivise che verranno usate durante le autenticazioni.
- **Inizializzazione:** prima che un sistema client possa operare in sicurezza è necessario che esso abbia tutte le informazioni fondamentali, come la chiave pubblica della CA
- **Certificazione:** processo attraverso cui una CA emette un certificato per la chiave pubblica di un utente e lo restituisce al sistema dell'utente e/o lo inserisce nella repository.
- **Recupero delle chiavi:** permette alle entità di recuperare le loro chiavi di cifratura/decifratura da un servizio di backup autorizzato
- **Aggiornamento delle chiavi:** tutte le coppie di chiavi devono essere aggiornate regolarmente e un nuovo certificato deve essere emesso.
- **Richiesta di revoca:** processo attraverso cui un'entità autorizzata avvisa la CA di una situazione che richiede la revoca di un certificato
- **Certificazione incrociata:** certificato inviato da una CA ad un'altra che contiene la firma che la prima utilizza per i certificati.

Gestione delle identità federata

Gestione delle identità federata: sistema basato su accordi, standard e tecnologie che permettono la portabilità delle identità, degli attributi delle identità e dei loro permessi attraverso diverse organizzazioni e numerose applicazioni.

Gestione delle identità

La gestione delle identità è un approccio centralizzato e automatizzato per fornire l'accesso alle risorse a livello di organizzazione da parte degli individui autorizzati. Deve essere definita un'identità per ogni utente, associati degli attributi a questa identità e imposto un mezzo attraverso il quale l'utente può verificare la sua identità.

Il concetto centrale è l'uso del **single sign-on (SSO)** che abilita l'utente ad accedere a tutte le risorse della rete dopo una sola autenticazione.

I servizi forniti tipicamente dai sistemi di gestione delle entità federati sono:

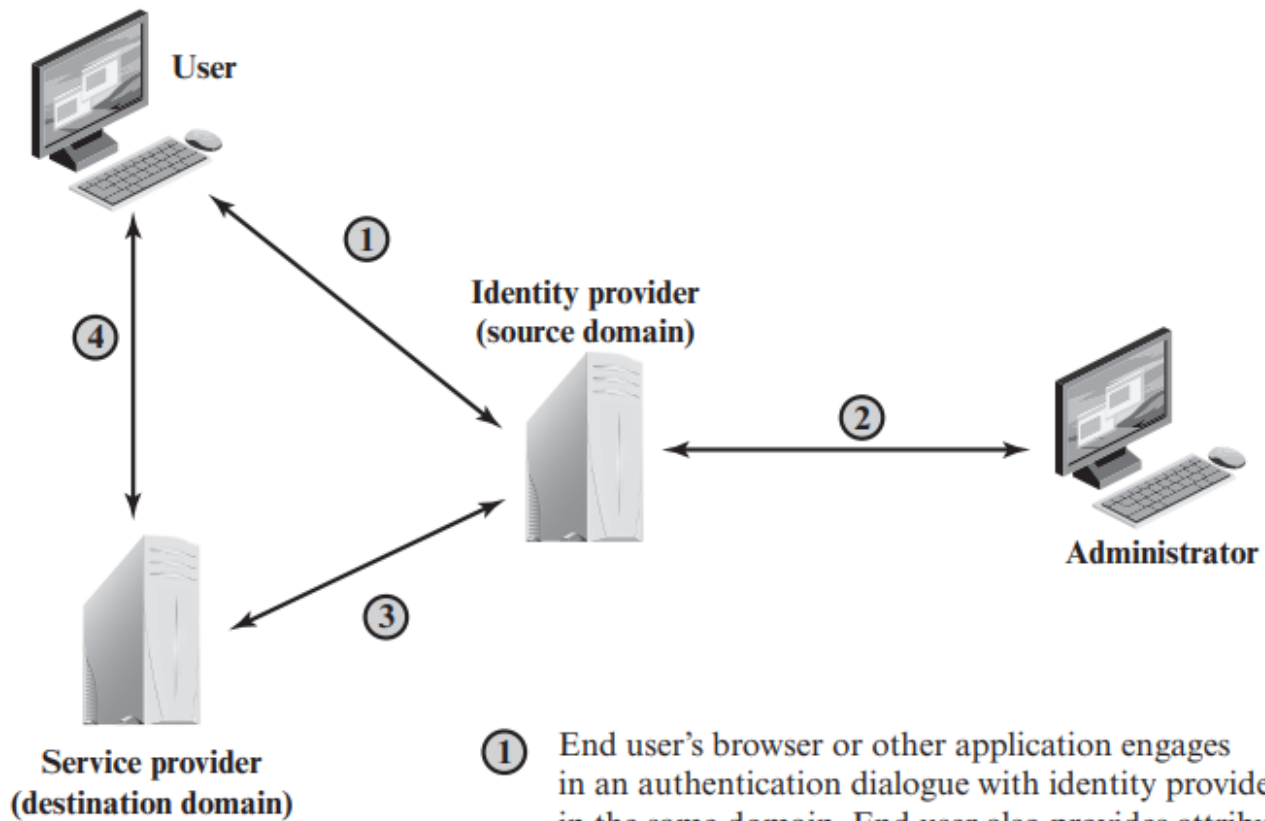
- Punto di contatto: autenticazione dell'utente e gestione delle sessioni
- Servizi SSO
- Servizi di gestione delle chiavi e dei certificati
- Servizi per la gestione delle informazioni collegate all'identità di un utente
- Autorizzazione: garantisce l'accesso a specifici servizi e risorse in base all'autenticazione

Identity federation

Estensione del meccanismo di gestione delle identità ad un contesto più ampio di cui fanno parte organizzazioni autonome, partner esterni alle organizzazioni, applicazioni e servizi di terze parti.

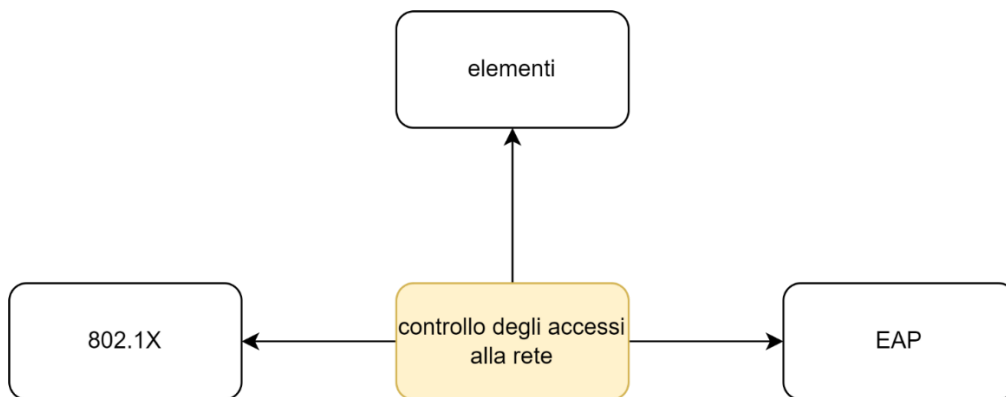
L'obiettivo è quello di fornire un servizio di condivisione delle identità degli utenti così che essi possano autenticarsi una singola volta e utilizzare tutti i servizi nella federazione. Visto che i domini sono indipendenti non è possibile implementare un sistema centralizzato, la condivisione delle identità deve basarsi sull'adozione di standard comuni e sulla creazione di livelli di fiducia.

Una funzionalità fondamentale di un FIMS (federated identity management system) è la mappatura delle identità; due organizzazioni nella federazione possono mantenere le identità in formati diversi che devono essere mappati uno nell'altro affinché le identità siano portabili.



- ① End user's browser or other application engages in an authentication dialogue with identity provider in the same domain. End user also provides attribute values associated with user's identity.
- ② Some attributes associated with an identity, such as allowable roles, may be provided by an administrator in the same domain.
- ③ A service provider in a remote domain, which the user wishes to access, obtains identity information, authentication information, and associated attributes from the identity provider in the source domain.
- ④ Service provider opens session with remote user and enforces access control restrictions based on user's identity and attributes.

05 Network access control



Controllo degli accessi alla rete (NAC)

Termine che comprende il controllo degli accessi a una rete.

Procedura per autenticare gli utenti che accedono alla rete e determinare quali dati essi possono accedere e quali azioni possono svolgere; anche analizzando lo stato di salute del dispositivo (il dispositivo è fidato? ha un anti-virus aggiornato? ci sono delle applicazioni dell'organizzazione installate?).

Ad esempio nel momento in cui un'organizzazione ha una politica BYOD (bring your own device) deve essere sicura che la connessione del dispositivo alla rete sia sicura.

Agent-based vs agentless

Le politiche di controllo degli accessi possono essere suddivise in:

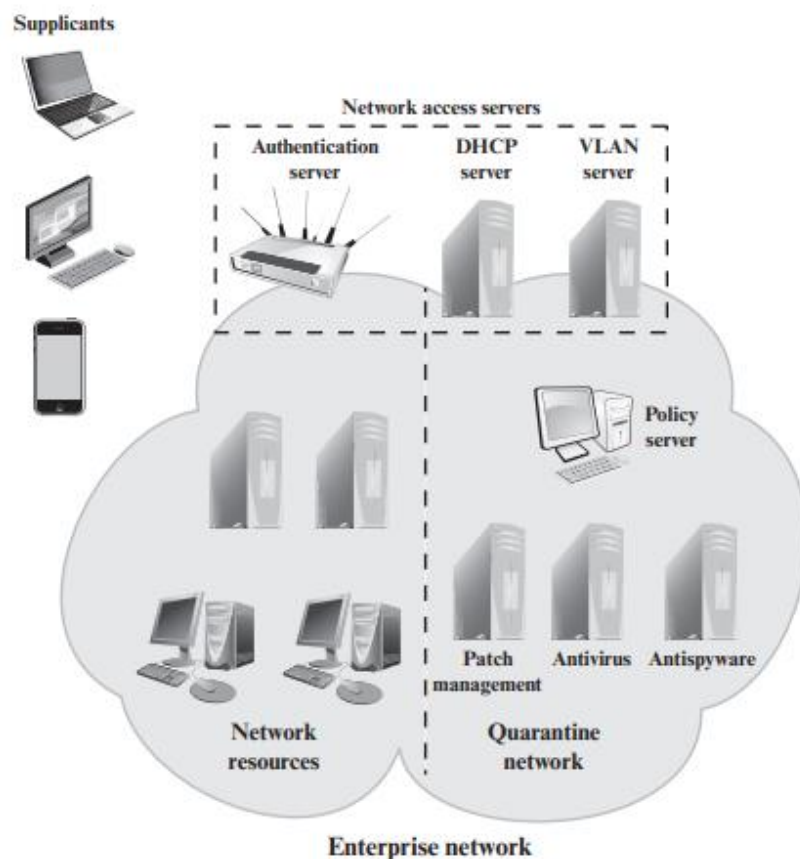
- **agent-based**: richiede l'installazione di un software su ogni dispositivo che ha bisogno di connettersi alla rete. L'agent porta avanti i controlli sullo stato di salute del dispositivo e si autentica l'utente prima di permettere l'accesso alla rete.
Vantaggi: permette di creare delle regole molto specifiche (sistema operativo, tipologia di dispositivo) e di monitorare costantemente i cambiamenti dell'ecosistema del dispositivo.
Svantaggi: l'agent deve essere installato e mantenuto su ogni dispositivo che deve accedere la rete; esso può consumare risorse e impattare le performance; potrebbe non essere compatibile con ogni dispositivo.
- **agentless**: la procedura di controllo viene affidata a dei protocolli come 802.1X.
Vantaggi: non richiede l'installazione e il mantenimento dell'agent; generalmente più facile da implementare.
Svantaggi: può essere meno efficiente; le regole che possono essere imposte sono meno specifiche e possono controllare meno fattori

Un dispositivo che non supera i controlli relativi allo stato di salute può essere ammesso alla zona di quarantena della rete in cui gli è permesso di installare tutti gli elementi necessari per essere ammesso alla rete.

Elementi di un sistema NAC

3 categorie di componenti:

- **Richiedente accesso (AR):** il nodo che sta provando ad accedere la rete, anche detti clients
- **Policy server:** determina le condizioni di salute dell'host in base alle politiche dell'organizzazione e, in base a esse, quali accessi possono essere garantiti. Si serve di altri sistemi, come antivirus
- **Network access server (NAS):** punto di controllo degli accessi per gli utenti che si connettono a una rete aziendale dall'esterno; può contenere il proprio servizio di autenticazione o fare affidamento su quello del policy server. Solitamente è un server RADIUS (remote authentication dual-in user service).



Nel momento in cui un AR richiede l'accesso alla rete esso deve essere autenticato; l'autenticazione può essere espletata dal NAS o dal policy server.

L'autenticazione si potrebbe concludere con la creazione di chiavi di sessione che permetteranno future comunicazioni sicure.

L'autenticazione serve a verificare l'identità dichiarata dal client che permette al policy server di determinare i privilegi.

In base allo stato di salute dell'AR gli viene concesso l'accesso solo a determinate zone della rete. Lo stato di salute di un sistema viene misurato in base alla compliance con i requisiti dati dalle configurazioni di sicurezza dell'organizzazione. In base al risultato dei controlli di salute l'AR potrebbe essere rigettato, ammesso alla zona di quarantena della rete o ammesso alla rete.

Una volta che l'AR è stato autenticato e controllato, il NAS può permettergli di interagire con le risorse della rete; esso può mediare ogni scambio per rinforzare la sicurezza oppure può usare dei modelli predefiniti per la gestione dei privilegi dell'AR.

Metodi di imposizione dell'accesso alla rete

I metodi di imposizione sono le azioni applicate agli AR per regolare gli accessi alla rete aziendale. Imporre l'autorizzazione significa rendere l'autorizzazione necessaria per lo svolgimento di un'azione.

Metodi di imposizione NAC comuni:

- **IEEE 802.1X:** protocollo del livello di collegamento (switch) che impone l'autorizzazione prima che a una porta venga assegnato un indirizzo IP. Fa uso del protocollo Extensible authentication per il processo di autenticazione.
- **Virtual local area networks:** in questo approccio la rete aziendale, costituita da un certo numero di LANs viene suddivisa logicamente in un certo numero di virtual LANs. Il sistema NAC decide verso quale VLAN deve essere ridiretto l'AR in base ai suoi permessi e al suo stato di salute.
- **Firewall:** permettono o negano il traffico tra un host nella rete e uno esterno
- **Gestione DHCP:** il Dynamic host configuration protocol si occupa dell'assegnazione degli indirizzi IP, attraverso esso si possono imporre gli IP

Extensible authentication protocol

EAP è un framework che fornisce delle funzionalità comuni e dei metodi di negoziazione e autenticazione detti metodi EAP (EAP-MD5, EAP-TLS).

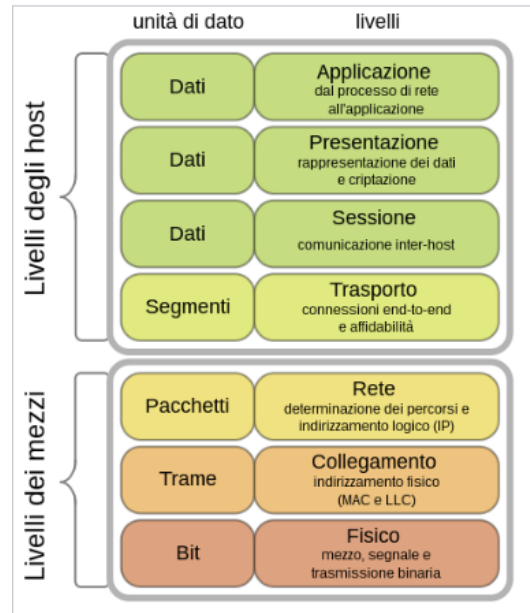
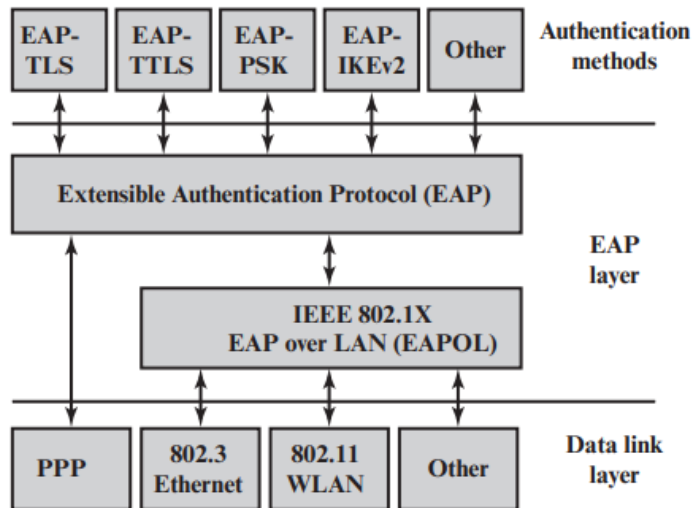
Fornisce un servizio per lo scambio di informazioni tra un client e un server di autenticazione. Permette di incapsulare i frame di vari protocolli di autenticazione.

Entità

- **authenticator:** entità che si occupa dell'autenticazione delle altre entità
- **peer:** entità che chiede di essere autenticata
- **backend authentication server:** entità che fornisce un servizio di autenticazione all'authenticator; esegue i metodi EAP per l'authenticator.

Metodi di autenticazione

EAP (extensible authentication method) supporta più metodi di autenticazione, per questo ci si riferisce a lui come estensibile. Fornisce un servizio di trasporto generico per lo scambio delle informazioni di autenticazione tra i client e il server, che viene esteso usando uno specifico protocollo di autenticazione installato sia sul client che sul server.



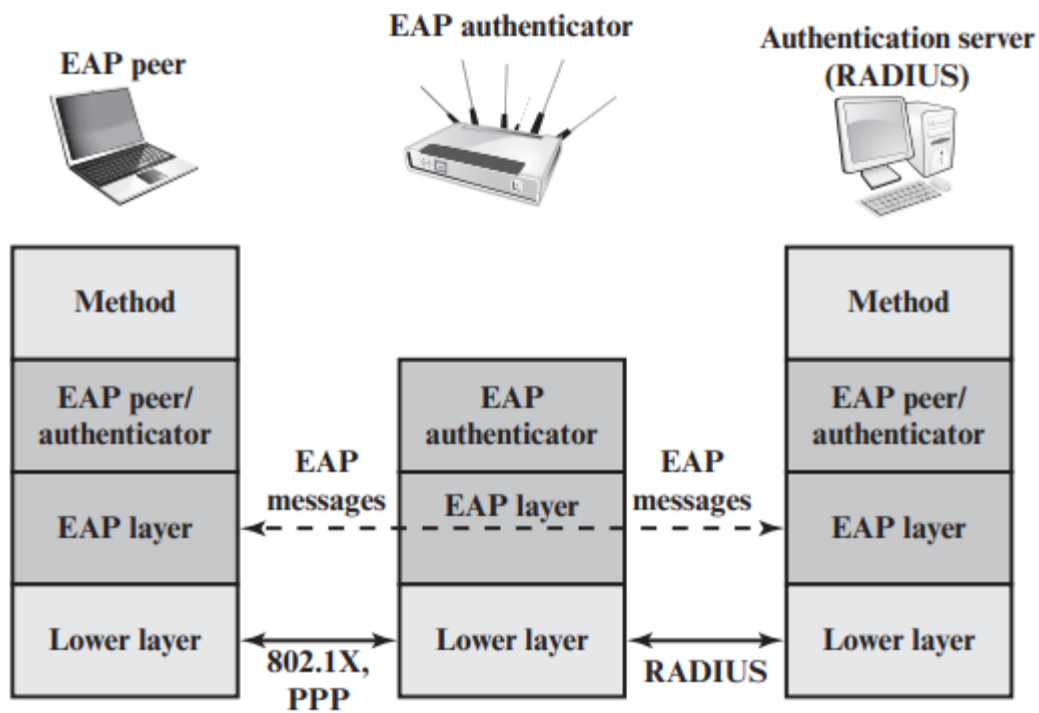
metodi di autenticazione maggiormente utilizzati sono:

- EAP-TLS: definisce **come il protocollo TLS può essere incapsulato in messaggi EAP**. EAP-TLS utilizza l'infrastruttura a chiave pubblica per autenticare client e server tramite i rispettivi certificati.
- EAP-TTLS: EAP- tunneled TLS
- EAP-IKEv2: basato su Internet Key Exchange protocol v2, supporta la mutua autenticazione e la creazione di una chiave di sessione.

Scambi EAP

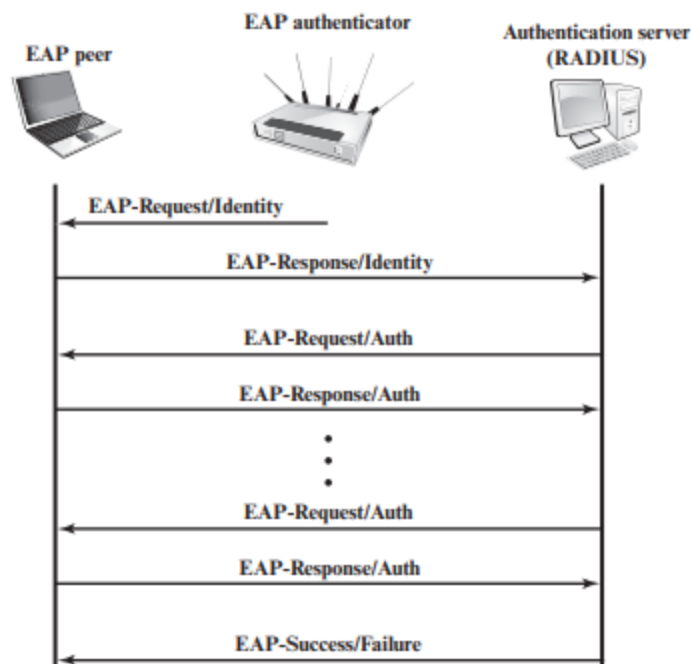
Qualsiasi sia il protocollo utilizzato per l'autenticazione, le informazioni di autenticazione e quelle del protocollo di autenticazione sono trasportate in messaggi EAP.

L'autenticazione viene svolta attraverso lo scambio di messaggi EAP tra il client e l'autenticatore.

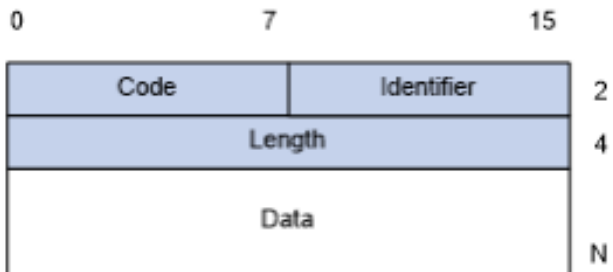


L'EAP authenticator è un nodo, come ad esempio un NAS che richiede l'autenticazione EAP prima di garantire l'accesso al server.

Passi dello scambio di autenticazione:



1. viene fatto uno scambio che stabilisce la necessità di uno scambio EAP
2. l'autenticatore invia una richiesta di identificazione al peer al quale segue uno scambio per l'ottenimento di tutte le informazioni di autenticazione; nel momento in cui il peer risponde con il primo messaggio contenente il suo identificativo, l'autenticatore sceglie un metodo di autenticazione supportato da EAP e inserisce nella risposta un campo indicante il type, il peer può accettare il metodo o mandare un messaggio che notifica la mancata accettazione.
3. lo scambio termina quando l'autenticatore stabilisce che può o non può autenticare il peer



Un pacchetto EAP contiene i campi:

- code: tipo di pacchetto (1 richiesta, 2 risposta, 3 successo, 4 fallimento)
- identifier: utilizzato per far corrispondere richiesta e risposta
- length: lunghezza del pacchetto
- data: utilizzato se il pacchetto è di tipo 1 o 2; contiene le informazioni del pacchetto (dipendono dal metodo).

Ogni metodo aggiunge dei propri campi a questo pacchetto base.

RADIUS (remote authentication dial-in user service)

Protocollo AAA (authorization, authentication, accounting) per la gestione degli accessi a una rete. È un protocollo del livello di applicazione che può utilizzare sia TCP che UDP. È implementato come un processo in background sui sistemi UNIX e Microsoft.

Utilizza due tipi di pacchetti per gestire il processo AAA:

- **Access-Request:** gestisce autenticazione e autorizzazione
- **Accounting-Request:** gestione del processo di accounting

Accounting: processo necessario per tenere traccia dell'attività dell'utente quando accede le risorse di rete, incluso il tempo speso nella rete, i servizi acceduti, la quantità di dati trasferiti durante la sessione.

Comunicazione di autenticazione

Le entità sono 3: l'utente che si vuole autenticare, il NAS e il server RADIUS.

L'utente invia una richiesta contenente le credenziali al NAS, il NAS invia una Access-request al server RADIUS che può fare i controlli di autenticazione in autonomia oppure affidarsi a una risorsa esterna (SQL, Kerberos, Active directory).

Il server RADIUS può restituire tre tipi di risposta:

Access Reject: l'utente non può accedere a nessuna risorsa della rete.

Access Challenge: vengono richieste informazioni aggiuntive come una password secondaria, un PIN, un token. Questa risposta viene inviata anche quando si hanno processi di autenticazione più complicati dove viene stabilito un tunnel tra la macchina dell'utente e il server RADIUS in modo che le credenziali non siano visibili al NAS.

Access Accept: viene garantito l'accesso. Il server RADIUS controlla che l'utente sia autorizzato a utilizzare il servizio richiesto. Le informazioni riguardanti l'autorizzazione possono essere mantenute nel server RADIUS o su un altro server.

Nel momento in cui l'utente è autenticato viene iniziata la fase di accounting, il NAS invia al server RADIUS un messaggio di tipo Accounting-Request con il campo acct_status_type=start che contiene l'identificativo dell'utente e altra informazioni. Il server RADIUS risponde e durante la sessione il NAS può inviare dei messaggi che modificano lo stato della sessione attiva.

Nel momento in cui l'utente termina la connessione alla rete, il NAS invia un messaggio di tipo Accounting Stop.

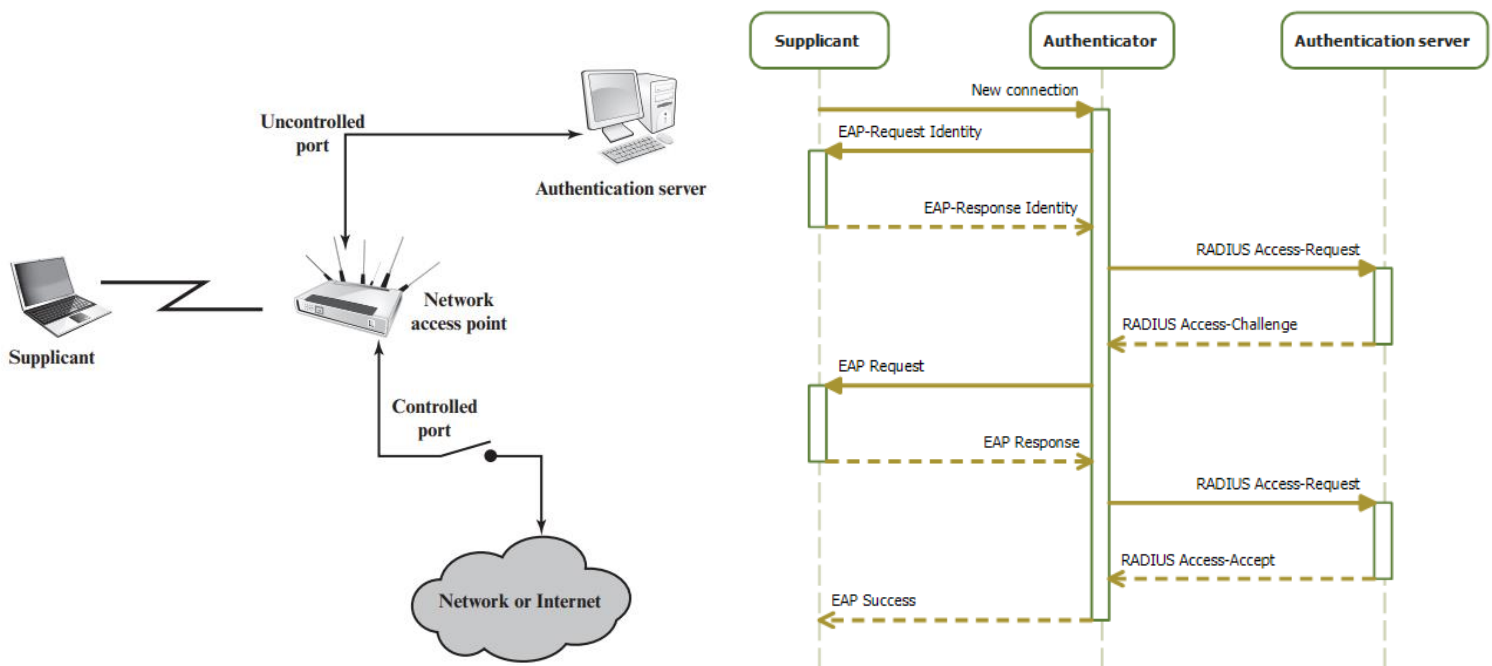
802.1X, port-based access control

Lo **standard 802.1X** è stato progettato per il controllo degli accessi alle LAN attraverso porte fisiche (es quelle degli switches). È supportato dalla maggior parte dei nuovi switch.

I termini principali sono:

- Autenticatore: entità a uno degli estremi della LAN che facilita l'autenticazione dell'entità all'altro estremo
- Scambio di autenticazione: conversazione tra sistemi che svolgono il processo di autenticazione
- Processo di autenticazione: operazioni crittografiche e supporto per i data frame in cui consiste l'autenticazione
- Server di autenticazione AS: entità che fornisce il servizio di autenticazione; in base alle credenziali fornite dal supplicante stabilisce se può concedergli l'accesso alle risorse del sistema in cui risiede

Ogni porta logica dello switch viene mappata in uno dei due tipi di porta fisica: una **porta non controllata** che permette al supplicant di scambiare messaggi con l'AS indipendentemente dal suo stato di autenticazione o una **porta controllata**, che permette gli scambi solo se il supplicant è autenticato e autorizzato.



Quando un nuovo supplicant viene rilevato, solo la porta dell'autenticator è attiva e impostata sullo stato "unauthorized", nel quale solo il traffico 802.1X è consentito. Altro traffico basato su protocolli internet come TCP/UDP è respinto.

Per avviare la fase di autenticazione, l'autenticator trasmette ad intervalli regolari dei frame, detti *EAP-request identity*, ad uno specifico indirizzo di livello 2 sulla rete locale; il supplicant rimane in ascolto su questo indirizzo e risponde con un *EAP-Response identity* contenente un identificativo. L'autenticatore incapsula il frame in un pacchetto RADIUS e lo invia all'AS. Il supplicant potrebbe anche iniziare la procedura inviando un *EAPOL-Start frame* all'autenticator, che risponderebbe con un *EAP-Request identity*.

L'AS risponde con un pacchetto RADIUS contenente un *EAP Request* che specifica un *EAP Method* (il tipo di autenticazione che il supplicant deve eseguire). L'autenticatore incapsula l'*EAP Request* in un frame EAPOL e lo trasmette al supplicant. A questo punto il supplicant può iniziare ad utilizzare il metodo di autenticazione richiesto oppure inviare un *NAK*.

Se l'AS e il supplicant sono d'accordo sul metodo di autenticazione, vengono inviati dei frame tra il supplicant e l'AS, tradotti dall'autenticator, fino a che l'AS non risponde con un *EAP-Success* o un *EAP-Failure*. Se l'autenticazione va a buon fine, l'autenticatore imposta lo stato della porta su "autorizzato" e permette tutto il normale traffico. Nel momento in cui il supplicant si slogga, invia un *EAPOL-logoff* e l'autenticatore reimposta lo stato della porta a "unauthorized".

802.1X fa uso di **EAPOL** (EAP over LAN), un protocollo a livello di rete che permette al supplicant di comunicare con l'autenticatore e supporta lo scambio di pacchetti EAP.

Nel momento in cui il supplicant si connette alla rete non conosce il MAC dell'autenticatore, quindi invia un pacchetto

EAPOL-start a uno speciale gruppo multicast riservato per gli autenticatori; l'autenticatore invia una richiesta di identificazione incapsulata in un pacchetto **EAPOL-EAP**;

se il supplicant viene ammesso alla rete, l'autenticatore gli invia un pacchetto

EAPOL-key con le chiavi crittografiche;

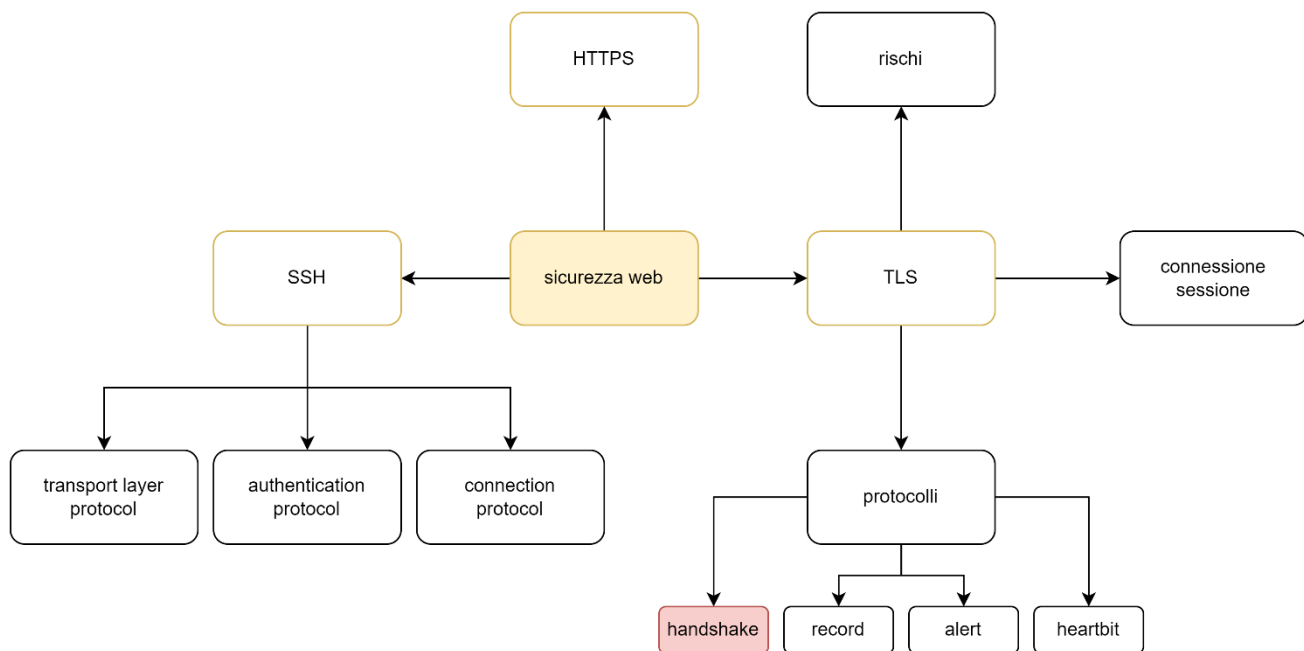
nel momento in cui il supplicant si vuole disconnettere dalla rete esso invia un pacchetto

EAPOL-logoff.

EAPOL

Incapsula i pacchetti EAP in pacchetti Ethernet, la sicurezza dello scambio dipende dal metodo EAP utilizzato (es EAP-TLS).

06 Trasport-level security



Discussione dei requisiti generali per la sicurezza del web e dei tre schemi che si focalizzano sulla sicurezza del transport layer: SSL/TLS, HTTPS, SSH.

Considerazioni sulla sicurezza del web

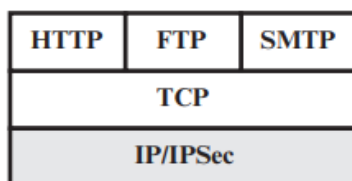
Ci sono alcuni aspetti delle applicazioni client/server basate sul web che richiedono delle apposite considerazioni di sicurezza: la facilità di uso dei browser e di configurazione dei server nasconde sw molto complesso che può essere a rischio di attacchi; gli utenti dei siti web possono essere incoscienti dei rischi che i loro dati possono correre.

I principali rischi sono riassunti nella tabella

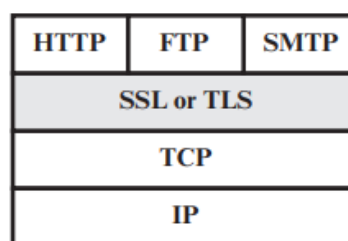
	Threats	Consequences	Countermeasures
Integrity	• Modification of user data • Trojan horse browser • Modification of memory • Modification of message traffic in transit	• Loss of information • Compromise of machine • Vulnerability to all other threats	Cryptographic checksums
Confidentiality	• Eavesdropping on the net • Theft of info from server • Theft of data from client • Info about network configuration • Info about which client talks to server	• Loss of information • Loss of privacy	Encryption, Web proxies
Denial of Service	• Killing of user threads • Flooding machine with bogus requests • Filling up disk or memory • Isolating machine by DNS attacks	• Disruptive • Annoying • Prevent user from getting work done	Difficult to prevent
Authentication	• Impersonation of legitimate users • Data forgery	• Misrepresentation of user • Belief that false information is valid	Cryptographic techniques

essi possono essere classificati in attivi e passivi oppure attraverso la localizzazione del rischio: nel server, nel browser, durante la trasmissione.

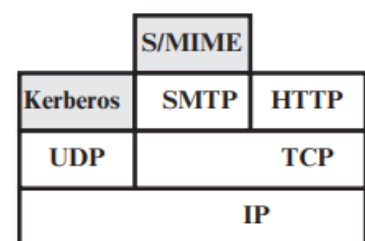
I meccanismi utilizzati per fornire sicurezza al traffico web differiscono per il loro posizionamento nello stack TCP/IP.



(a) Network level



(b) Transport level



(c) Application level

IPSec permette di avere una soluzione multi-purpose trasparente all'utente finale e alle applicazioni; solo il traffico selezionato viene filtrato.

SSL e TLS possono essere implementati come parte dei protocolli sottostanti ed essere trasparenti alle applicazioni oppure possono essere inseriti in specifici pacchetti.

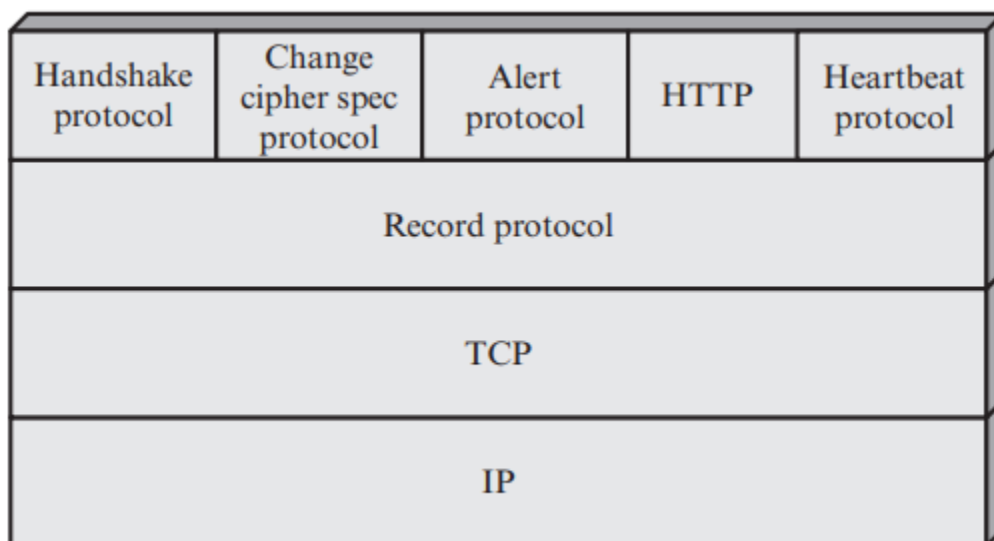
I servizi di sicurezza relativi alle applicazioni specifiche sono inclusi nelle stesse. Il servizio può essere studiato appositamente per i requisiti dell'applicazione.

Transport layer security

Uno dei servizi di sicurezza più utilizzati è **Transport Layer Security (TLS)**. TLS è uno standard Internet evoluto dal protocollo **Secure Socket Layer (SSL)**, che è stato deprecato.

TLS è un servizio general-purpose implementato come un insieme di protocolli che si appoggiano su TCP (l'insieme comprende protocolli sia a livello di trasporto che di applicazione).

Ha lo scopo di fornire una connessione sicura end-to-end.



Due concetti importanti di TLS sono la sessione e la connessione:

- **Connessione:** relazione peer-to-peer, ogni connessione è associata a una sessione. Le connessioni sono transitorie.
- **Sessione:** associazione tra un client e un server; viene creata dall'Handshake protocol; definisce un insieme di parametri di sicurezza crittografici che possono essere condivisi su più connessioni; sono utilizzate per evitare la negoziazione di nuovi parametri di sicurezza ad ogni connessione.

Lo stato di una sessione è definito da:

- **Identificativo della sessione:** sequenza arbitraria scelta dal server per identificare lo stato di una sessione attiva o ripristinabile.
- **Compression method:** algoritmo utilizzato per comprimere i dati prima della cifratura

- **Specifica della cifratura:** definisce l'algoritmo di cifratura dei dati e l'algoritmo di hash utilizzato per calcolare il MAC (message authentication code).
- **Master secret:** chiave segreta condivisa tra il client e il server
- **Is resumable:** flag che indica se la sessione può essere utilizzata per inizializzare nuove connessioni.

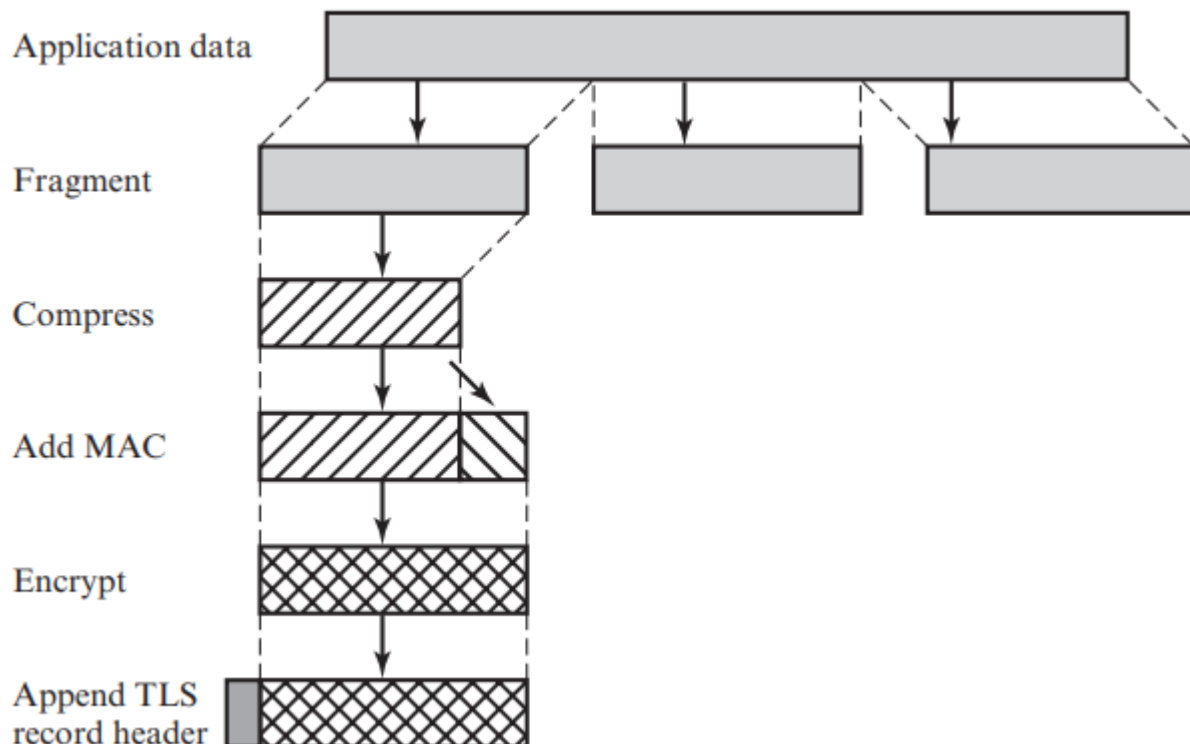
Lo stato della connessione è definito da:

- **Numero randomico:** scelto dal client e dal server per ogni connessione
- **Chiave MAC del server:** chiave segreta utilizzata nelle operazioni MAC sui dati inviati dal server
- **Chiave MAC del client:** chiave simmetrica utilizzata dal client
- **Chiave di cifratura del server:** utilizzata per la cifratura simmetrica dei dati da parte del server
- **Chiave di cifratura del client:** utilizzata per la cifratura simmetrica dei dati da parte del client
- **Vettori di inizializzazione:** quando viene utilizzato un cifrario a blocchi in modalità CBC, questo campo contiene i suoi vettori di inizializzazione

Record Protocol

Fornisce due servizi:

- **Confidenzialità:** l'handshake protocol definisce una chiave condivisa che viene usata per la cifratura convenzionale del payload
- **Integrità del messaggio:** l'handshake protocol definisce anche una chiave segreta condivisa che viene usata per generare un MAC



Il record protocol frammenta i dati del livello di applicazione in blocchi, li comprime, applica il MAC, li encrizza (chiave simmetrica) e vi appende l'header TLS.

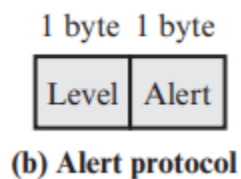
L'header contiene:

- **Content type**: indica il protocollo del livello di applicazione
- **Version**: versione del TLS utilizzata
- **Lunghezza post-compressione**

Change cypher spec protocol

Messaggio di un singolo byte con il valore di 1; serve a fare in modo che lo stato 'pending' venga copiato nello stato corrente, ciò aggiornata la suite crittografica da utilizzare nella connessione.

Alert protocol



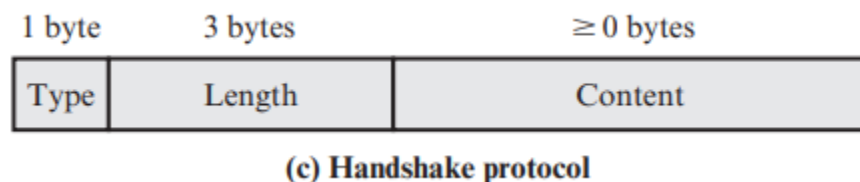
Utilizzato per trasportare alerts correlati al TLS all'altra entità, tali messaggi sono compressi e cifrati come specificato dallo stato corrente.

Ogni messaggio in questo protocollo consiste di due bit:

il primo prende il valore 1 quando l>alert è un avvertimento o 2 quando è un errore fatale, nel secondo caso TLS termina la connessione; altre connessioni nella stessa sessione potrebbero continuare ma non ne verranno stabilite delle nuove nella sessione corrente.

Il secondo byte contiene un codice che indica lo specifico alert, ci sono alert che sono sempre fatali.

Handshake protocol

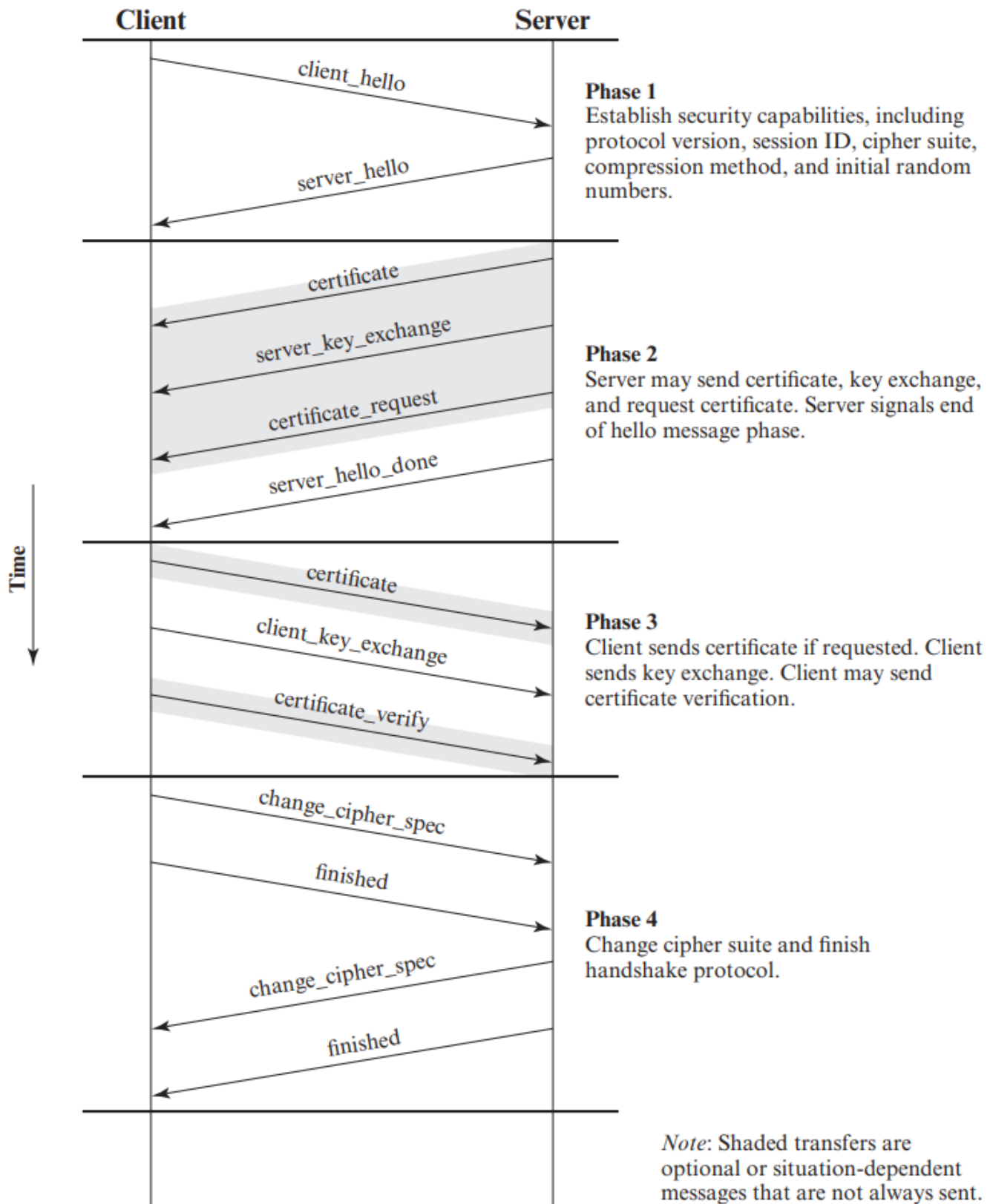


Parte più complessa di TLS; permette al client e al server di autenticarsi a vicenda e di negoziare il metodo di cifratura, l'algoritmo per il calcolo del MAC e le chiavi per la cifratura dei dati.

Viene utilizzato prima che vengano trasmessi i dati.

Ogni messaggio ha tre campi: tipo (vedi tabella), lunghezza e contenuti.

Lo scambio consiste di 4 fasi:



1. Definizione delle capacità:
nel messaggio 'client_hello' il client inserisce: gli algoritmi di cifratura e i metodi di compressione che supporta. Viene indicato anche se il client vuole continuare una sessione o iniziarne una nuova.
Il messaggio 'server_hello' contiene l'algoritmo di cifratura e il metodo di compressione scelti dal server a partire da quelli elencati dal client; in questo momento client e server scelgono come scambiarsi le chiavi di cui avranno bisogno.
2. Autenticazione del server e scambio delle chiavi:
il server inizia lo scambio inviando il suo certificato se esso deve autenticarsi; viene inviato il messaggio **server_key_exchange** nel caso in cui lo scambio delle chiavi viene fatto con Diffie-Hellman oppure con RSA (il server deve creare un paio di chiavi RSA e usare il messaggio **server_key_exchange** per inviare quella pubblica che verrà utilizzata dal client per cifrare la chiave simmetrica).
3. Autenticazione del client e scambio delle chiavi:
se il server ha richiesto il certificato del client questo scambio inizia con l'invio di quello; segue il messaggio **client_key_exchange**, il cui contenuto dipende dal tipo di scambio scelto: per RSA contiene una chiave cifrata con la chiave inviata dal server; per Diffie-Hellman contiene i parametri pubblici del client.
4. Conclusione

Heartbeat protocol

Heartbeat= segnale periodico che viene usato per indicare il normale funzionamento o di sincronizzare altre parti di un sistema.

Il protocollo heartbeat viene utilizzato per monitorare la disponibilità di un'entità protocollare. Nel caso di TLS, esso si trova sopra al Record Protocol e consiste di due tipi di messaggi:

heartbeat_request e **heartbeat_response**. L'uso di tale protocollo viene stabilito durante la fase 1 dell'handshake: ognuno dei due peer indica se supporta il protocollo.

Il protocollo ha due scopi: assicurare a una delle due parti che l'altra è ancora in ascolto, generare traffico sulla connessione durante i periodi in cui le due entità non si trasmettono dati in modo da evitare che un firewall possa chiudere la connessione.

HTTPS

HTTP over SSL, si riferisce alla combinazione di HTTP e SSL per implementare una comunicazione sicura tra un client e un server web; utilizza la porta 443 che invoca SSL.

Quando viene utilizzato vengono cifrati: Url del documento richiesto, il contenuto del documento, il contenuto dei form, i cookie, gli header HTTP.

Inizializzazione della connessione

Il client inizia la connessione al server sulla porta appropriata e invia il messaggio ClientHello TLS per iniziare l'handshake TLS. Quando l'handshake è terminato il client invia la prima richiesta HTTP; tutti i dati HTTP vengono inviati come application data di TLS.

Chiusura della connessione

La chiusura della connessione HTTPS richiede la relativa a livello TLS; per la corretta chiusura della connessione TLS è necessario un messaggio **close_notify** di cui deve essere attesa la risposta; HTTPS deve essere in grado di reagire anche alle connessioni TCP non chiuse correttamente anche se esse potrebbero indicare la presenza di un attacco, quindi viene inviato un messaggio di allerta.

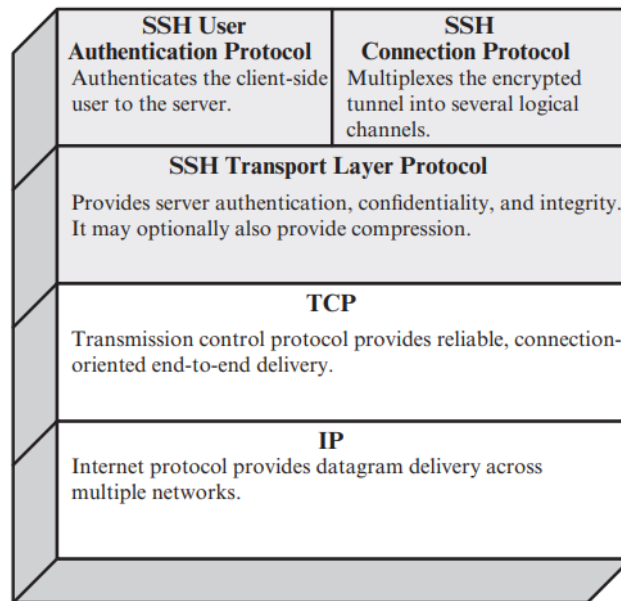
SSH (Secure shell)

Protocollo per la sicurezza delle comunicazioni in rete, progettato per essere relativamente semplice e poco costoso da implementare; permette di usufruire in sicurezza di servizi su reti non sicure.

Le sue applicazioni più diffuse sono il login remoto e l'esecuzione da linea di comando.

È un protocollo client-server il che significa che le due entità che comunicano devono essere abilitate all'utilizzo di SSH (deve essere installato il software adeguato).

La prima versione era incentrata sul fornire un servizio di logon remoto sicuro per rimpiazzare TELNET; può essere utilizzato anche per il trasferimento di file e e-mail.



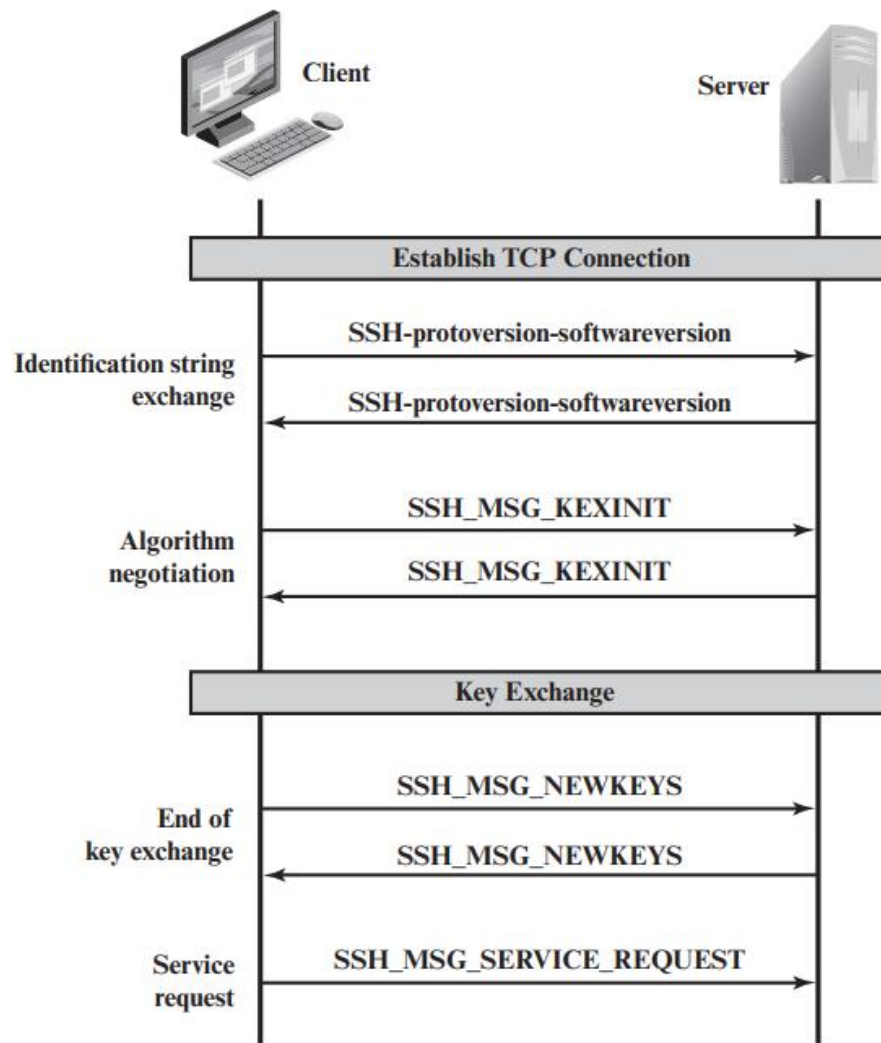
È organizzato in tre protocolli allo stack sopra TCP:

- **Transport layer protocol:** fornisce autenticazione del server, confidenzialità e integrità dei dati
- **User authentication protocol:** autentica l'utente al server
- **Connection protocol:** permette di avere diversi canali di comunicazione logici che si appoggiano a una singola connessione SSH

Transport layer protocol

Il server deve possedere una coppia di chiavi pubblica/privata utilizzate per la sua autenticazione. Il client deve avere la chiave pubblica dell'host prima di iniziare la connessione SSH. Ci sono due possibilità:

1. Il client ha un DB locale che associa a ogni host la sua chiave pubblica.
2. L'associazione host name-chiave viene certificata da una CA. Il client conosce solo la chiave della CA e può verificare l'autenticità di tutte le chiavi fornite dal server.



Il client stabilisce una connessione TCP con il server.

Il server invia la sua chiave pubblica al client che la confronta con quella contenuta nel DB locale o ottenuta dalla CA.

Dopo che il server è stato autenticato inizia la fase di negoziazione dell'algoritmo di cifratura: sia il client che il server inviano gli algoritmi supportati ordinati per preferenza.

Successivamente inizia la fase necessaria per la determinazione della master key tramite Diffie-Hellman.

User authentication protocol

Fornisce i mezzi attraverso cui il client si identifica presso il server.

I metodi di autenticazione sono:

- **chiave pubblica:** il client invia un messaggio al server che contiene la sua chiave pubblica, firmato con la chiave privata. Quando il server riceve il messaggio controlla se la chiave è accettabile per l'autenticazione e se la firma è corretta.
- **password:** il client invia un messaggio contenente la password in chiaro e esso viene protetto dalla cifratura del protocollo del livello di trasporto.
- **host-based:** viene autenticato l'host del client e non il client stesso; il client invia una firma generata a partire dalla chiave privata del suo host.

Connection protocol

Presuppone che sia in uso una connessione di autenticazione sicura detta **tunnel**, essa viene utilizzata dal connection protocol per creare n canali logici.

Tutti i tipi di comunicazione che utilizzano SSH, come le sessioni dei terminali, sono supportate utilizzando canali separati. Ad ogni canale, ogni parte associa un identificativo che deve essere lo stesso.

Quando una delle due parti vuole aprire un canale alloca un numero locale per quel canale e invia un messaggio contenente: il tipo di canale, il numero del canale e delle informazioni riguardanti i pacchetti che verranno inviati attraverso esso.

Una volta che il canale è aperto il trasferimento dei dati viene svolto usando uno specifico messaggio che include in numero del canale e il blocco di dati.

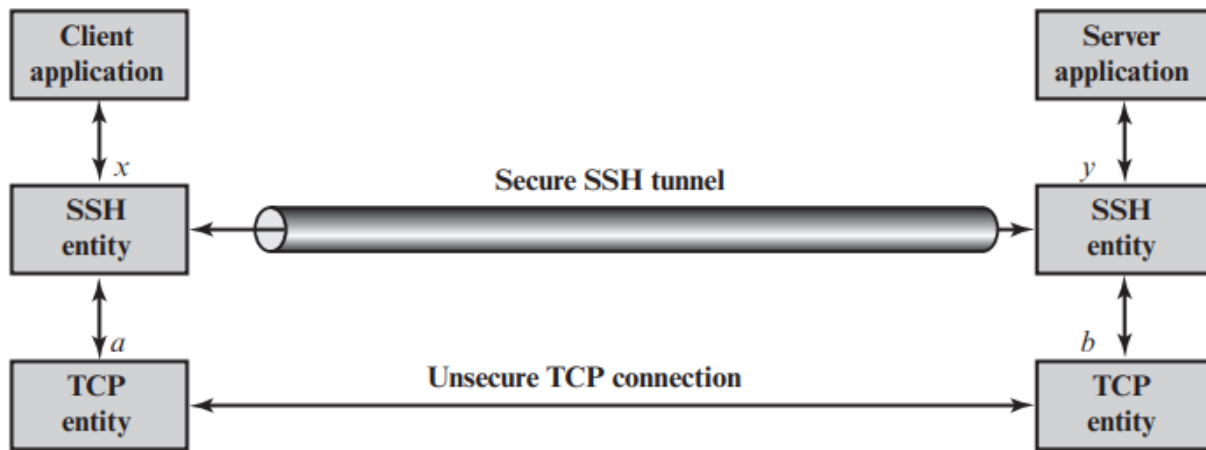
La chiusura del canale viene effettuata attraverso l'invio di uno specifico messaggio contenente il numero del canale.

Tipi di canale:

1. **sessione:** esecuzione remota di un programma
2. **x11:** protocollo che fornisce un'interfaccia grafica per le applicazioni che girano sul server
3. **forwarded-tcpip**
4. **direct-tcpip**

Port forwarding: una delle componenti più importanti di SSH è il port forwarding; fornisce la possibilità di convertire ogni connessione TCP non sicura in una connessione SSH sicura. In questo contesto con il termine porta ci si riferisce all'identificativo di un utente TCP. Ogni applicazione che gira sopra TCP ha un numero di porta; il traffico TCP viene consegnato all'applicazione appropriata in base al numero di porta. Per rendere sicura la connessione TCP, SSH è configurato in modo che il transport layer protocol stabilisce una connessione TCP tra il client SSH e le applicazioni del server;

viene stabilito un tunnel SSH sopra la connessione TCP. Il traffico TCP viene rediretto verso la porta scelta da SSH.

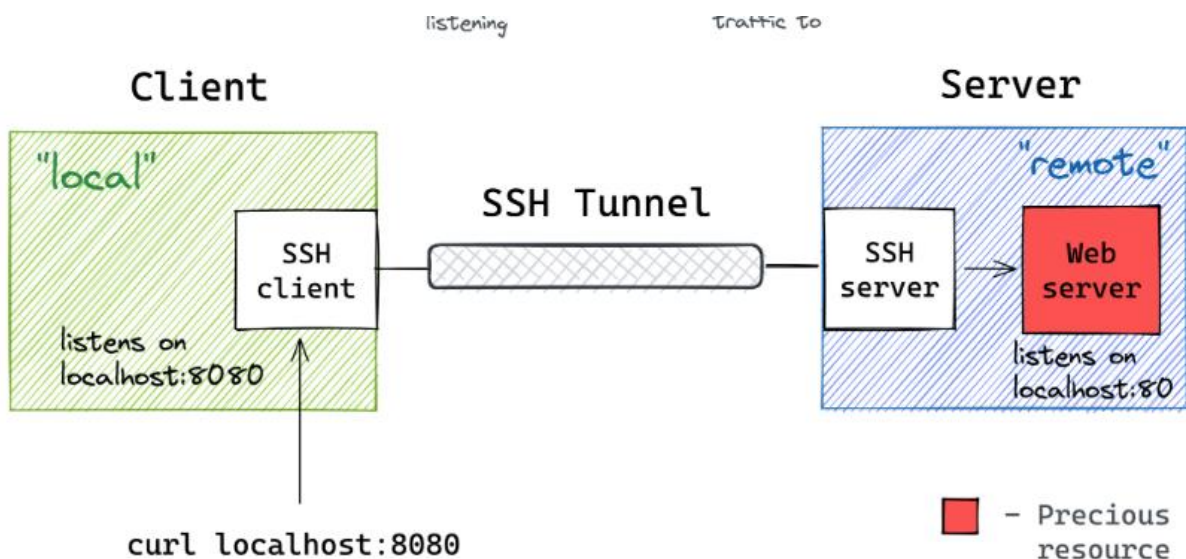


SSH supporta due tipi di port forwarding: locale e remoto.

Il **forwarding locale** permette al client di settare un processo dirottatore che intercetta il traffico del livello di applicazione selezionato e lo indirige verso un tunnel SSH sicuro; dall'altra parte SSH riceve il traffico sulla porta selezionata e lo invia alla porta di destinazione indicata dal client.

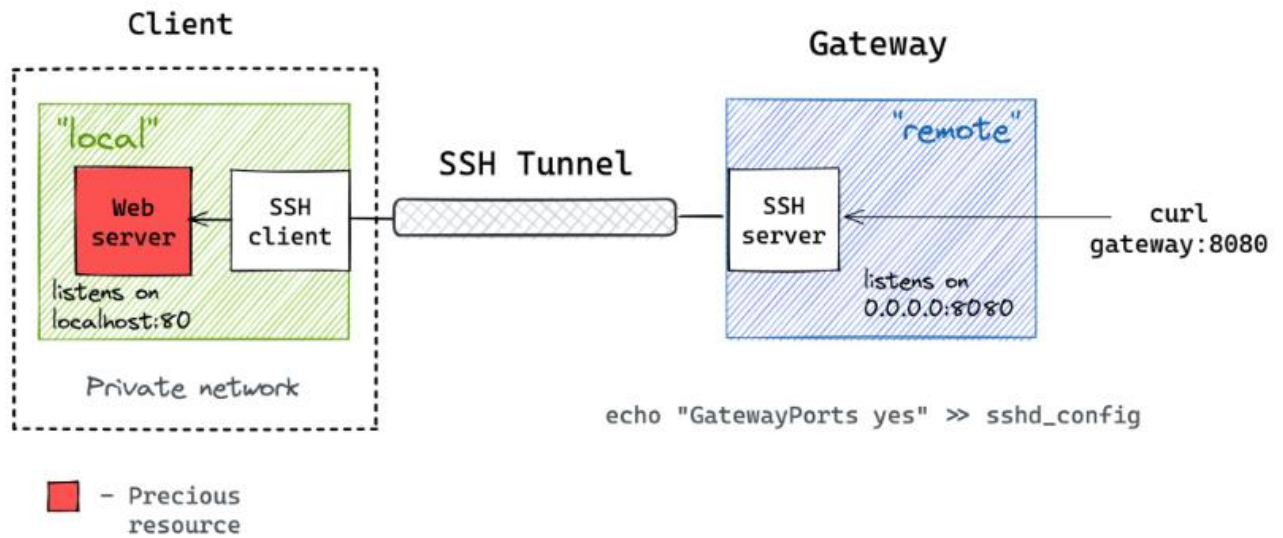
```
ssh -L [local_addr:]local_port:remote_addr:remote_port [user@]sshd_addr
```

Nella macchina del client, SSH ascolta tutto il traffico verso la porta local_port e lo invia tramite il tunnel a remote_addr:remote_port

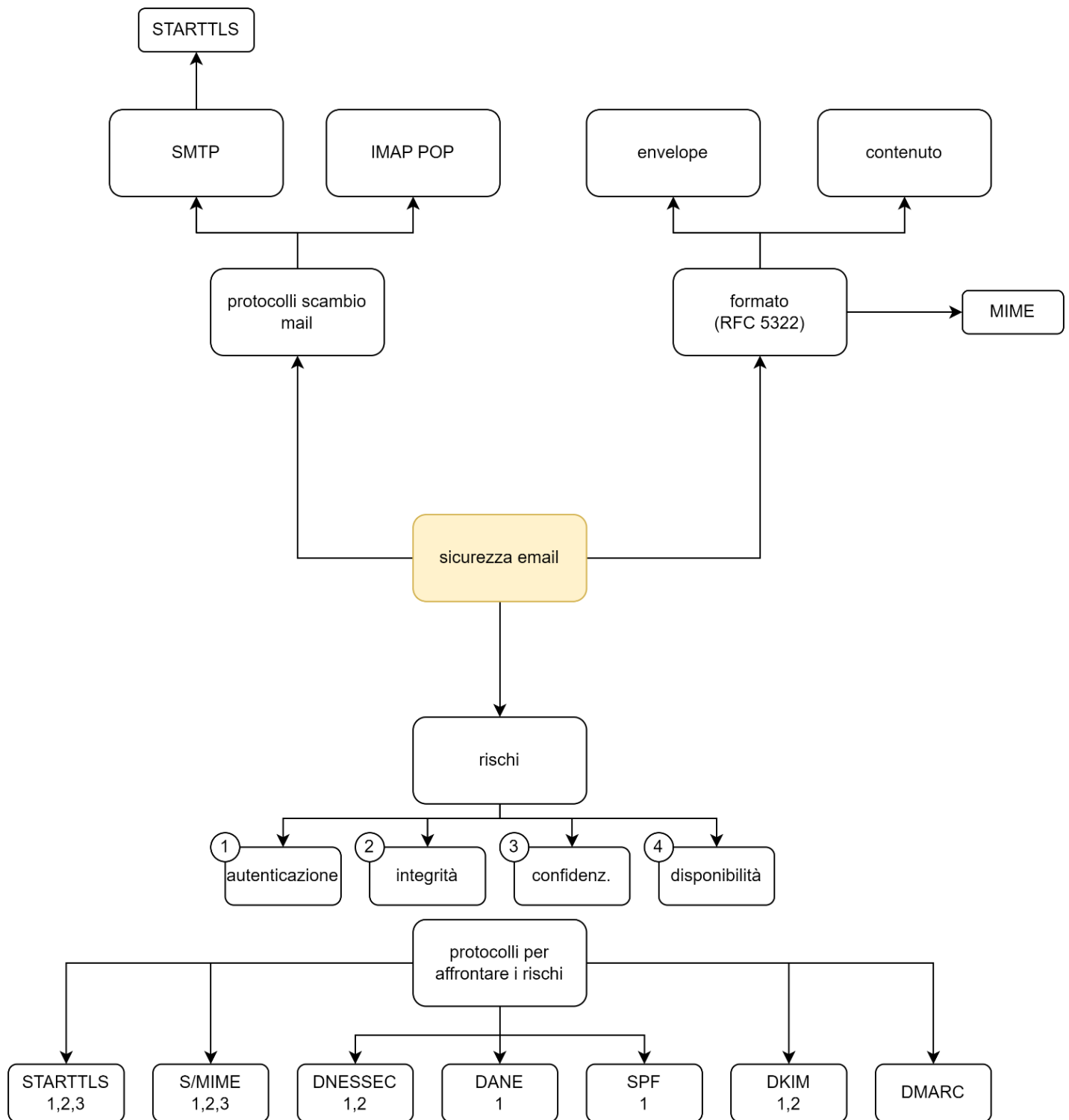


Il forwarding remoto viene usato per esporre momentaneamente un servizio locale al resto del mondo.

```
ssh -R [remote_addr:]remote_port:local_addr:local_port [user@]gateway_addr
```

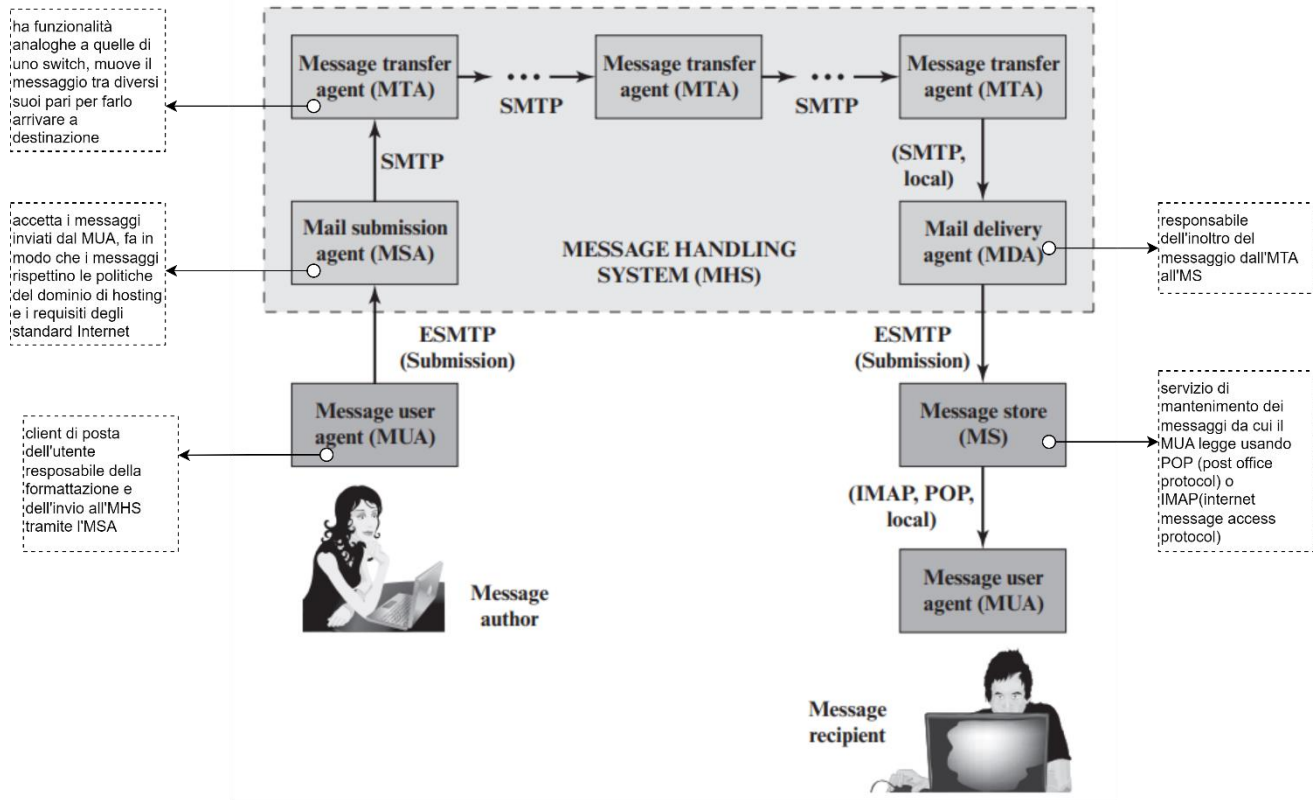


08 Sicurezza e-mail



Internet mail architecture

Componenti delle e-mail



Altri due elementi sono fondamentali nell'architettura:

- ADMD: administrative management domain, email provider
- DNS: servizio di lookup che permette di mappare il nome di un host nel suo indirizzo IP

Protocolli

Due protocolli vengono utilizzati per lo scambio mail: SMTP, per spostare i messaggi attraverso internet dal mittente al destinatario; IMAP o POP per il trasferimento dei messaggi tra mail servers.

SMTP è un protocollo che incapsula i messaggi email in un involucro ed è usato per inviare il messaggio dal mittente al destinatario attraverso i vari MTA. È un protocollo text based in cui il client (il mittente) contatta il server (next-hop recipient) e gli invia un set di comandi relativi al messaggio da inviare e il messaggio stesso. Il mittente e il destinatario possono essere separati da un solo server SMTP oppure i server SMTP nel percorso diventano a loro volta client per il server successivo.

Comunicazione SMTP

```
S: 220 foo.com Simple Mail Transfer Service Ready
C: HELO bar.com
S: 250 OK
C: MAIL FROM:<Smith@bar.com>
S: 250 OK
C: RCPT TO:<Jones@foo.com>
S: 250 OK
C: RCPT TO:<Green@foo.com>
S: 550 No such user here
C: RCPT TO:<Brown@foo.com>
S: 250 OK
C: DATA
S: 354 Start mail input; end with <cr><lf>.<cr><lf>
C: Blah blah blah . . .
C: . . . etc. etc. etc.
C: <cr><lf><cr><lf>
S: 250 OK
C: QUIT
S: 221 foo.com Service closing transmission channel
```

È possibile utilizzare un'estensione per SMTP detta STARTTLS, che offre confidenzialità e autenticazione alla comunicazione.

POP (post office protocol) permette a un client di scaricare un messaggio email da un email server; la connessione tra il client e il server è TCP e per poter accedere alla mail il client deve fornire username e password. IMAP fornisce un meccanismo di autenticazione più forte di quello di POP.

Formati email

Il formato tradizionale delle email è definito dal RFC 5322 del 2008 che suddivide la struttura complessiva della mail in due parti: il contenitore o envelope (informazioni per la trasmissione della mail) e il contenuto; lo standard 5322 si applica solo al contenuto. Per lo standard il contenuto può avere una serie di header che possono essere usati per creare l'envelope.

La struttura di un messaggio che soddisfa lo standard 5322 è semplice: il messaggio consiste in una serie di linee (header) seguite da una linea bianca e dal body. La linea bianca fa da separatore tra le due sezioni.

```
Date: October 8, 2009 2:15:49 PM EDT
From: "William Stallings" <ws@shore.net>
Subject: The Syntax in RFC 5322
To: Smith@Other-host.com
Cc: Jones@Yet-Another-Host.com
```

```
Hello. This section begins the actual
message body, which is delimited from the
message heading by a blank line.
```

MIME (multipurpose internet mail extension) è un'estensione di 5322 che ha lo scopo di risolvere i seguenti problemi di SMTP:

- impossibilità di trasmettere file eseguibili o oggetti binari
- impossibilità di trasmettere caratteri rappresentati con 8 bit, SMTP utilizza la formattazione ASCII a 7 bit.
- i server SMTP potrebbero rifiutare messaggi troppo pesanti
- problemi di formattazione generici

La specifica MIME include gli elementi:

- nuovi campi per l'header che specificano informazioni sul body
- supporto multimediale
- supporto per la conversione dei contenuti

Nuovi header:

- **MIME-version:** indica che il messaggio è conforme alla specifica MIME
- **Content-Type:** descrive il tipo di contenuto della mail in modo che il ricevente possa scegliere l'agente o meccanismo appropriato per la rappresentazione

- **Content-transfer-encoding:** indica il tipo di trasformazione applicata al contenuto del messaggio per renderlo idoneo al trasferimento
- **Content-ID:** usato per identificare le entità MIME in maniera univoca in diversi contesti
- **Content-Description:** descrizione testuale del contenuto, utile quando il contenuto non è leggibile (es: audio)

Canonical Form: formato, dipendente dal tipo di contenuto del messaggio, standardizzato per l'uso tra sistemi. Nasce per ovviare al problema della lettura del **Native Form** da parte di sistemi diversi; la native form comprende l'uso dei caratteri nativi del sistema e delle convenzioni sui terminatori di linea. La canonical form consiste nella traduzione in un sistema di formattazione universale della native form del sistema.

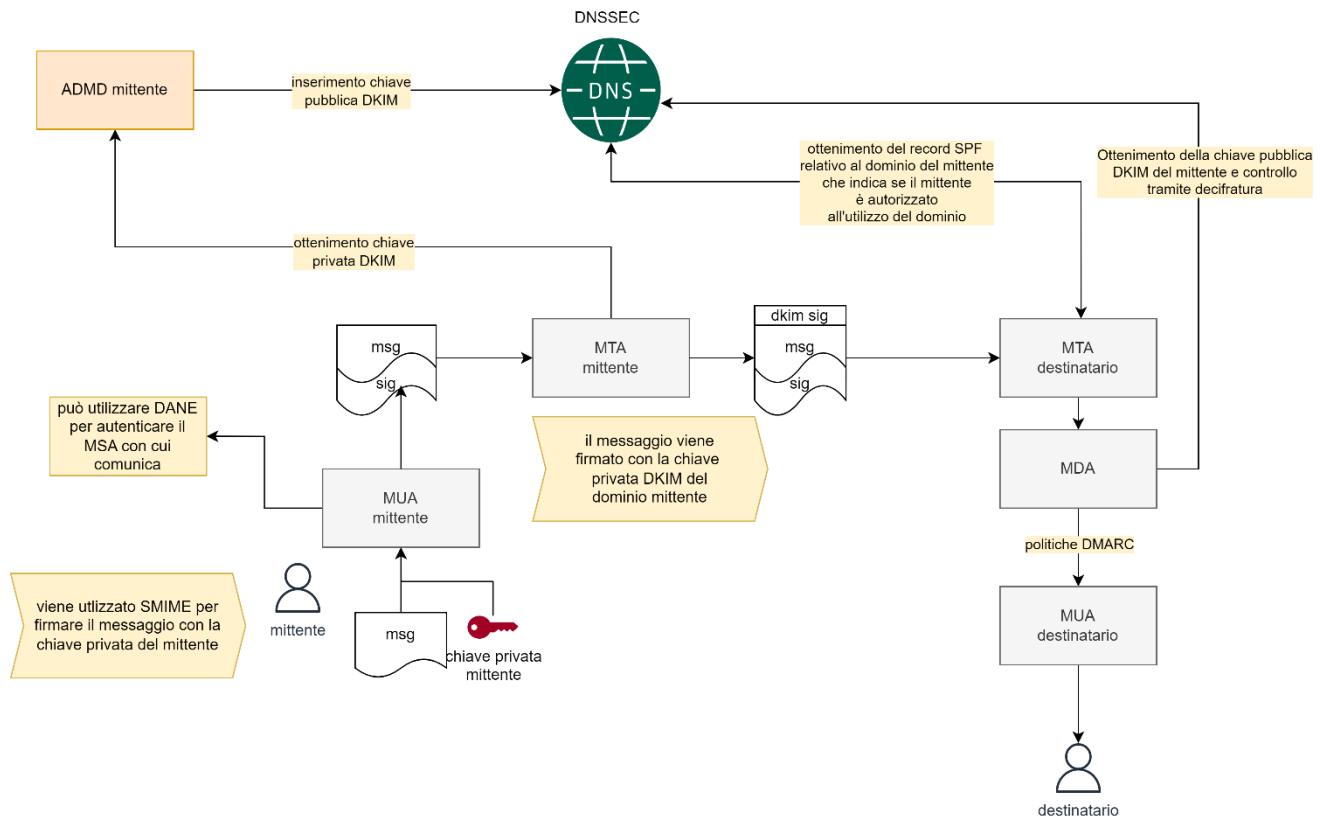
Rischi e sicurezza

I rischi inerenti le email possono essere classificati in:

- di autenticazione
- di integrità
- di confidenzialità
- di disponibilità

Lo standard 800-177 indica alcuni protocolli come mezzo per la difesa contro questi rischi:

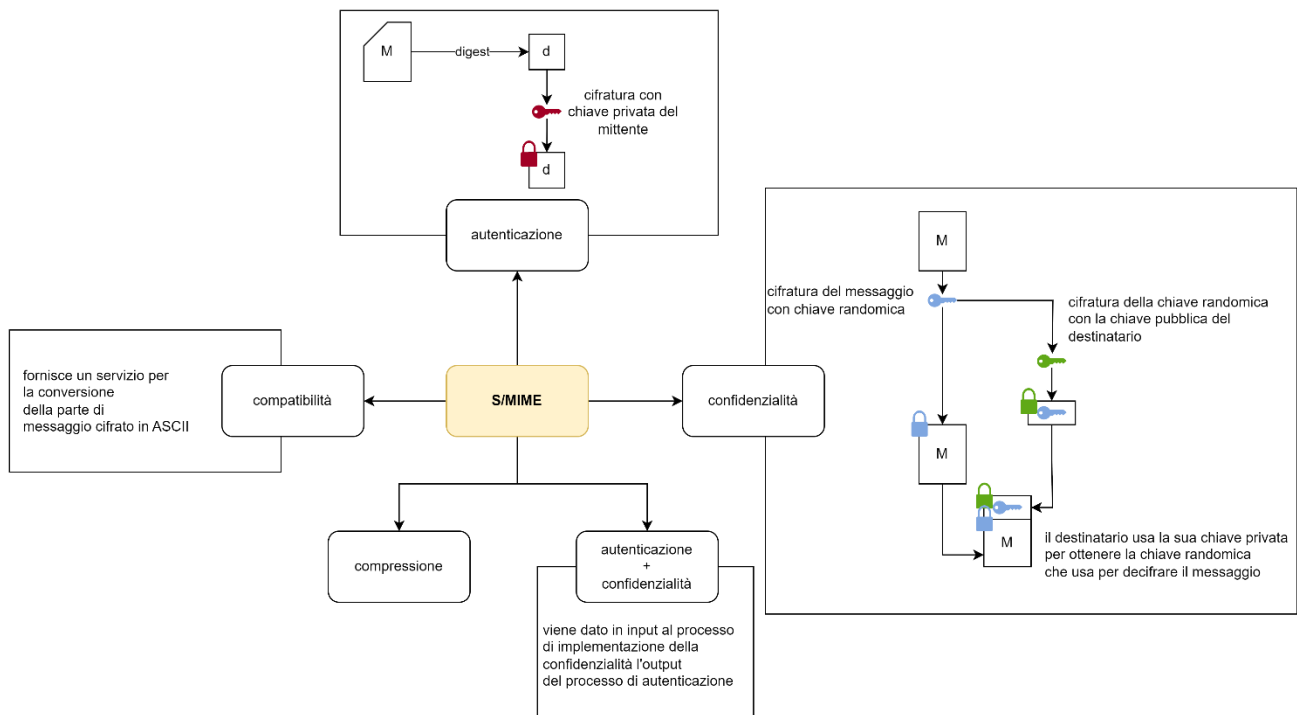
- **STARTTLS:** fornisce autenticazione, non-ripudio (tramite firma digitale), integrità e confidenzialità (tramite cifratura) del corpo del messaggio
- **S/MIME:** come sopra
- **DNS security extension (DNSSEC):** fornisce autenticazione e integrità dei dati del DNS
- **DNS-base authentication of named entities (DANE):** permette di associare un certificato a chiave pubblica a un certo dominio tramite un record DNS, in modo da poterlo autenticare senza ricorrere a una CA
- **Sender policy framework (SPF):** utilizza DNS per permettere ai proprietari dei domini di creare dei record di associazione tra il nome del dominio e un range di indirizzi IP di mittenti autorizzati. Permette di eliminare i messaggi provenienti da indirizzi IP che non sono autorizzati ad utilizzare il dominio per l'invio dei messaggi.
- **DomainKeys identified mail (DKIM):** permette a un MTA di firmare alcuni header e il corpo del messaggio in modo da validare il dominio mittente e fornire l'integrità del corpo del messaggio.
- **Domain-base message authentication, reporting and conformance (DMARC):** permette ai mittenti di conoscere l'efficacia delle loro politiche SPF e DKIM



S/MIME

SMIME = secure multipurpose internet mail extension; è un miglioramento alla sicurezza di MIME.

Fornisce 4 servizi: autenticazione, confidenzialità, compressione, compatibilità.



Autenticazione

Fornita tramite firma digitale. Viene usato RSA con SHA-256:

1. il mittente crea il messaggio
2. viene usato SHA-256 per generare un digest del messaggio
3. il digest viene cifrato con RSA usando la chiave privata del mittente e il risultato è appeso al messaggio insieme alle informazioni che permetteranno al destinatario di ottenere la chiave pubblica del mittente
4. il destinatario usa RSA con la chiave pubblica del mittente per decifrare il messaggio e recuperare il digest
5. il destinatario utilizza il corpo del messaggio per generare il digest e lo confronta con quello appena ottenuto

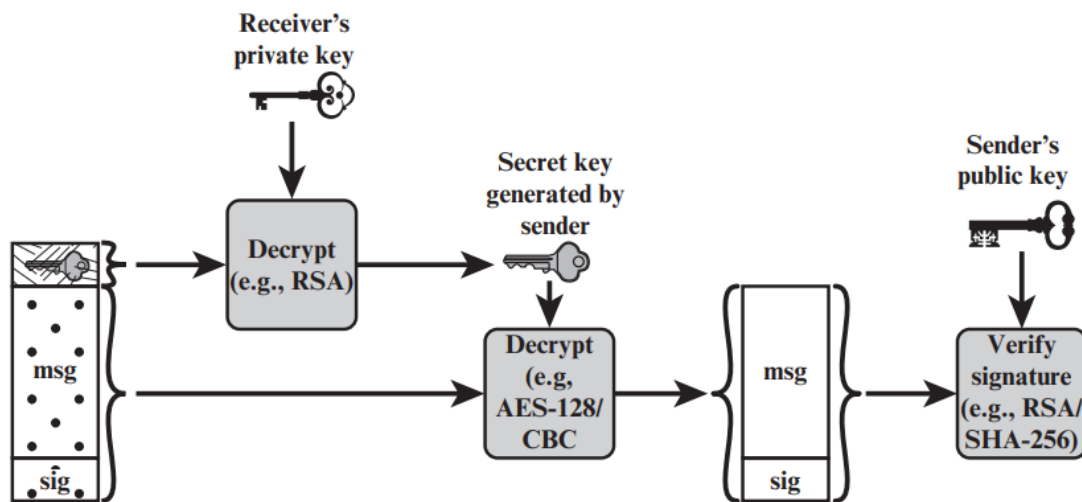
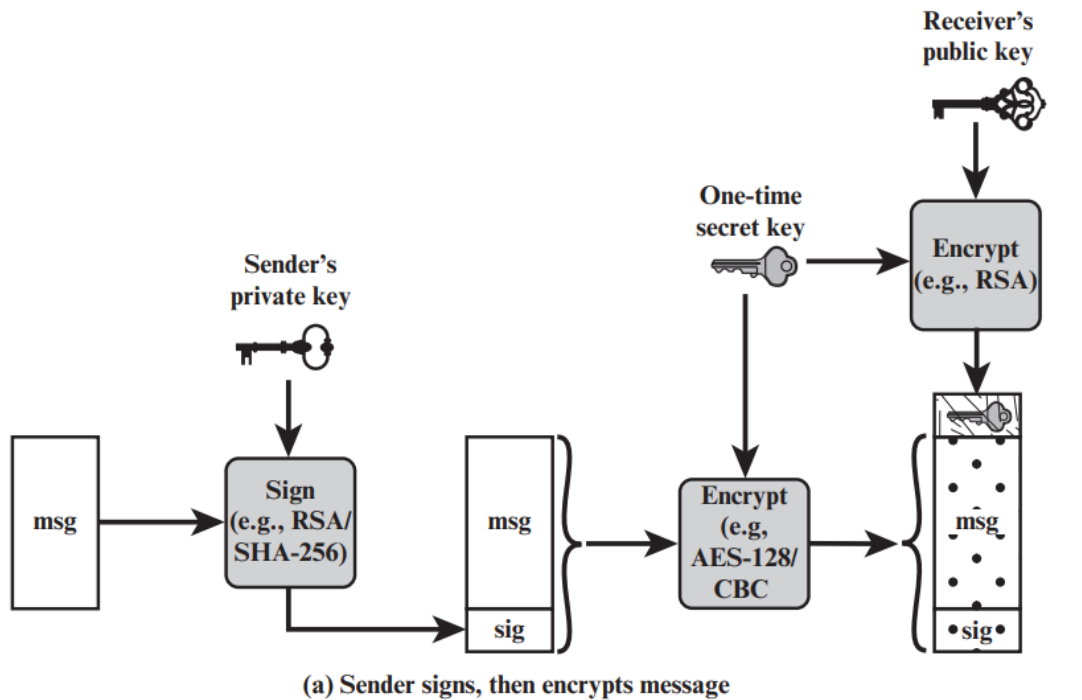
Confidenzialità

S/MIME fornisce confidenzialità attraverso la cifratura del messaggio; spesso viene usato AES con una chiave da 128-bit e la modalità CBC. La chiave usata è simmetrica e viene usata solo una volta per messaggio quindi deve essere inviata con il messaggio stesso cifrandola con la chiave pubblica del destinatario.

Il processo è il seguente:

1. il mittente genera il messaggio e una chiave randomica da 128-bit
2. il messaggio viene criptato con la chiave generata
3. la chiave viene cifrata con RSA utilizzando la chiave pubblica del destinatario
4. il destinatario usa RSA con la sua chiave privata per ottenere la chiave simmetrica con cui decodifica il corpo del messaggio

Autenticazione e confidenzialità nello stesso messaggio



Compressione

S/MIME permette di comprimere il messaggio per far risparmiare spazio sia per la trasmissione della mail sia nello storage.

Compatibilità

Quando viene utilizzato S/MIME almeno una parte del messaggio viene cifrata, quindi una parte del messaggio è composta da uno stream di ottetti. Molti sistemi email permettono solo l'uso di blocchi di testo ASCII quindi S/MIME fornisce un servizio di conversione della sezione cifrata in blocchi ASCII.

S/MIME permette di utilizzare anche altri servizi di sicurezza:

- Signed recipient: permette al mittente di dimostrare a un terzo che la mail è stata ricevuta dal destinatario; il destinatario firma tutto il messaggio ricevuto, inclusa la firma del mittente, e appende tutto al messaggio originario.
- Security labels: insieme di informazioni di sicurezza riguardanti la sensibilità del contenuto protetto; le etichette possono essere usate per il controllo degli accessi.
- Secure mailing list: quando un utente invia un messaggio a più destinatari è necessario un lavoro di cifratura ingente (utilizzando le chiavi di ogni destinatario) di cui il mittente può liberarsi affidandolo a un **Mail list agent (MLA)**; il mittente deve solo inviare il messaggio al MLA utilizzando la chiave pubblica del MLA.
- Signing certificates: servizio usato per collegare il certificato del mittente alla sua firma in maniera sicura.

PGP = pretty good privacy

Protocollo per la sicurezza delle mail alternativo a S/MIME. Le differenze fondamentali sono 2:

	S/MIME	PGP
chiavi di certificazione	usato certificati forniti dalle autorità di certificazione	gli utenti generano le loro chiavi pubblica e privata che sono a loro volta firmate da altri individui o autorità
distribuzione delle chiavi		non include la chiave pubblica del mittente in ogni messaggio quindi il destinatario la deve ottenere separatamente.

DNSSEC

DNS

Servizio di risoluzione che fornisce una mappatura tra il nome di un host e il suo indirizzo IP.

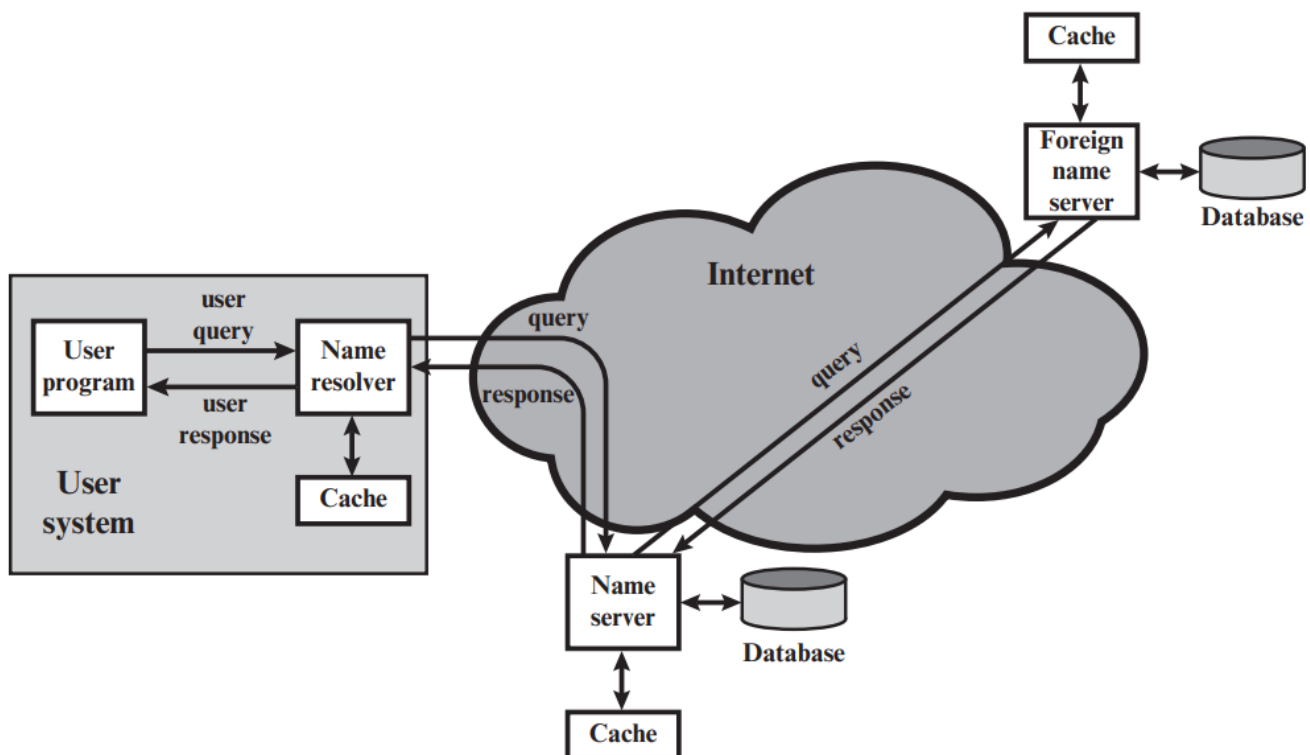
Composto da 4 elementi:

- **domain name space**: struttura ad albero necessaria per la risoluzione
- **database**: contiene i record con le informazioni per la risoluzione (RR = resource record); le funzionalità principali sono:

- gerarchia di profondità variabile per i nomi: con i livelli divisi dal (.)
- database distribuiti
- la distribuzione delle informazioni e il loro aggiornamento sono controllati dall'amministratore di quella zona
- **name servers:** programmi che mantengono le informazioni relative a una porzione del domain name space
- **resolvers:** programmi che estraggono informazioni dai name servers per rispondere alle richieste dei client.

Come avviene la risoluzione:

1. un programma richiede l'indirizzo IP di un dominio
2. nel DNS interrogato un modulo richiede la risoluzione al local name server
3. il local name server controlla se ha il nome richiesto nella cache o nel database e in caso lo restituisce; altrimenti interroga altri name server, quando ottiene la risposta la salva in cache per il TTL del RR
4. al client viene inviata una risposta con l'IP o con un codice di errore



DNSSEC

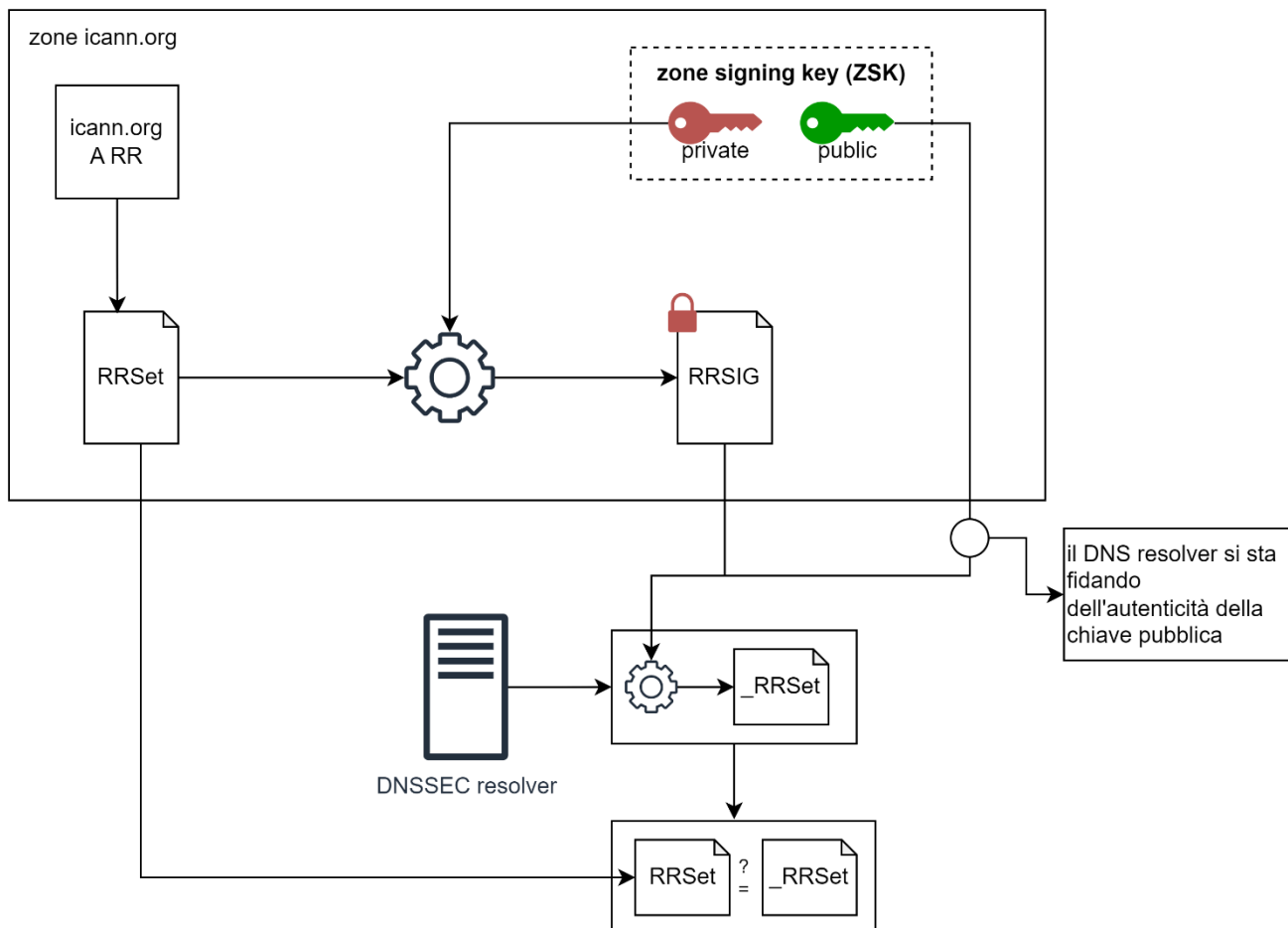
Fornisce protezione end-to-end attraverso l'uso delle firme digitali create dagli amministratori delle zone e verificate dal software di risoluzione del destinatario.

Aggiunge le firme crittografiche ai record DNS esistenti; tali firme vengono memorizzate nei name server DNS insieme agli altri tipi di record.

Controllando la firma associata è possibile verificare che il record non sia stato modificato (ad esempio a seguito di un attacco man in the middle).

Per proteggere un'area con DNSSEC è necessario raggruppare tutti i record dello stesso tipo in un insieme detto RRSSet che verrà firmato.

Ogni zona che contiene diversi RR possiede una coppia di chiavi detta ZSK = zone signing key; la chiave privata di questa coppia è mantenuta al di fuori del DNS stesso per ragioni di sicurezza. Gli RRSSet vengono cifrati con la chiave privata della zona.



Il DNSSEC resolver riesce a capire se i record restituiti dal DNS sono stati alterati confrontandoli con il record ottenuto decifrando con la chiave pubblica della zona l'RRSIG (che è la versione cifrata con la chiave privata della zona del RRSet).

DANE = dns-based authentication of named entities

Autenticazione basata su DNS di entità denominate.

Protocollo che permette di associare certificati digitali X.509 (TLS) a nomi di dominio tramite DNSSEC; serve per autenticare le parti TLS senza un'autorità di certificazione; cerca di risolvere le vulnerabilità di un sistema PKI (public key infrastructure) globale. Se una delle CA viene attaccata tutti i certificati precedentemente rilasciati e quelli che saranno rilasciati in futuro sono compromessi. Lo scopo di DANE è quello di sostituire l'affidamento sulle CA con quello su DNSSEC.

DANE definisce un nuovo tipo di record, TLSA, che può essere usato per autenticare i certificati SSL/TLS.

Il proprietario di un dominio crea un RR TLSA che identifica il certificato e la sua chiave pubblica. Quando un client riceve un certificato X.509 nella negoziazione TLS, esso ottiene il record TLSA per quel dominio e controlla che le informazioni coincidano.

Host Label	TTL	Record Class	Record Type	Certificate Usage	Selector	Matching Type	Certificate Association Data
_443._tcp.host-dane.example.com.	3600	IN	TLSA	3	1	1	0D6FCE13243AA7

Host label: identifica il dominio

TTL: durata del record

Record type: tipologia di record, necessario per identificazione (A, AAA, CNAME ...)

Certificate usage: definisce le regole per l'inserimento di un certificato (ad esempio quali controlli devono essere passati)

Selector:

- 0) l'intero certificato,
- 1) la chiave pubblica dell'utente

Matching type:

- 0) no hash, match del contenuto selezionato
- 1) SHA-256 del contenuto selezionato
- 2) SHA-512 del contenuto selezionato

Certificate association data: il dato che deve essere matchato, se selector è 1 e matching type è 0 allora questo campo contiene la chiave pubblica dell'utente, se matching type è 1 contiene l'hash della chiave e così via.

Sender policy framework

SPF è la modalità standard per il dominio mittente di identificarsi e riconoscere come autorizzato il mittente, per autorizzato si intende che il mittente del messaggio che utilizza un certo dominio può effettivamente usarlo. Il problema che viene indirizzato da SPF è: con l'infrastruttura corrente per l'invio delle mail è possibile che un certo utente invii una mail utilizzando un dominio di cui non fa parte.

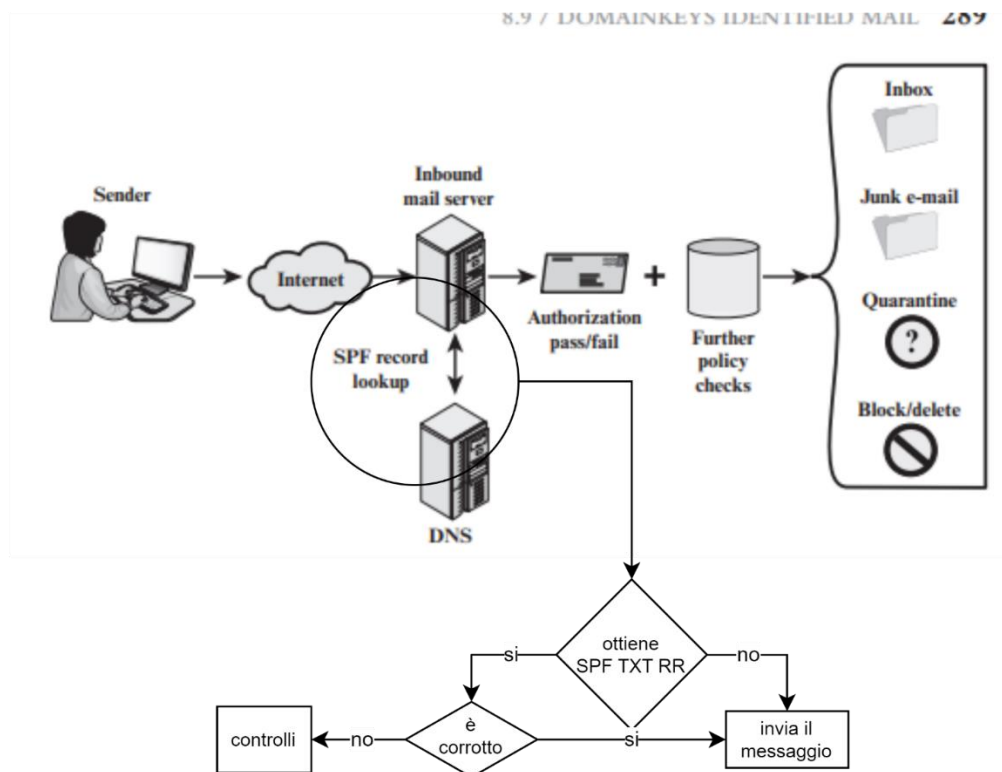
Il protocollo permette agli amministratori dei domini di definire chi può usare il loro dominio nel header from e nel HELO message. Per fare ciò gli amministratori inseriscono nel DNS un record SPF che contiene una whitelist di indirizzi abilitati all'utilizzo del dominio. L'utilizzo del dominio di cui si parla è quello relativo alla connessione SMTP quindi il controllo può essere eseguito prima che la mail venga consegnata al destinatario.

SPF lato mittente

L'amministratore del dominio deve definire delle regole per le quali un certo range di indirizzi IP (o singoli indirizzi IP) sono autorizzati ad utilizzare il dominio stesso e deve inserire queste regole in RR nel DNS.

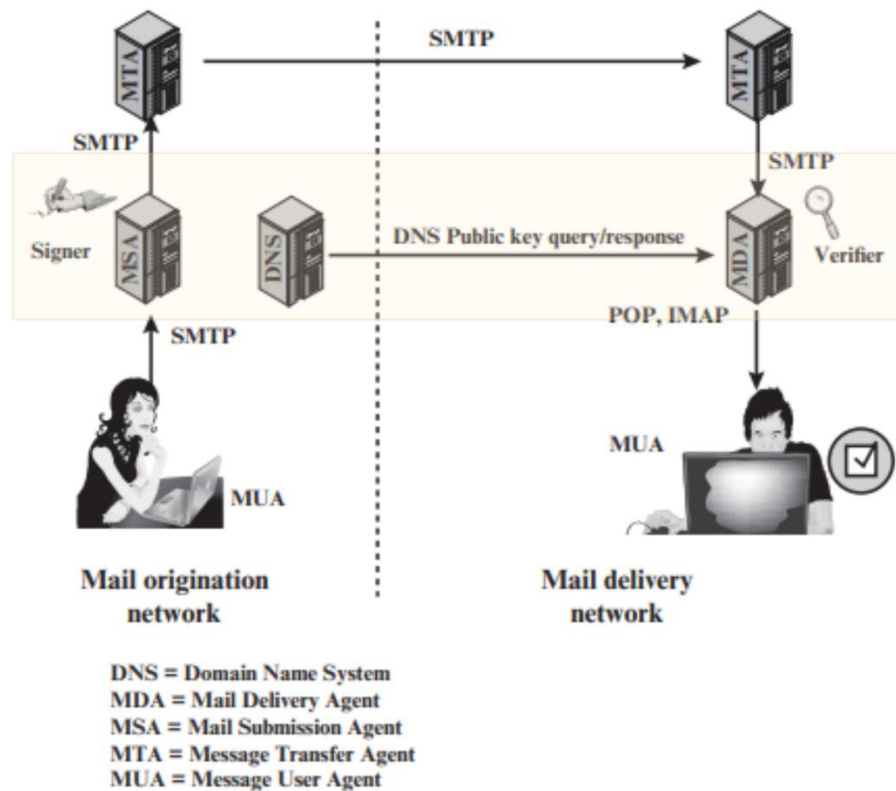
SPF lato destinatario

Se SPF è implementato lato destinatario, l'entità SPF utilizza il FROM nell'envelope della mail e l'indirizzo IP del mittente per capire se il mittente è autorizzato all'uso del dominio.



Domain keys identified mail

Meccanismo che permette al dominio mittente di firmare il messaggio e reclamarne la responsabilità tramite record DNS.



È un approccio trasparente sia al mittente che al destinatario in quanto implementato a livello di MSA e MDA. Viene firmato l'intero messaggio (S/MIME firma solo il contenuto del messaggio, lasciando scoperti gli header).

Indirizza tutti i rischi legati alla falsificazione del mittente.

DMARC = domain based authentication, reporting and conformance

Permette al mittente di specificare le politiche con cui devono essere gestiti i messaggi da lui inviati, lo fa standardizzando il modo in cui il destinatario utilizza SPF e DKIM. Il protocollo stabilisce che il dominio indicato nel FROM header del messaggio matchi l'identificativo di DKIM (l'header deve combaciare con il dominio che ha firmato il messaggio) o SPF (l'header deve matchare il dominio autenticato tramite SPF).

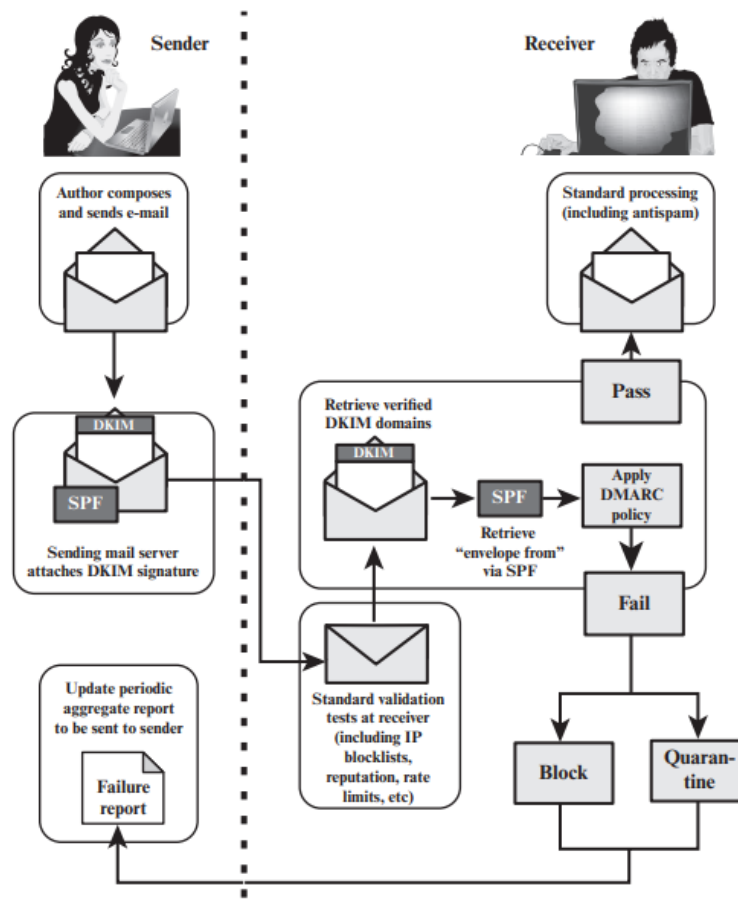
DMARC lato mittente

L'amministratore del dominio deve configurare SPF e/o DKIM e postare un RR contenente le politiche di gestione dei suoi messaggi nel DNS.

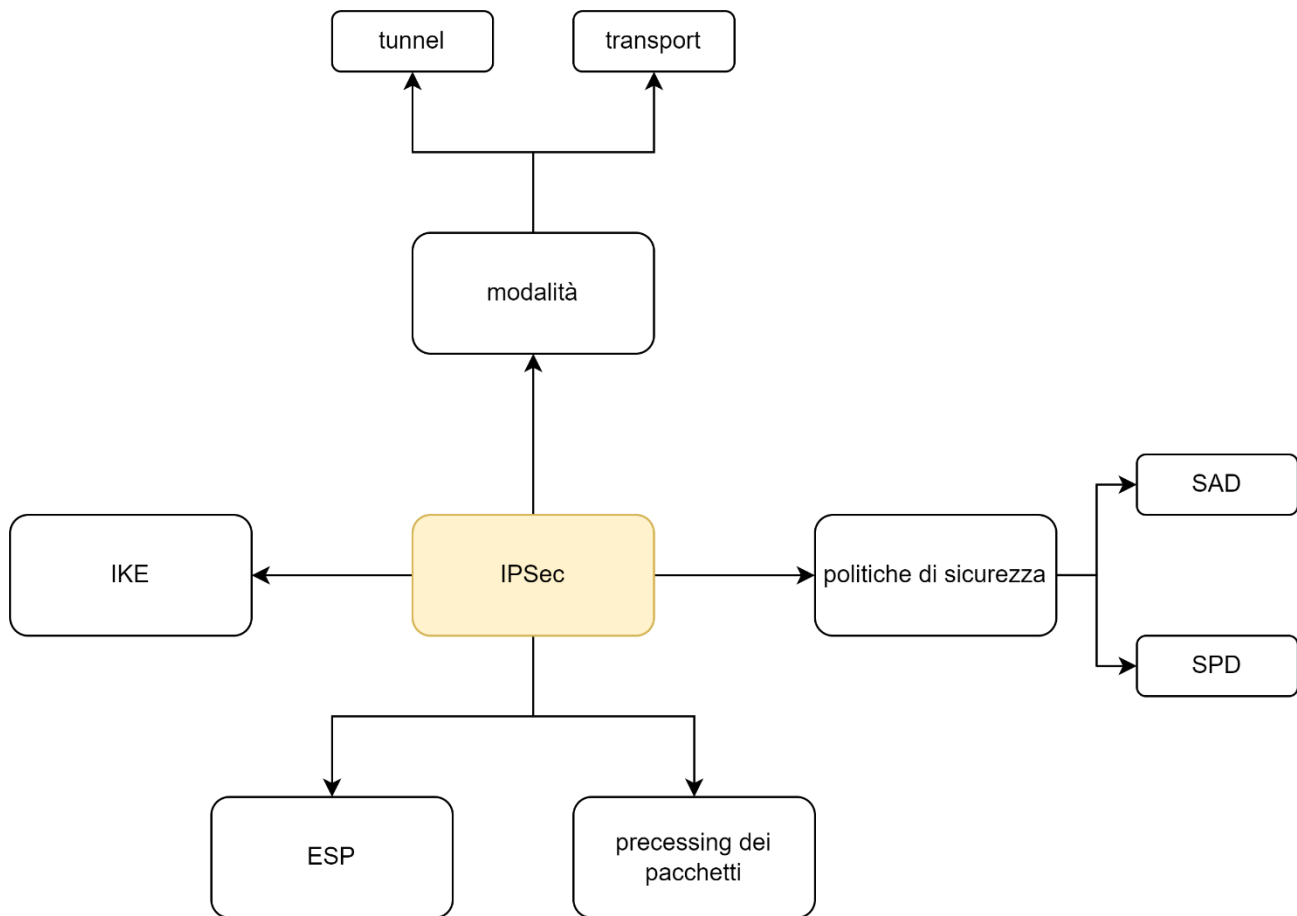
DMARC lato destinatario

Nel momento in cui il destinatario riceve il messaggio esegue i seguenti passi:

1. test di validazione standard, come il controllo che l'IP mittente non sia in quale blacklist
2. estrae il campo from dalla mail e controlla che sia un indirizzo mail valido
3. richiede al DNS il record DMARC del dominio mittente, se non gli viene restituito non viene fatto nessun altro controllo
4. effettua i controlli DKIM
5. richiede il record SPF del mittente e effettua i relativi controlli
6. controlla che il from sia allineato agli identificativi DKIM o SPF
7. tutti i risultati dei controlli sono passati al modulo DMARC che li confronta con le politiche definite nel record DMARC ottenuto
8. se i controlli vengono passati la mail viene inviata al destinatario altrimenti viene generato un report e, coerentemente con le politiche del mittente, questo viene inviato indietro.



09 IPSec



Non è un protocollo, è un insieme di tecniche per garantire la sicurezza del traffico IP. Comprende tecniche per assicurare: autenticazione (ESP), confidenzialità (ESP) e gestione delle chiavi (IKE).

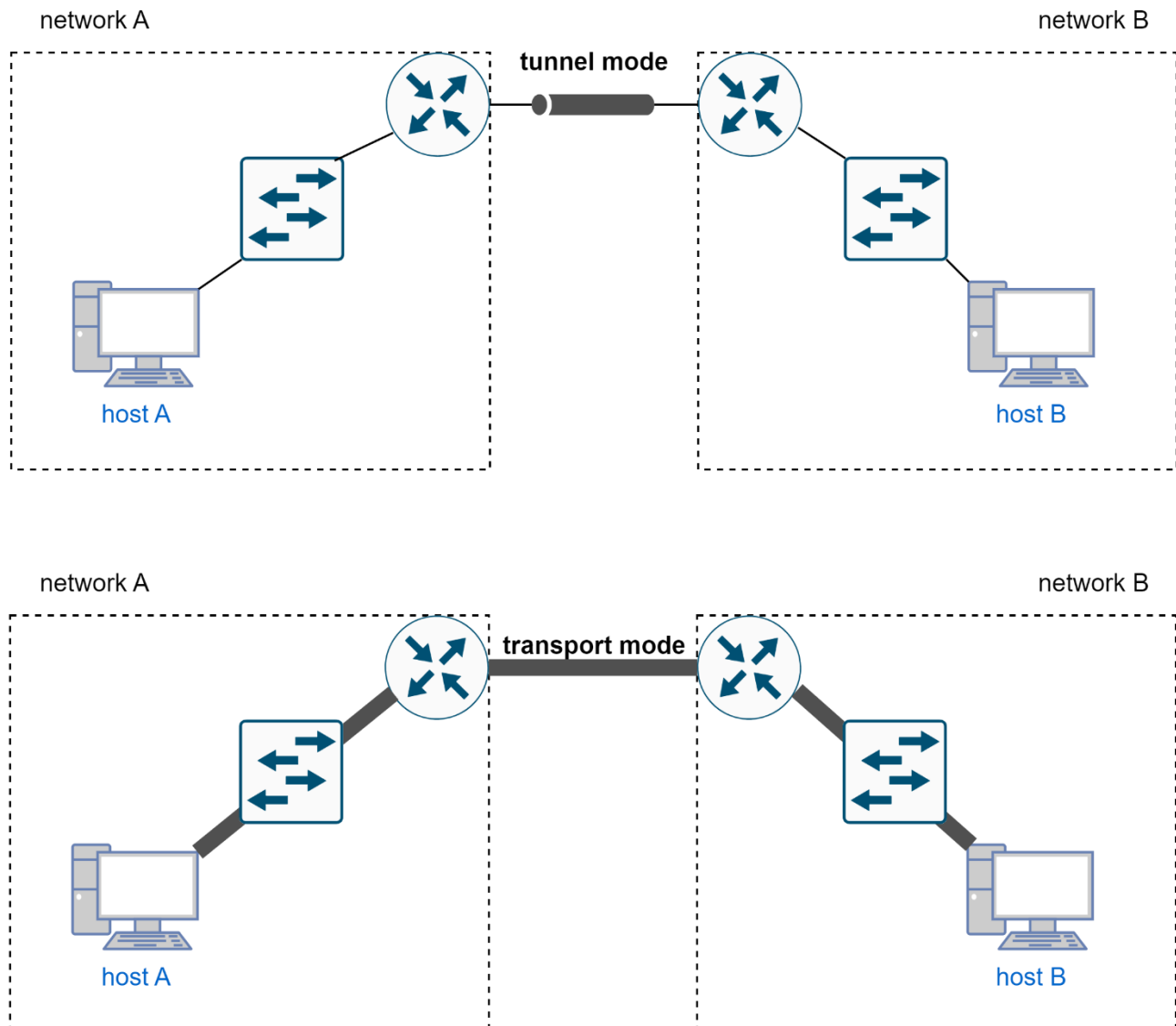
Le parti fondamentali che compongono IPsec sono:

- ESP: encapsulating security payload, meccanismo che fornisce autenticazione e confidenzialità permette di aggiungere dei campi al pacchetto IP (un header e un trailer).
- IKE: internet key exchange, schema di gestione delle chiavi

Modalità

IPsec fornisce sicurezza attraverso due modalità di configurazione della rete:

- **transport mode:** fornisce protezione end-to-end, i pacchetti vengono cifrati/autenticati nel momento in cui partono dal mittente e rimangono tali fino a che non raggiungono il destinatario; viene protetto solo il payload e non l'header in quanto i router nel percorso devono essere in grado di instradare il pacchetto; si dice che fornisce protezione ai protocolli di livello superiore.
- **tunnel mode:** il traffico che viene protetto è quello tra il gateway/firewall della rete a cui appartiene il mittente e quello della rete del destinatario. Viene cifrato l'intero pacchetto, inclusi gli header e esso viene utilizzato come payload di un nuovo pacchetto IP che ha negli header le informazioni necessarie per fare in modo che esso venga recapitato al gateway della rete del destinatario.



Politiche di sicurezza

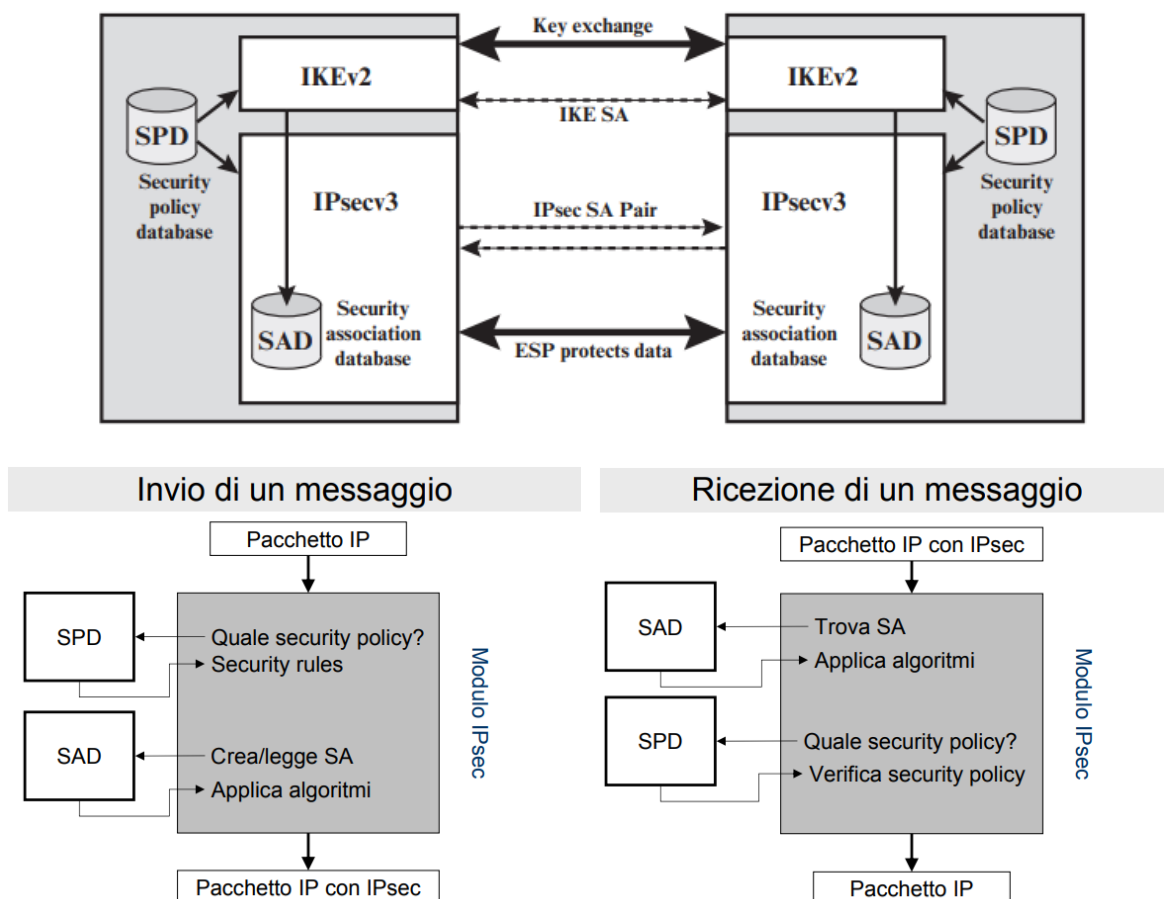
La gestione dei pacchetti IP, quando viene implementata IPsec, è determinata dai dati contenuti in due database: **Security association DB (SAD)** e **Security policy DB (SPD)**.

Una **secure association (SA)** è un'associazione logica tra due host che permette di determinare quali politiche applicare a tutti i pacchetti IP che vengono scambiati tra gli host; una SA è un'associazione a una via, ovvero è identificata dall'indirizzo del destinatario, per creare una policy che regoli il traffico full-duplex è necessario creare due SA. Una SA definisce anche se IPsec viene implementato in tunnel o transport mode.

Le SA sono memorizzate nelle entry di un DB detto **Security association DB**; ogni entry contiene le informazioni identificative della SA, dei meccanismi che devono essere applicati al traffico e il TTL della SA stessa.

Il security policy DB contiene delle regole che definiscono quale traffico deve essere coperto da IPsec; ogni regola contiene:

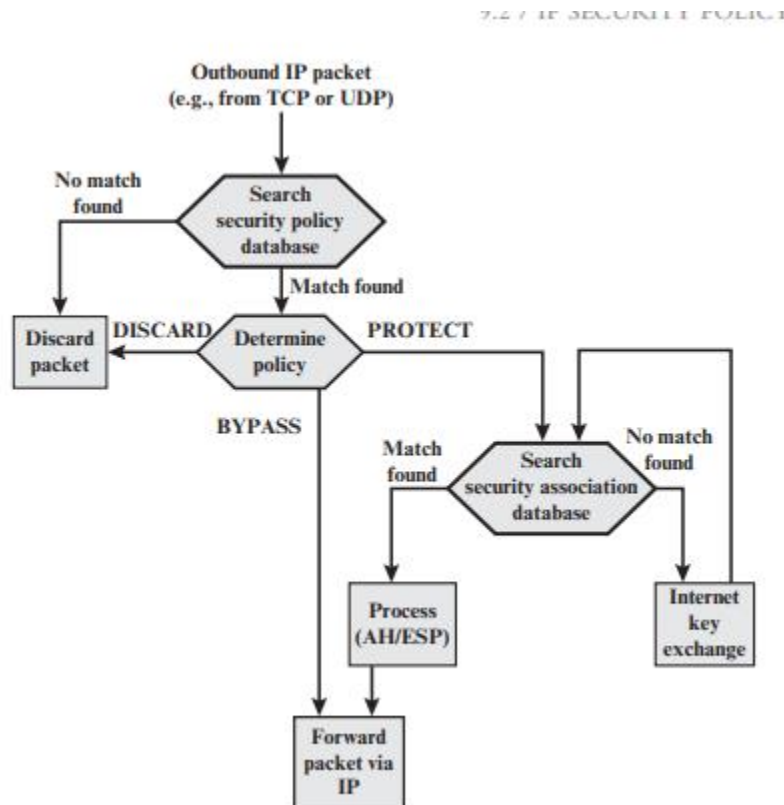
- indirizzo sorgente e di destinazione del pacchetto
- il protocollo e la porta utilizzati
- identificativo di una SA



Processing dei pacchetti

IPsec viene eseguito a livello di pacchetto, quando è implementato ogni pacchetto viene processato sia prima della trasmissione lato mittente che prima del passaggio ai protocolli più alti, lato destinatario.

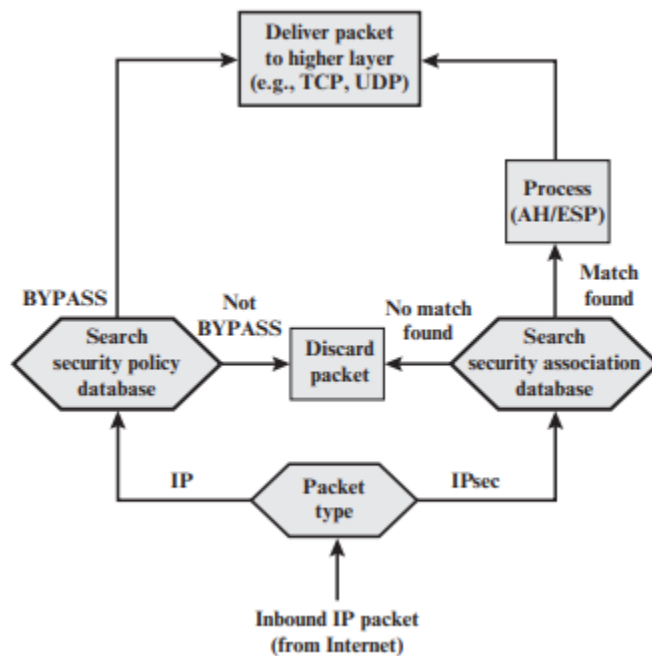
Lato mittente



Quando il livello IP riceve il pacchetto dallo stack protocollare superiore, il modulo IPsec:

- cerca una corrispondenza nel SPD
- se non viene trovata alcuna corrispondenza il pacchetto viene scartato e viene generato un messaggio d'errore
- se viene trovata una corrispondenza ci sono 3 possibilità:
 - la regola è DISCARD → il pacchetto viene eliminato
 - la regola è BYPASS → non vengono fatti altri controlli e il pacchetto viene inviato
 - la regola è PROTECT → viene fatta una ricerca nel SAD, se non viene trovata una corrispondenza viene utilizzato IKE per crearne una, se viene trovata corrispondenza vengono lette le regole per il processing del pacchetto, che può essere cifrato e/o autenticato, in transmission o tunnel mode.

Lato destinatario

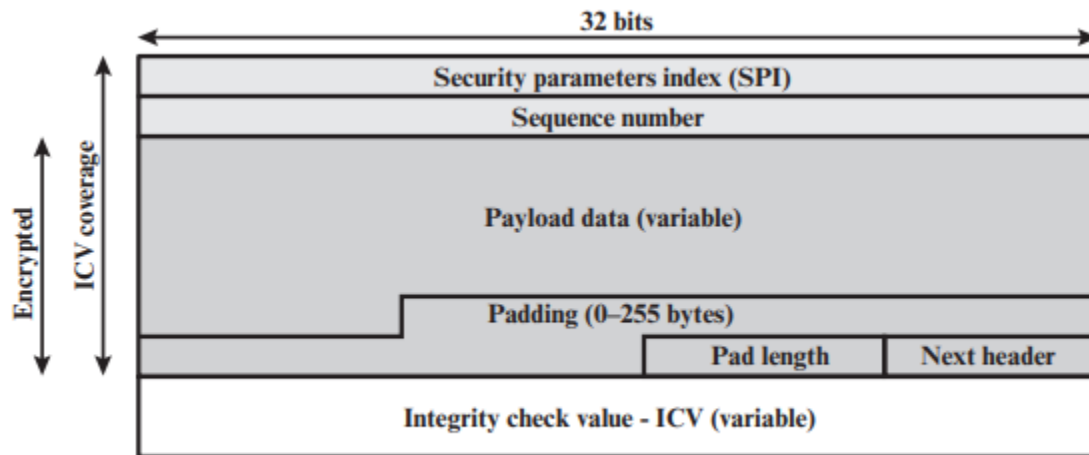


La ricezione di un pacchetto IP triggera il modulo IPsec; vengono seguiti gli step:

- il modulo determina se il pacchetto è protetto
- se il pacchetto non è protetto viene cercata una corrispondenza nel SPD se non viene trovata un'entry o se la regola è PROTECT o DISCARD il pacchetto viene eliminato, se viene trovata una corrispondenza e la regola è BYPASS il pacchetto viene passato al protocollo superiore
- se il pacchetto è protetto viene cercata una corrispondenza nel SAD; se non viene trovata il pacchetto viene eliminato, altrimenti vengono applicati i meccanismi relativi per decifrare o controllare l'autenticità del pacchetto e poi esso viene passato al protocollo superiore

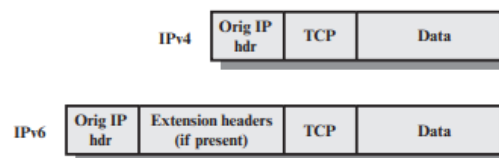
ESP = encapsulation security payload

Meccanismo che fornisce autenticazione, confidenzialità e integrità, dipendentemente dalle opzioni selezionate nella [SA](#).

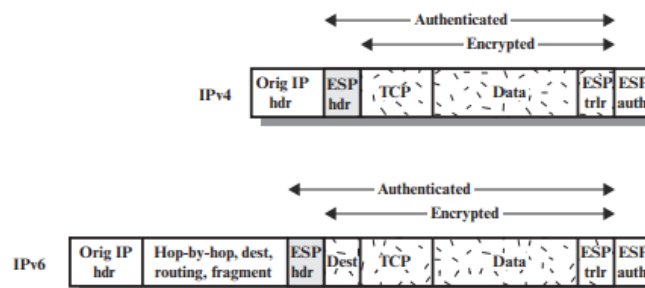


(a) Top-level format of an ESP Packet

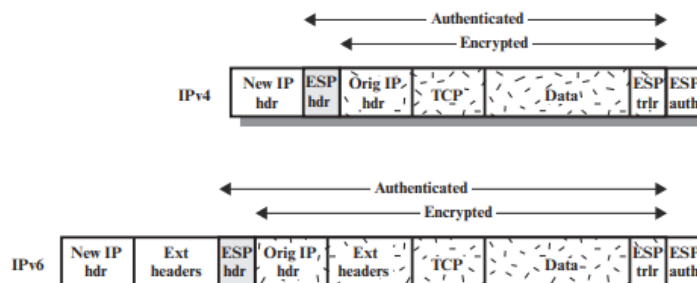
ESP può essere utilizzato sia in transport mode che in tunnel mode.



(a) Before Applying ESP



(b) Transport Mode



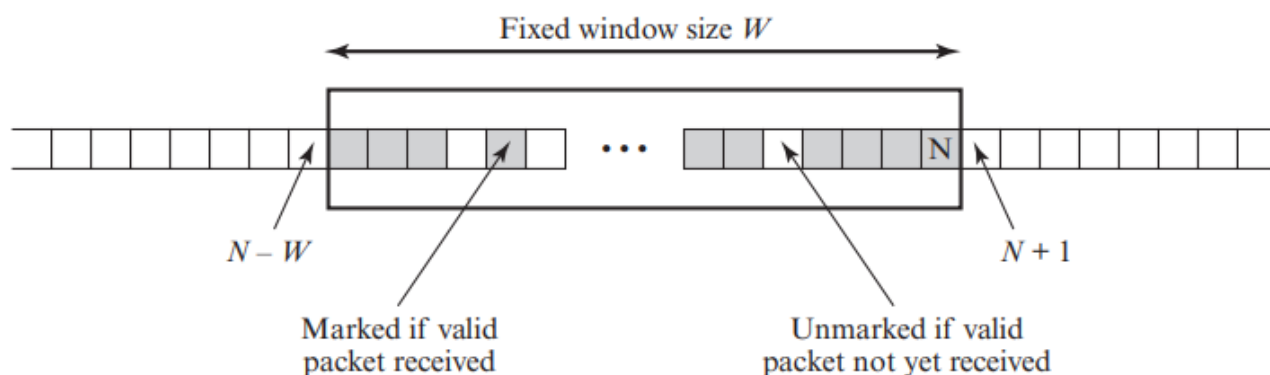
Viene inserito l'header ESP subito prima di quello del protocollo del livello di trasporto e un trailer ESP è inserito alla fine del pacchetto, se viene selezionata anche l'autenticazione viene inserito un ulteriore campo dopo il trailer.

In transport mode viene cifrato il pacchetto IP e il trailer ESP (l'header IP deve essere lasciato intatto per gli instradamenti).

In tunnel mode il pacchetto viene cifrato e utilizzato come payload di un nuovo pacchetto IP che ha gli header necessari per la gestione di IPsec nei gateway delle reti degli host.

Fornisce anche un servizio anti-replay: nel momento in cui viene concordata una SA, il mittente inizializza un numero di sequenza a 0, associato a quella SA. Ogni volta che un pacchetto viene inviato su quella SA, il mittente incrementa il numero di sequenza e lo inserisce nell'header ESP. Il destinatario mantiene una finestra di dimensione W (di default 64); nel momento in cui viene ricevuto un pacchetto il destinatario controlla il numero di sequenza:

- se esso è nella finestra e è nuovo (non è stato già ricevuto un pacchetto con lo stesso numero) lo processa
- se esso è maggiore dell'estremo destro della finestra, la finestra viene fatta scorrere fino a quel numero
- se esso è minore dell'estremo sinistro viene scartato



Combinazione delle associazioni di sicurezza

Possono essere definiti dei **security association bundle** ovvero delle sequenze di SA che permettono di usufruire di un insieme di servizi IPsec invece del solo che può essere fornito dalla singola SA. Le SA che fanno parte di un bundle possono avere diversi indirizzi di destinazione.

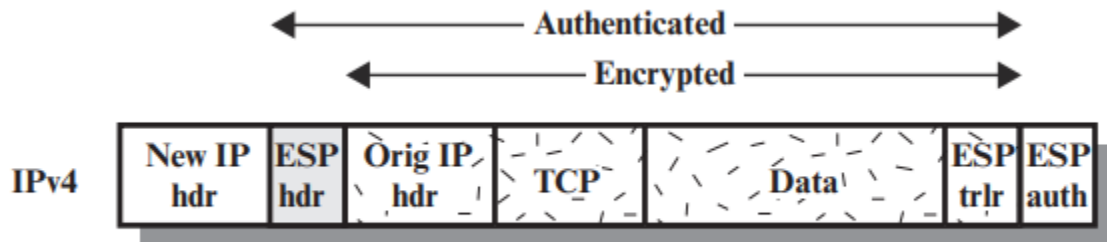
Le SA possono essere combinate in due modi:

- **transport adjacency**: allo stesso pacchetto IP vengono applicate più regole, senza utilizzare il tunneling
- **iterate tunnelling**: permette di definire tunnel di lunghezza diversa e quindi di creare zone in cui si applicano determinate politiche.

Combinazione di autenticazione e cifratura

ESP con l'opzione per l'autenticazione

viene prima applicato ESP ai dati che devono essere protetti e poi viene inserito l'header per l'autenticazione. La cifratura dipende dalla modalità di collegamento, in transport mode viene cifrato solo il payload, in tunnel viene cifrato tutto il pacchetto.



Transport adjacency

autenticazione dopo cifratura

consiste nell'usare due SA di trasporto: la prima di cifratura e la seconda di autenticazione. La prima SA cifra solo il payload, la seconda applica l'header di autenticazione che a questo punto copre tutto il pacchetto.

Transport-tunnel bundle

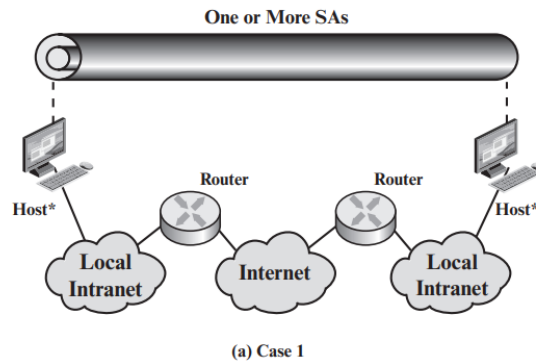
autenticazione prima della cifratura

può essere preferibile autenticare prima di cifrare per proteggere i dati autenticati e perché il destinatario potrebbe dover mantenere le informazioni di autenticazione ed è più agevole farlo se l'autenticazione è applicata al messaggio non criptato.

Combinazioni di SA C:\Users\hanaj\Downloads\Esame_c47fe8a88e5c477db88fe10acacfaf12\Untitled79.png

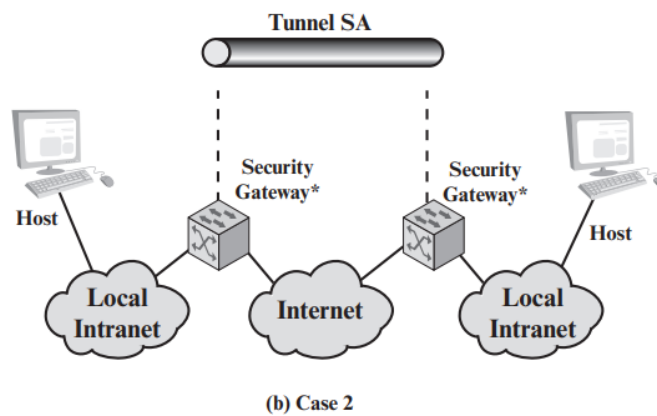
Caso 1

tutti i meccanismi di sicurezza sono implementati nei sistemi finali. Quindi le possibili SA sono: ESP in transport mode, ESP con auth in transport mode, ESP seguito da auth in transport mode, una delle precedenti dentro a una SA in tunnel mode.



Caso 2

tutti i meccanismi sono implementati solo tra i gateway e nessun host implementa IPsec. Non c'è bisogno di creare più regole visto che in tunnel mode viene protetto l'intero pacchetto.

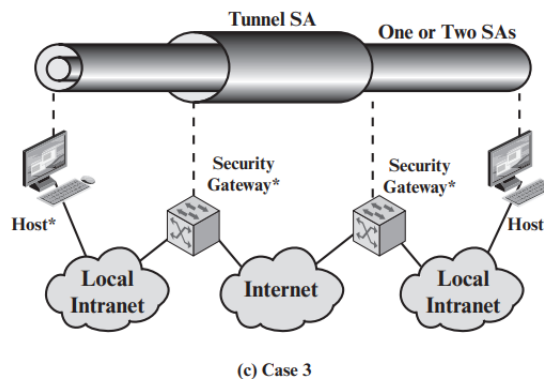


Caso 3

viene costruito a partire dal caso 2 aggiungendo una regola end-to-end. Possono essere applicate tutte le combinazioni del caso 1.

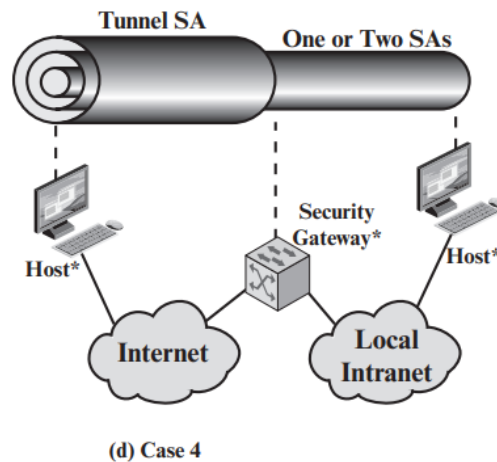
Caso 4

remoto che usa Internet per un'organizzazione e accede



fornisce supporto a un host remoto che usa Internet per raggiungere il firewall di un'organizzazione e accede a un server dietro a esso. È

richiesto solo il tunnel mode tra l'host remoto e il firewall. La comunicazione tra l'host remoto e il server può essere gestita secondo il caso 1.



IKE = internet key extension

IKE

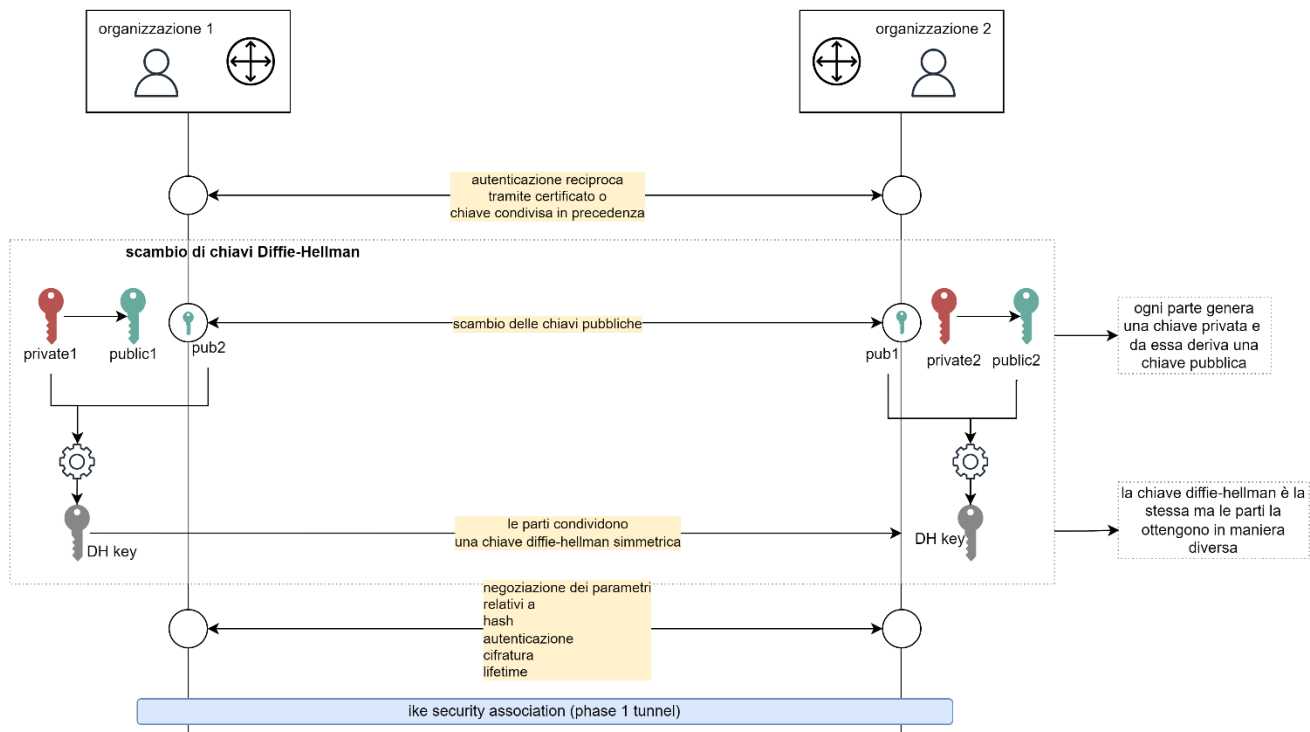
Protocollo utilizzato per negoziare le informazioni necessarie per la creazione delle SA e per i meccanismi di autenticazione/cifratura utilizzati da IPsec.

Gli scambi del protocollo sono distribuiti in due fasi:

- fase 1: lo scopo è stabilire un tunnel sicuro, utilizza il framework ISAKMP (letto isak-mp)
- fase 2: utilizzata per negoziare i parametri che servono a IPsec (le informazioni relative al protocollo di incapsulamento, alla cifratura, all'hashing, alla modalità tunnel o transport)

La suddivisione in due fasi è utile in quanto alla fine di ognuna di esse viene creato un tunnel (la fase uno produce un IKE tunnel mentre la fase due produce un IPsec tunnel), il tunnel della fase 1 richiede molto più tempo per essere costruito ma è riutilizzabile da più tunnel della fase 2 (molto più veloce da creare e utilizzato fin quando c'è traffico da scambiare).

Fase 1

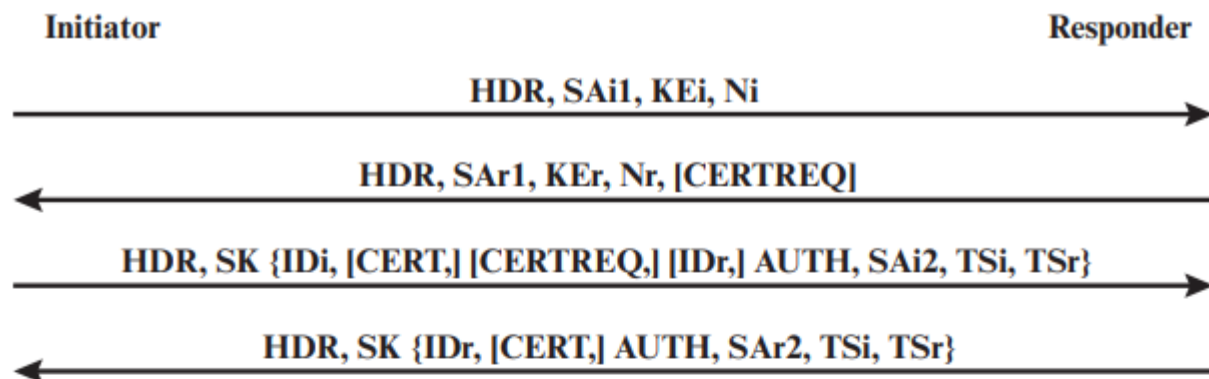


Determinazione delle chiavi

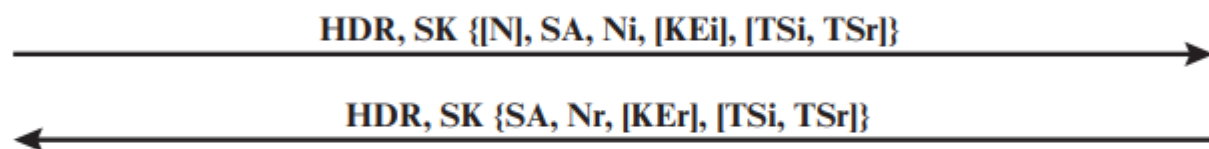
Rifinimento dell'algoritmo Diffie-Hellman:

- impiega un **cookie** per la protezione dagli attacchi di intasamento: un opponente potrebbe contraffare l'indirizzo di una delle due parti e inviare una chiave pubblica Diffie-Hellman alla vittima che inizierebbe il processo di computazione della chiave privata; l'attaccante può inviare molte richieste di questo tipo per danneggiare la vittima. IKE utilizza un cookie (numero pseudo-randomico) che viene inserito nel primo messaggio e che l'altra parte accetta tramite un ack, il cookie deve essere ripetuto nelle successive richieste. Il metodo consigliato per generare il cookie è un fast hash (es MD5) degli IP mittente e destinatario, le porte UDP di invio e destinazione e di un valore segreto generato localmente. Ogni parte genera un cookie, lo invia all'altra e ne riceve l'ack. Tale ack deve essere ripetuto anche durante il primo messaggio dello scambio con DH. Ciò fa in modo che un attaccante possa indurre la vittima a generare ack ma non ad intraprendere uno scambio DH.
- impiega un **nonce** per la protezione dagli attacchi di replica: ogni nonce è un numero pseudo-randomico
- gli scambi sono autenticati tramite firma digitale, cifratura a chiave pubblica o a chiave simmetrica.

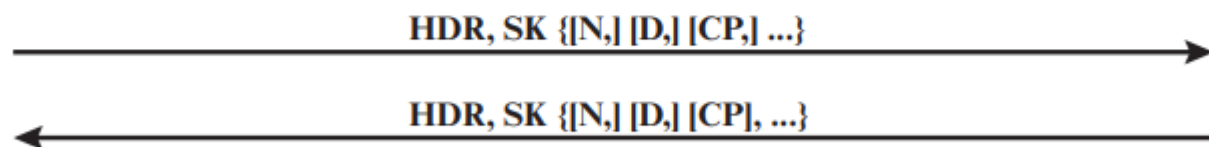
Come avviene lo scambio



(a) Initial exchanges



(b) CREATE_CHILD_SA exchange



(c) Informational exchange

HDR = IKE header

SAr1 = offered and chosen algorithms, DH group

KEi = Diffie-Hellman public key

Nx = nonces

CERTREQ = Certificate request

IDx = identity

CERT = certificate

SK {...} = MAC and encrypt

AUTH = Authentication

SAr2 = algorithms, parameters for IPsec SA

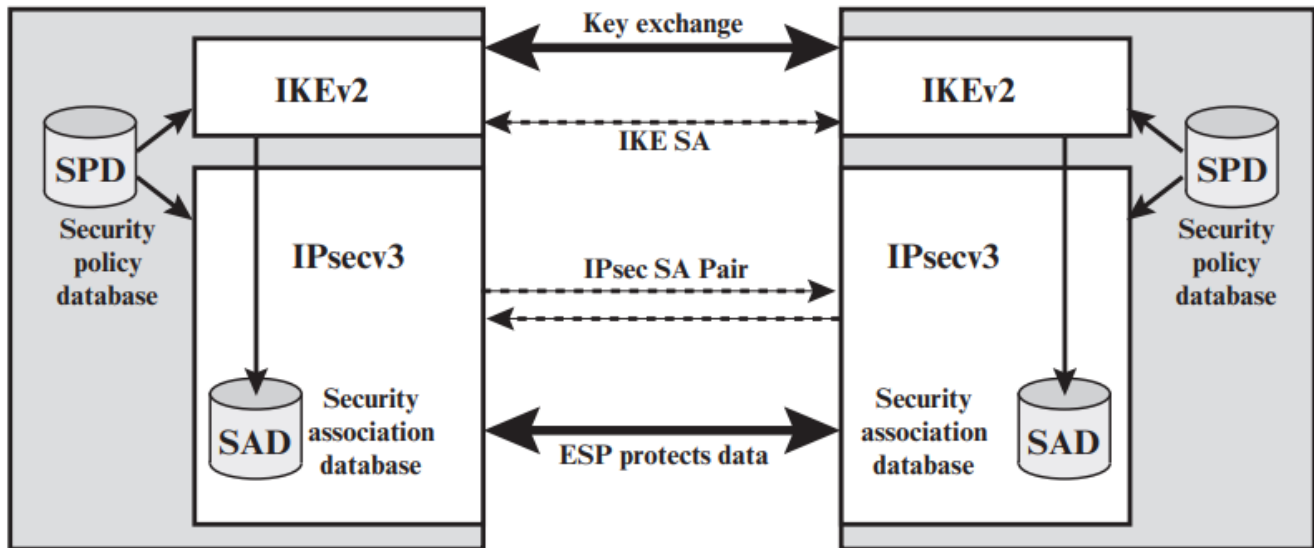
TSx = traffic selectors for IPsec SA

N = Notify

D = Delete

CP = Configuration

i primi scambi (a) servono per concordare gli algoritmi di cifratura e altri parametri che utilizzeranno successivamente. Il risultato di questo scambio è la creazione di una SA detta IKE SA che definisce i parametri per la creazione di un canale sicuro tra i peers.



Nel secondo scambio (b) le due parti si autenticano e inizializzano un primo IPsec SA che sarà collocato nel SAD e utilizzato per proteggere le comunicazioni ordinarie (non-IKE) tra i pari.

L'ultimo scambio serve per veicolare le informazioni di gestione come i messaggi di errore.

Scambio SA

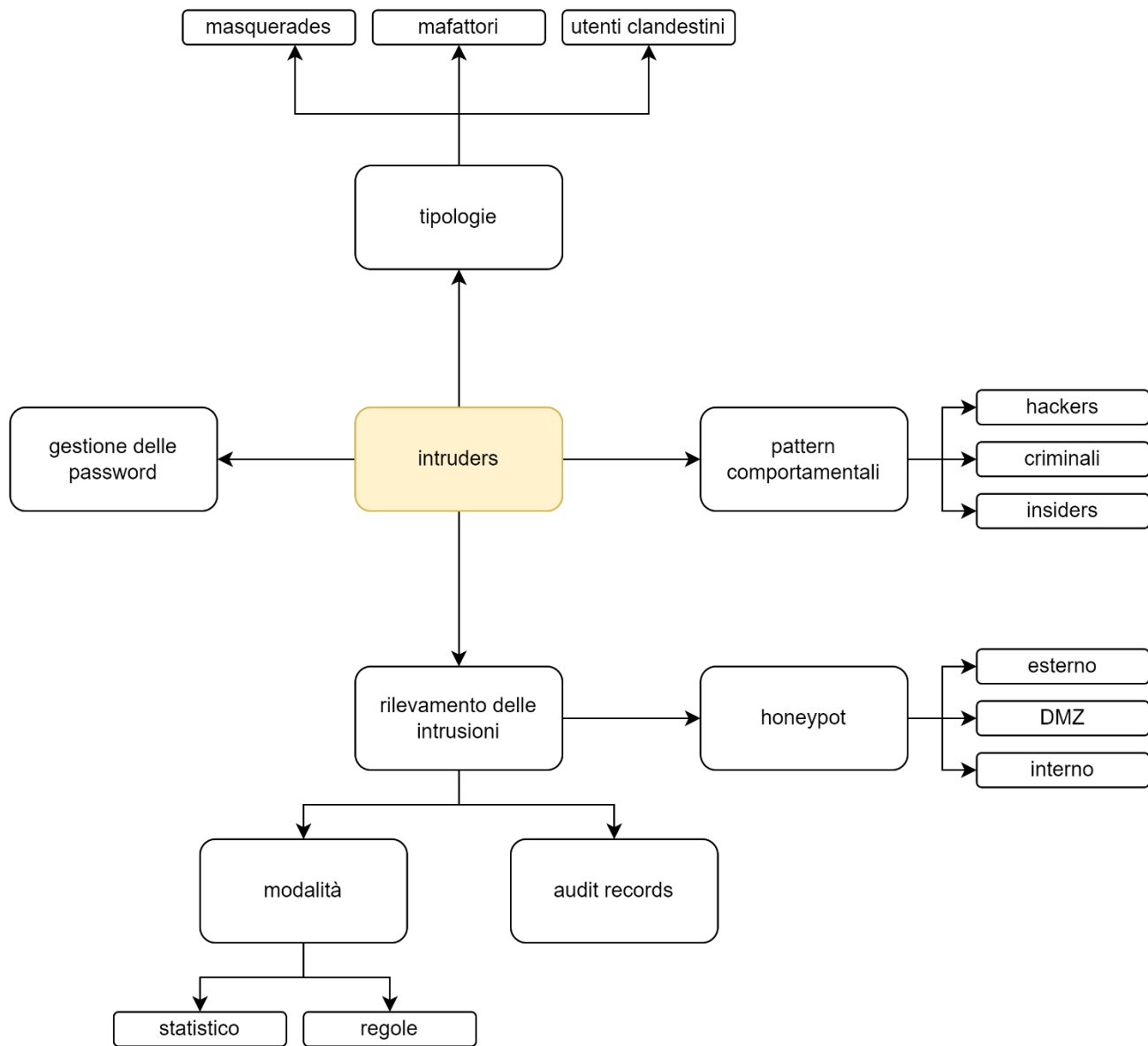
IKE definisce una procedura e un formato di pacchetti per creare, negoziare, modificare e cancellare le SA.

Un messaggio IKE consiste di un header seguito da uno o più payload, il tutto gestito da un protocollo di trasporto (UDP).

Tipi di payload

Type	Parameters
Security Association	Proposals
Key Exchange	DH Group #, Key Exchange Data
Identification	ID Type, ID Data
Certificate	Cert Encoding, Certificate Data
Certificate Request	Cert Encoding, Certification Authority
Authentication	Auth Method, Authentication Data
Nonce	Nonce Data
Notify	Protocol-ID, SPI Size, Notify Message Type, SPI, Notification Data
Delete	Protocol-ID, SPI Size, # of SPIs, SPI (one or more)
Vendor ID	Vendor ID
Traffic Selector	Number of TSs, Traffic Selectors
Encrypted	IV, Encrypted IKE payloads, Padding, Pad Length, ICV
Configuration	CFG Type, Configuration Attributes
Extensible Authentication Protocol	EAP Message

11 Intruders



Le intrusioni consistono nell'acquisizione dell'accesso non autorizzato a un determinato sistema o nell'acquisizione di privilegi da parte di utenti che normalmente non ne usufruiscono.

Intrusi

Possono essere suddivisi in tre classi:

- **masquerades**: individui che non sono autorizzati ad utilizzare un sistema che accedono utilizzando l'account di un altro utente.
- **malfattori**: utenti legittimi che accedono dati, programmi o risorse che non sono autorizzati ad accedere.
- **utenti clandestini**: individui che prendono il controllo del sistema di vigilanza (riconoscimento degli attacchi).

Pattern comportamentali

I pattern comportamentali degli intrusi cambiano costantemente per evitare che le regole volte ad intercettare proprio quei pattern blocchino gli attacchi. Comunque ogni tipo di attaccante segue un pattern collegato proprio alla sua tipologia:

- **hackers**: attaccano i sistemi con lo scopo di dimostrare le loro capacità e condividere informazioni con la comunità. I sistemi di prevenzione e rilevamento delle intrusioni sono pensati per proteggere i sistemi da tali attacchi. Tali sistemi sono tarati sulle vulnerabilità scoperte da enti preposti che pubblicano dei report, accessibili anche dagli attaccanti.
- **criminali**: gruppi organizzati di hackers che hanno obiettivi studiati e mirano ad ottenere l'accesso al sistema, collezionare più dati possibile e uscire velocemente.
- **insider**: gli attaccanti hanno conoscenza del sistema e dei pattern comportamentali ritenuti innocui.

Tecniche di intrusione

L'obiettivo degli intrusi è guadagnare l'accesso a un sistema o aumentare i privilegi che posseggono. Conoscendo la password di un utente un intruso può accedere al sistema con i suoi privilegi; tipicamente un sistema mantiene un file di associazione tra gli ID degli utenti e le loro pswd. Il file può essere protetto in due modi:

- **one-way function**: il sistema mantiene l'associazione tra l'ID dell'utente e l'output di una funzione di hashing prodotto dandole in input la pswd dell'utente.
- **controllo degli accessi**: il file può essere acceduto solo da utenti con determinati privilegi

Rilevamento delle intrusioni

Anche il miglior sistema di prevenzione può fallire quindi si rende necessaria l'implementazione di un sistema di rilevamento, motivato anche da:

- la possibilità di identificare e espellere l'intruso se il rilevamento è abbastanza veloce
- l'utilizzo come deterrente
- la possibilità di collezionare informazioni sulle intrusioni da utilizzare per i sistemi di prevenzione

Il rilevamento è basato sull'assunto che il comportamento di un intruso deve differire in qualche modo da quello di un utente legittimo; devono essere studiate delle regole per definire quando un comportamento sia ritenuto pericoloso e tali regole devono produrre il minor numero possibile di falsi positivi e falsi negativi.

Audit records

Strumento fondamentale per il rilevamento delle intrusioni. Un audit record è la registrazione del comportamento di un utente; servono per confrontare comportamenti sospetti con quelli considerati normali.

Elementi contenuti in un audit record:

- soggetto: chi svolge l'azione
- azione
- oggetto: elemento su cui viene svolta l'azione
- eventuali eccezioni
- uso delle risorse: numero di risorse utilizzate (gli intrusi possono essere identificati per il volume di risorse utilizzate)
- timestamp

Approcci di rilevamento

- **rilevamento statistico**: prevede che vengano collezionate informazioni riguardanti il comportamento degli utenti legittimi durante un periodo di tempo. I comportamenti osservati vengono poi testati per capire di quale natura sono, questi test possono essere fatti utilizzando una **soglia** che stabilisce la frequenza normale di un determinato avvenimento oppure utilizzando un **profilo** che stabilisce quali sono le azioni normali per un certo utente.
- **basato sulle regole**: viene definito un insieme di regole che possono essere usate per determinare se un certo comportamento fa parte di un pattern. Viene analizzato lo storico degli audit records per identificare dei pattern e per generare automaticamente delle regole che descrivano questi patterns. Nel momento in cui il sistema viene monitorato, i comportamenti degli utenti vengono controllati tramite le regole per determinare se sono allineati con lo storico. Le regole possono essere utilizzate anche per identificare l'intrusione: in

questo caso le regole non definiscono il comportamento normale ma quello dell'intruso, vengono create analizzando strumenti di attacco noti.

Un sistema di rilevamento delle intrusioni perfetto dovrebbe rivelare un numero sostanziale di intrusioni e mantenere il tasso di falsi allarmi minimo.

Rilevamento delle intrusioni distribuito

Tipicamente il rilevamento delle intrusioni avviene tramite strumenti stand-alone. Un'organizzazione potrebbe aver bisogno di difendere un sistema distribuito; l'obiettivo potrebbe essere raggiunto anche implementando su ogni macchina lo strumento stand-alone ma si raggiungono risultati migliori creando un sistema coordinato.

I problemi che possono sorgere durante l'implementazione di un sistema di rilevamento delle intrusioni distribuito sono:

- le varie macchine potrebbero avere a che fare con audit record con diversi formati.
- una o più macchine potrebbero essere usate come punti di collezionamento e analisi, quindi i dati relativi agli audit records vanno trasmessi ed è necessario garantire la confidenzialità e l'integrità di questi dati
- può essere implementato un sistema centralizzato (con una sola macchina che si occupa del collezionamento e dell'analisi dei dati) o decentralizzato. I problemi principali del centralizzato sono: la macchina che mantiene gli audit record può diventare il collo di bottiglia e un single point of failure; lo svantaggio principale del decentralizzato è il coordinamento.

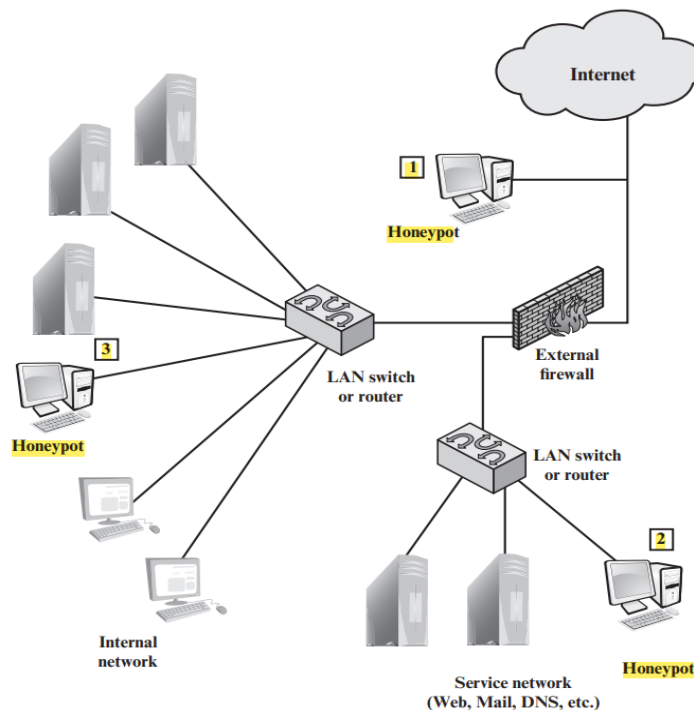
Honeypot

Sistemi progettati per attrarre gli intrusi e tenerli lontani dai sistemi che contengono i veri dati, servono anche a collezionare informazioni sull'intruso.

Tali sistemi vengono riempiti con informazioni che possono sembrare di valore ma che un utente legittimo non accedrebbe mai. Quindi ogni accesso agli honeypot è sospetto, per questo essi sono equipaggiati con sistemi di logging e monitoring. Viene fatto in modo che ogni attacco a un honeypot vada a buon fine per fare in modo che gli amministratori del sistema abbiano tempo per mobilitarsi.

Possono essere costruite anche intere reti fatte di honeypot che emulano il comportamento della rete reale.

Gli honeypot possono essere posizionati in diverse locazioni all'interno della rete:



1. Fuori dal firewall: utile per tracciare i tentativi di connessione agli indirizzi IP non utilizzati nel contesto della rete. Non si hanno sistemi compromessi all'interno della rete ma è inutile verso gli attacchi provenienti dall'interno.
2. DMZ (demilitarized zone): l'honeyot viene piazzato nella zona demilitarizzata, ovvero nella rete che contiene i servizi esterni come i server mail. Solitamente il firewall blocca gli accessi a servizi non necessari verso la DMZ quindi per installare un honeypot in quella locazione c'è bisogno di modificare le regole di protezione.
3. Internamente: l'honeyot viene piazzato nella rete interna insieme agli altri server, in questo modo esso può attrarre gli attacchi interni. Lo svantaggio principale è che potrebbe essere compromesso e utilizzato per attaccare la rete dall'interno.

Gestione delle password

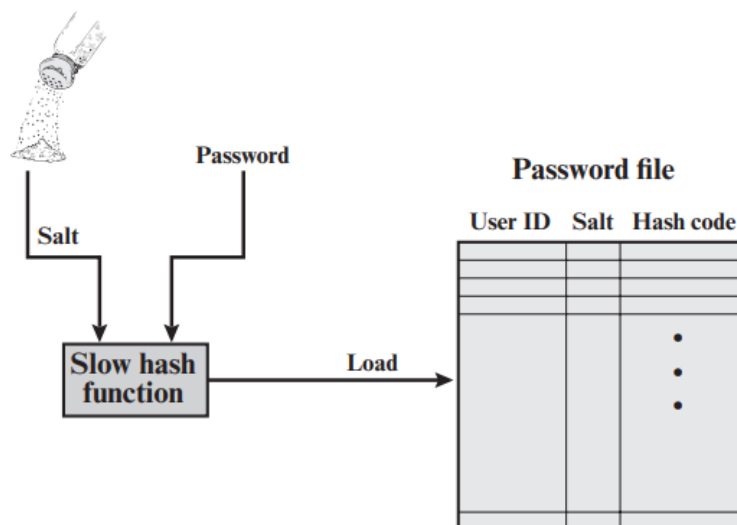
La prima linea di difesa contro le intrusioni è il sistema di password. La password fornita da un utente serve a autenticare l'ID che viene fornito insieme ad essa.

Tipicamente un sistema che basa l'autenticazione sulle password mantiene un file contenente l'associazione tra ID utente e pwd. Invece di memorizzare la password in chiaro è possibile memorizzare il risultato di una funzione di hash che prende in input la pwd.

Le principali strategie per la scoperta delle pwd sono:

- attacco tramite dizionario: se l'attaccante riesce a ottenere il file con le pwd può comparare gli hash con quelli di parole comunemente utilizzate.
- attacco specifico: viene presa una password comune e la si prova in combinazione a diversi ID utente.
- scoperta della pwd di un singolo utente: l'attaccante cerca di ottenere informazioni sull'utente target e sulle politiche del sistema di creazione pwd per indovinare la pwd dell'utente.
- dirottamento della postazione: l'attaccante aspetta fino a che il target non lascia incustodita la postazione di lavoro su cui ha effettuato il login.
- social engineering
- monitoraggio: se la password viene comunicata attraverso una rete essa può essere intercettata

Utilizzo delle funzioni di hash

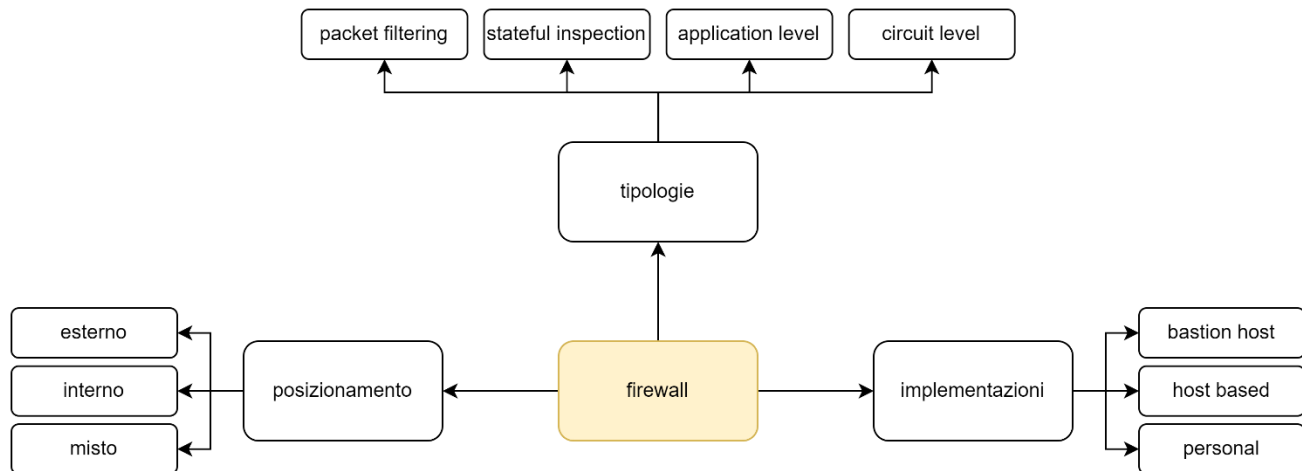


I principali metodi di password cracking sono: viene generato un dizionario di possibili password e viene cercata una corrispondenza nel file con le pwd; viene generato il dizionario e ogni password che esso contiene viene hashata con tutti i possibili salt, il risultato viene detto rainbow table

Scelta della password da parte degli utenti

Visto che la maggior parte degli utenti utilizza pwd facili da indovinare potrebbe essere necessario implementare un sistema che controlla la forza della pwd; tale sistema può agire real-time nel momento in cui l'utente sceglie la sua pwd oppure in maniera schedulata, con lo scopo di rintracciare le pwd memorizzate che possono essere indovinate e consigliare agli utenti di cambiarle.

12 Firewalls



I firewall possono essere un mezzo efficace per la protezione delle reti e dei sistemi dai rischi collegati alla rete.

Casi in cui è necessario un firewall

Nel momento in cui un'organizzazione ha accesso a internet essa può essere raggiunta dall'esterno; anche se è possibile equipaggiare ogni host nella rete con un sistema stand-alone per la protezione dagli attacchi, ciò potrebbe essere non sufficiente. Un'alternativa a questo approccio è l'utilizzo di firewall che permettono di proteggere il collegamento verso l'esterno.

Conviene utilizzare dei firewall anche perché in tal modo le politiche di sicurezza riguardanti l'interazione con internet vengono implementate in un solo punto ed è più semplice aggiornare il sistema nel momento in cui si scoprono delle vulnerabilità.

Caratteristiche dei firewall e politiche di accesso

Gli obiettivi di un firewall sono:

- controllare il traffico in ingresso e in uscita. Tale obiettivo viene raggiunto bloccando tutto il traffico ad eccezione di quello generato dal firewall stesso

- solo il traffico definito sicuro dalle politiche dell'organizzazione può passare attraverso il firewall

Una componente critica nell'implementazione di un firewall sono proprio le politiche che definiscono quale traffico può essere consentito e quale deve essere bloccato.

Le caratteristiche del traffico che possono essere usate per il filtraggio sono:

- indirizzi IP: i controlli vengono fatti sugli indirizzi del mittente e del destinatario o sui numeri di porta o su altri valori dei protocolli di trasporto
- informazioni dei protocolli di applicazione: vengono controllate informazioni relative al livello di applicazione per permetterne l'utilizzo sotto certe condizioni, es possono essere inviate richieste HTTP solo a determinati domini

Caratteristiche principali dei firewall:

- un firewall definisce un singolo punto di ingresso e uscita che tiene gli utenti non autorizzati al di fuori della rete protetta.
- fornisce una locazione per monitorare gli eventi legati alla sicurezza, su di esso possono essere implementati i sistemi di registrazione dei record di controllo.
- possono servire come piattaforme per l'implementazione di IPsec

Le principali limitazioni dei firewall sono:

- non possono proteggere dagli attacchi che bypassano il firewall stesso
- non possono proteggere dagli attacchi interni

Tipi di firewall

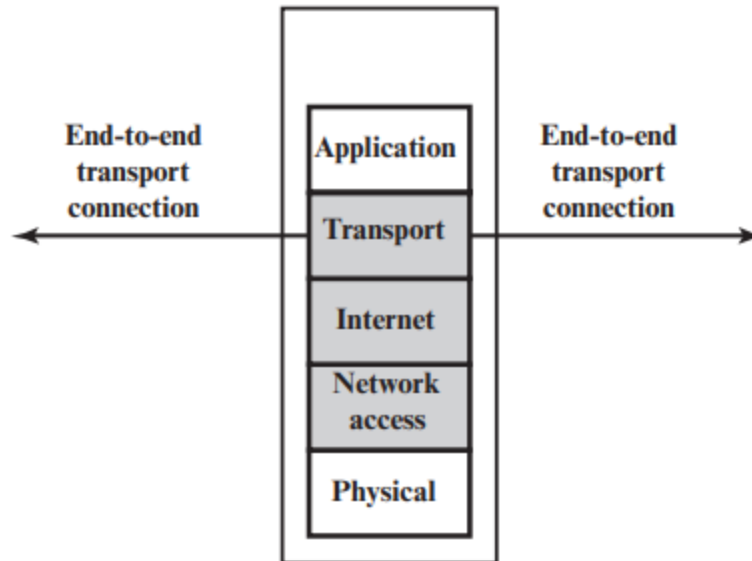
Packet filtering

Applicano una serie di regole a ogni pacchetto IP in ingresso e in uscita e decidono se inviarlo o scartarlo. Le informazioni che possono essere prese in considerazione nelle regole sono: gli indirizzi IP di mittente e destinatario, i numeri di porta delle applicazioni del mittente e del destinatario, il protocollo di trasporto, l'interfaccia su cui arriva il pacchetto e quella a cui è destinato (è possibile creare regole che facciano scartare tutti i pacchetti ricevuti su interfacce rivolte verso l'esterno che hanno come indirizzo del mittente un IP appartenente a una macchina interna).

Nel momento in cui il pacchetto matcha una regola, gli vengono applicate le politiche di quella regola. Se non viene matchata alcuna regola viene applicato il comportamento di default che può essere discard o forward, dipendentemente dalle esigenze dell'organizzazione; il principale rischio della politica di forward come default è che gli amministratori della rete devono essere pronti ad implementare nuove regole nel momento in cui viene scoperto un nuovo rischio.

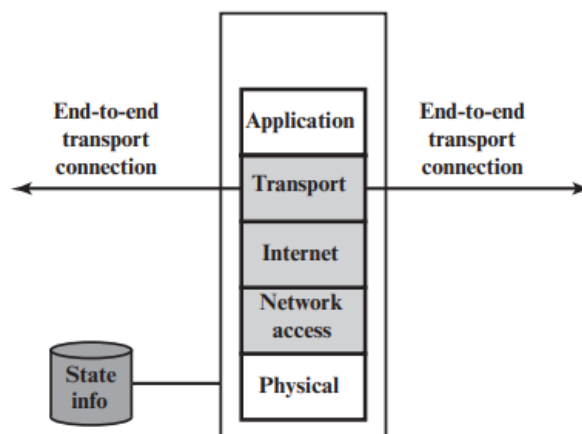
Le principali debolezze di questo tipo di firewall sono:

- visto che non vengono esaminate le informazioni relative al livello di applicazione, essi sono vulnerabili agli attacchi che utilizzano vulnerabilità specifiche dell'applicazione.
- spesso non vengono supportate funzioni di autenticazione
- sono vulnerabili agli attacchi che sfruttano le debolezze delle specifiche di TCP/IP
- visto che possono essere configurate poche regole per decidere se un pacchetto viene inviato o scartato, c'è un alto rischio di malconfigurazione



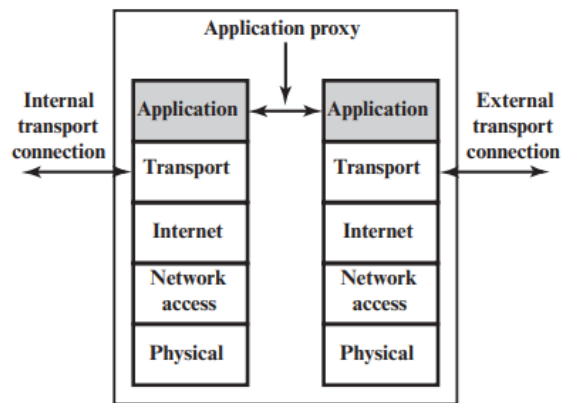
Stateful inspection

Mantengono una tabella con le informazioni che identificano tutte le connessioni TCP verso l'esterno, i pacchetti provenienti dall'esterno vengono fatti passare solo se corrispondono a una di quelle connessioni.



Application level

Gli utenti contattano il firewall tramite un'applicazione TCP/IP, il firewall richiede al client le informazioni di autenticazione e quelle relative al server che vuole contattare. Quando il client fornisce le informazioni viene creata una connessione TCP verso il server. Non tutte le applicazioni sono permesse quindi il traffico che deve essere controllato è un sottoinsieme di quello che attraversa la rete.

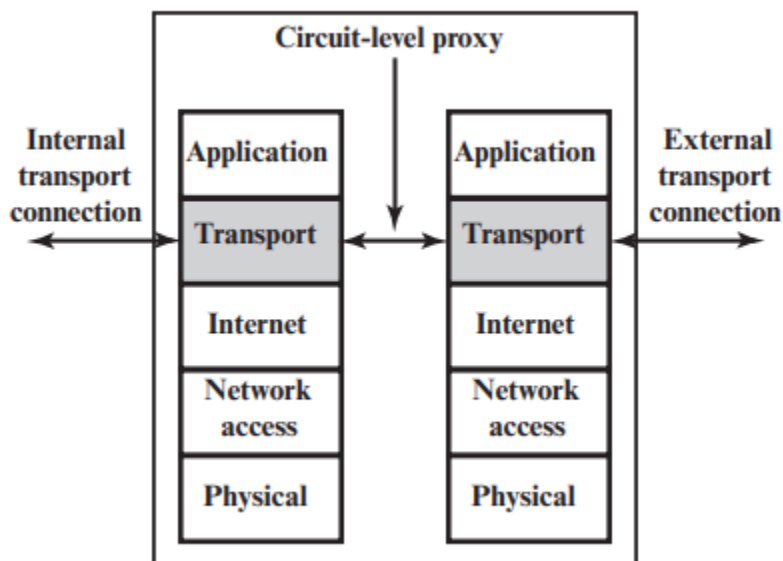


(d) Application proxy firewall

Circuit level

Come nel caso dell'application level, non permette la connessione TCP end-to-end ma deve essere egli a veicolarla. Nel momento in cui deve essere stabilita una connessione tra due host, il firewall ne crea due: una tra esso e il primo host e una tra esso e il secondo host.

Il firewall controlla solo quali connessioni possono essere stabilite, non il traffico che viene inviato su di esse.



Implementazioni

Solitamente i firewall vengono implementati su macchine singole su cui gira un sistema operativo come Linux.

Bastion host

Viene identificata una macchina che si trova in una posizione forte, che contiene solo le applicazioni necessarie per l'implementazione del firewall.

Host-based

Modalità per rendere sicuri gli host, individualmente. Vengono installati dei moduli che svolgono le funzioni desiderate. Una locazione comune per questo tipo di firewall è un server.

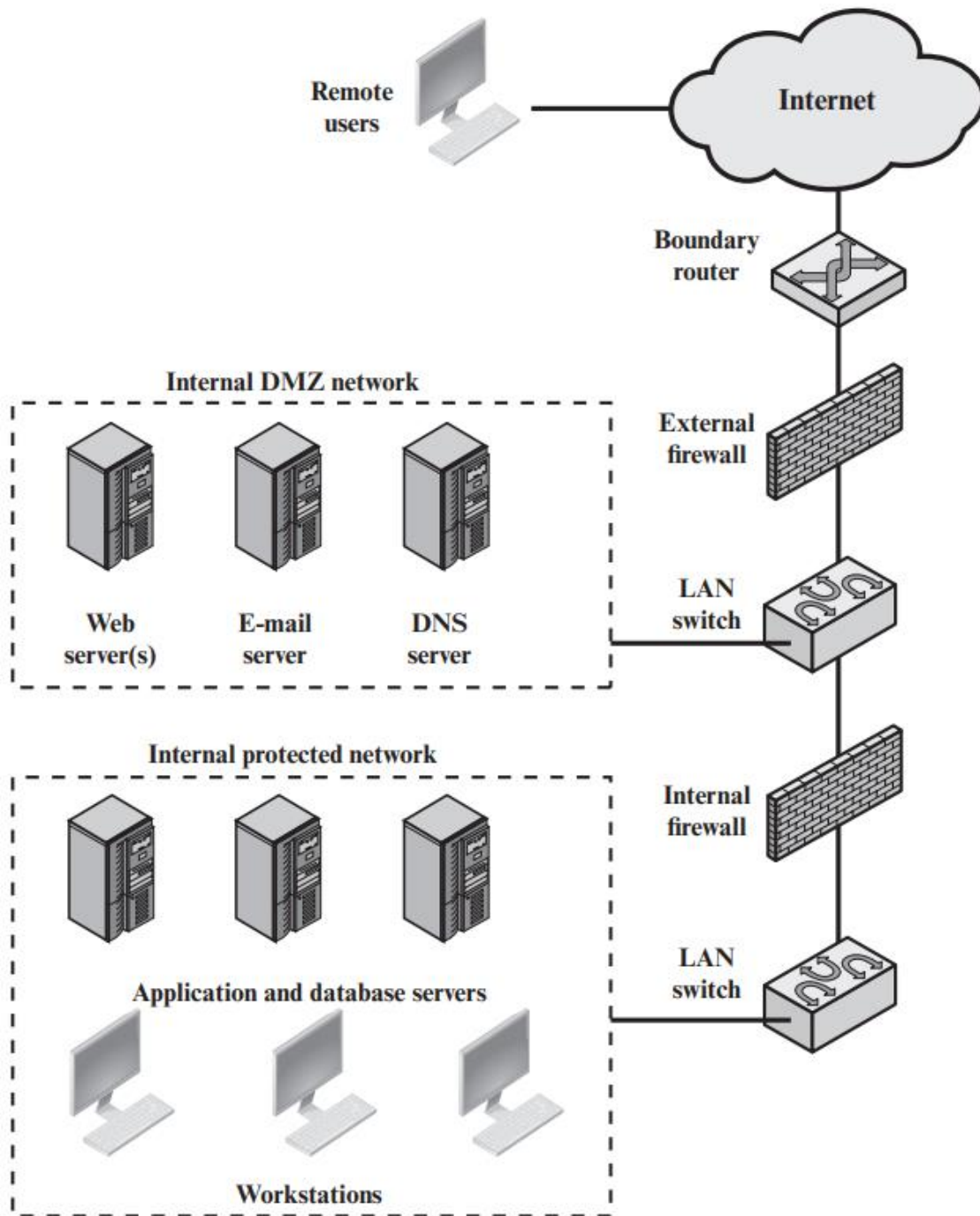
I vantaggi di questo approccio sono :

- le regole di filtraggio possono essere ritagliate sull'ambiente.
- la protezione è indipendente dalla topologia della rete
- livello aggiuntivo di protezione

Personal

Controllano il traffico tra un PC e Internet o la rete aziendale. Sono implementati come moduli software. Il loro principale scopo è quello di bloccare gli accessi remoti non autorizzati alle macchine.

Posizionamento e configurazioni



I firewall possono essere posizionati all'esterno della DMZ, subito prima del router che connette la rete interna a quella esterna.

Possono essere inseriti tra la DMZ e la rete interna in modo da bloccare gli attacchi provenienti dagli host infetti della DMZ stessa.

I firewall possono anche essere distribuiti: viene applicato un approccio misto, ai firewall di sopra vengono aggiunti dei firewall personali.